

Contents

1	基本設計 index(メインシステム)	7
1.1	0. 文書情報	7
1.2	1. 目的・対象範囲	7
1.3	2. 設計方針(全体像)	8
1.4	3. システム構成(全体像)	8
1.5	4. 機能一覧 (FRxx_*.md と基本設計成果物の対応)	8
1.6	5. データフロー(概観)	9
1.7	6. 非機能要件への対応方針(基本)	9
1.8	7. 基本設計ファイル一覧	10
1.9	8. SCR × ドキュメント カバレッジ表	10
1.10	9. 連携 IF × ドキュメント カバレッジ	11
1.11	10. 関連ドキュメント	12
1.12	11. 未確定事項・確認事項	12
2	画面設計書 (メイン)	12
2.1	1. 文書概要	12
2.1.1	1.1 目的	12
2.1.2	1.2 対象範囲	12
2.1.3	1.3 版数	12
2.1.4	1.4 関連ドキュメント	13
2.2	2. 画面一覧	13
2.3	3. 画面遷移	14
2.3.1	3.1 Mermaid 遷移図	14
2.3.2	3.2 主要遷移ルール	14
2.4	4. 共通 UI 部品 + サイドメニュー	14
2.4.1	4.1 既存共通部品 (§ 5.3.1)	14
2.4.2	4.2 UI/UX 共通要件で追加する部品 (§ 5.3.2)	15
2.4.3	4.3 文言の共通基準	15
2.4.4	4.4 サイドメニュー (§ 5.6)	15
2.4.5	4.5 レスポンシブ方針	16
2.5	5. 画面詳細	17
2.5.1	5.1 SCR-001 ログイン	17
2.5.2	5.2 SCR-002 アカウント登録	17
2.5.3	5.3 SCR-003 パスワード再設定	18
2.5.4	5.4 SCR-010 プロジェクト一覧	19
2.5.5	5.5 SCR-010-M1 プロジェクト設定モダール(新規/編集)	20
2.5.6	5.6 SCR-011 未解決質問一覧/詳細	20
2.5.7	5.7 SCR-012 FAQ 管理	22
2.5.8	5.8 SCR-013 個別チャット部屋	24
2.5.9	5.9 SCR-014 ウィジェット設定	26
2.5.10	5.10 SCR-015 利用状況・課金ダッシュボード	27
2.5.11	5.11 SCR-016 設定(退会・課金画面入口)	27
2.5.12	5.12 SCR-017 ユーザー管理	28
2.5.13	5.13 SCR-017-M1 メンバー招待/編集モダール	29
2.5.14	5.14 SCR-018 プライバシーポリシー/利用規約閲覧	30
2.5.15	5.15 SCR-021 お知らせ一覧	31
2.5.16	5.16 SCR-022 お知らせ詳細	32
2.5.17	5.17 SCR-023 メール確認	32
2.5.18	5.18 SCR-024 退会申請	33
2.5.19	5.19 SCR-025 規約再同意割込み	34
2.5.20	5.20 SCR-027 エンドユーザー再入室	34
2.6	6. ユーザー種別別表示制御 (§ 5.5)	35
2.7	7. エンドユーザー向け画面の共通方針 (§ 5.7)	35
2.8	8. 未決事項	35
2.9	9. 変更履歴	35
3	API 設計書 (メイン)	36
3.1	1. 文書概要	36
3.1.1	1.1 目的	36
3.1.2	1.2 対象範囲	36

3.1.3	1.3 版数	36
3.1.4	1.4 関連ドキュメント	36
3.2	2. API 一覧	36
3.2.1	2.1 機能と API の対応 (§ 6.3)	36
3.2.2	2.2 外部 I/F 一覧 (§ 8.1)	37
3.3	3. 共通仕様	37
3.3.1	3.1 API 共通仕様 (§ 8.2)	37
3.3.2	3.2 オーナー境界判定	37
3.3.3	3.3 幂等性キー	37
3.3.4	3.4 Webhook 共通仕様 (§ 8.7.3)	37
3.3.5	3.5 連携 IF エンドポイント命名規約 (§ 8.8)	38
3.3.6	3.6 認証ヘッダ	38
3.4	4. レート制限・キャパシティ (§ 11.7 リミット設計表の正本)	38
3.5	5. API 詳細	39
3.5.1	5.1 認証 API	39
3.5.2	5.2 利用者(メンバー)API	40
3.5.3	5.3 プロジェクト管理 API	41
3.5.4	5.4 FAQ 管理 API	42
3.5.5	5.5 ウィジェット API	42
3.5.6	5.6 未解決質問 API	43
3.5.7	5.7 チャット API	43
3.5.8	5.8 利用量・課金 API	43
3.5.9	5.9 お知らせ受信箱 API	44
3.5.10	5.10 規約・退会 API	44
3.5.11	5.11 AI 推論 IF(AnswerProvider 抽象化)	45
3.5.12	5.12 メール配信 IF(EmailProvider 抽象化)	45
3.5.13	5.13 連携 IF(受信側、メイン側エンドポイント)	45
3.5.14	5.14 外部 Webhook(Resend 等)	48
3.6	6. 連携 IF 通信仕様一覧	49
3.7	7. 未決事項	49
3.8	8. 変更履歴	49
4	テーブル定義書 (メイン)	49
4.1	1. 文書概要	49
4.1.1	1.1 目的	49
4.1.2	1.2 対象範囲	49
4.1.3	1.3 版数	50
4.1.4	1.4 関連ドキュメント	50
4.2	2. テーブル一覧	50
4.2.1	2.1 retention_class 値の正本定義 (audit_logs.retention_class)	52
4.2.2	2.2 主要関係性 (§ 7.3 から移管)	52
4.2.3	2.3 メンバー権限保持方式(設計判断履歴、 § 7.1.1 から移管)	52
4.3	3. テーブル詳細	52
4.3.1	3.1 accounts (アカウント)	52
4.3.2	3.2 account_permissions (メンバー権限)	53
4.3.3	3.3 account_project_grants (メンバープロジェクト割当)	54
4.3.4	3.4 sessions (セッション)	54
4.3.5	3.5 access_tokens (アクセストークン)	54
4.3.6	3.6 projects (プロジェクト)	54
4.3.7	3.7 project_legacy_keys (レガシー API キー)	55
4.3.8	3.8 allowed_domains (許可ドメイン)	55
4.3.9	3.9 faqs (FAQ)	55
4.3.10	3.10 faq_revisions (FAQ 改訂履歴)	56
4.3.11	3.11 faq_search_fts (FAQ 全文検索、FTS5 仮想テーブル)	56
4.3.12	3.12 question_logs (質問ログ)	56
4.3.13	3.13 inquiries (案件)	57
4.3.14	3.14 inquiry_status_history (案件状態履歴)	57
4.3.15	3.15 inquiry_contacts (エンドユーザー連絡先、PII 暗号化)	58
4.3.16	3.16 chat_rooms (個別チャット部屋)	58
4.3.17	3.17 chat_messages (チャットメッセージ)	58
4.3.18	3.18 notification_logs (通知ログ)	59
4.3.19	3.19 ai_threshold_persistent_cache (AI しきい値キャッシュ)	59

4.3.20	3.20	email_suppression_list (メールサプレスリスト、全契約横断)	59
4.3.21	3.21	audit_logs (監査ログ、メイン側)	60
4.3.22	3.22	error_logs (エラーログ)	60
4.3.23	3.23	billing_subscriptions (課金サブスクリプション)	60
4.3.24	3.24	billing_invoices (請求書、7年保持)	61
4.3.25	3.25	usage_metering (利用量計測)	61
4.3.26	3.26	owner_quota_overrides (契約別レート / 予算上書き、統一実装)	61
4.3.27	3.27	service_announcements (お知らせ Control Plane)	62
4.3.28	3.28	announcement_recipients (お知らせ配信先 Control Plane)	62
4.3.29	3.29	inbox_messages (受信箱 Tenant Plane)	63
4.3.30	3.30	withdrawal_requests (退会申請)	63
4.3.31	3.31	terms_versions (規約版数、全契約横断)	63
4.3.32	3.32	terms_agreements (規約同意)	63
4.4	4.	ER 図 (主要部分、§ 7.2 から移管)	64
4.5	5.	テーブル間関連 (§ 2.2 と同期)	64
4.6	6.	命名規則・型方針 (§ 7.5 から移管)	64
4.7	7.	SaaS データ分離観点	65
4.7.1	7.1	オーナー境界によるデータ分離方式 (§ 2.6 + § 7.1 から移管)	65
4.7.2	7.2	オーナー行とメンバー行の判定	65
4.7.3	7.3	全契約横断テーブル (owner_account_id を持たない)	65
4.8	8.	状態コード値・状態遷移 (§ 4.x から移管)	65
4.8.1	8.1	FAQ 状態遷移 (faqs.status)	65
4.8.2	8.2	案件状態遷移 (inquiries.case_status 、共有概念正本)	65
4.8.3	8.3	チャット部屋自動クローズ 6 段階 (chat_rooms.reminder_state)	65
4.8.4	8.4	通知状態遷移 (notification_logs.delivery_state)	66
4.8.5	8.5	契約状態遷移 (accounts.contract_status 、共有概念正本)	66
4.9	9.	データ削除モード (§ 7.8 から移管)	67
4.10	10.	データ保持の調整制約 (§ 11.4.1 から移管)	67
4.11	11.	PII 取扱 (§ 7.10 から移管)	67
4.12	12.	インデックス方針 (§ 7.6 から移管)	67
4.13	13.	未決事項	67
4.14	14.	変更履歴	68
5		権限設計書 (メイン)	68
5.1	1.	文書概要	68
5.1.1	1.1	目的	68
5.1.2	1.2	対象範囲	68
5.1.3	1.3	版数	68
5.1.4	1.4	関連ドキュメント	68
5.2	2.	ロール一覧	68
5.3	3.	権限フラグ定義 (account_permissions.permission_kind 5 値)	69
5.3.1	3.1	権限フラグ概要	69
5.3.2	3.2	主管 SCR / FR 対応	69
5.3.3	3.3	オーナー専有機能 (メンバーには account_permissions で付与不可)	69
5.4	4.	画面別権限マトリクス (§ 3.2 から移管)	69
5.5	5.	機能別権限	70
5.6	6.	API 別権限	71
5.7	7.	契約別利用制限 / 運営者上書き	71
5.7.1	7.1	単一プランの利用上限 (11_課金請求設計書.md § 3 参照)	71
5.7.2	7.2	80/100/125% 三段階アクション (11_課金請求設計書.md § 8 の参照)	71
5.8	8.	権限不足・契約上書き時の動作	71
5.9	9.	緊急時のみ可操作 (§ 3.2.1-2 から移管)	72
5.9.1	9.1	「△ 緊急時のみ可」操作の発動条件	72
5.9.2	9.2	緊急区分 × 検知ハンドラ × 承認 SLA	72
5.10	10.	未決事項	73
5.11	11.	変更履歴	73
6		エラー設計書 (メイン)	73
6.1	1.	文書概要	73
6.1.1	1.1	目的	73
6.1.2	1.2	対象範囲	73
6.1.3	1.3	版数	73

6.1.4	1.4 関連ドキュメント	73
6.2	2. エラー分類	73
6.3	3. 主要設計原則(エラー分類 A~D、§ 6.2.13 から移管)	74
6.4	4. エラー一覧	74
6.4.1	4.1 入力エラー (E-INPUT-*)	74
6.4.2	4.2 認証エラー (E-AUTH-*)	74
6.4.3	4.3 認可エラー (E-AUTHZ-*)	75
6.4.4	4.4 業務エラー (E-BIZ-*)	76
6.4.5	4.5 契約上限エラー (E-QUOTA-*)	76
6.4.6	4.6 課金エラー (E-BILL-*)	76
6.4.7	4.7 システムエラー (E-SYS-*)	77
6.4.8	4.8 外部連携エラー (E-EXT-*)	77
6.4.9	4.9 連携 IF エラー (E-IF-NNN-*)	77
6.4.10	4.10 Webhook エラー (E-WH-*)	78
6.4.11	4.11 規約エラー (E-LEGAL-*)	78
6.5	5. 異常系共通方針	78
6.5.1	5.1 入力エラー時の方針	78
6.5.2	5.2 認証エラー時の方針	78
6.5.3	5.3 認可エラー時の方針	78
6.5.4	5.4 業務エラー時の方針	78
6.5.5	5.5 契約上限エラー時の方針	79
6.5.6	5.6 課金エラー時の方針	79
6.5.7	5.7 外部連携エラー時の方針	79
6.5.8	5.8 連携 IF エラー時の方針	79
6.5.9	5.9 Webhook エラー時の方針	79
6.5.10	5.10 システムエラー時の方針	79
6.5.11	5.11 不正利用検知エラー時の方針 (FR-195)	79
6.6	6. ステータスコード対応表	79
6.7	7. error_logs テーブル設計・運用	80
6.8	8. 未決事項	80
6.9	9. 変更履歴	80

7 メッセージ一覧 (メイン) 80

7.1	1. 文書概要	80
7.1.1	1.1 目的	80
7.1.2	1.2 対象範囲	80
7.1.3	1.3 版数	81
7.1.4	1.4 関連ドキュメント	81
7.2	2. 共通基準	81
7.2.1	2.1 文言トーン	81
7.2.2	2.2 ボタン文言ルール	81
7.2.3	2.3 確認ダイアログルール	81
7.2.4	2.4 通知重要度ルール (共有概念正本)	81
7.2.5	2.5 エラーメッセージルール	81
7.2.6	2.6 禁則語 (単独使用禁止)	82
7.2.7	2.7 i18n キー化必須 (基本設計書 § 11.8 から移管)	82
7.3	3. メッセージ ID 体系	82
7.4	4. 画面別メッセージ全件	82
7.4.1	4.1 SCR-001 ログイン	82
7.4.2	4.2 SCR-002 新規登録	83
7.4.3	4.3 SCR-003 パスワード再設定	83
7.4.4	4.4 SCR-010 プロジェクト一覧	84
7.4.5	4.5 SCR-010-M1 プロジェクト設定モダル	85
7.4.6	4.6 SCR-011 未解決質問一覧 / 詳細	85
7.4.7	4.7 SCR-012 FAQ 管理	86
7.4.8	4.8 SCR-013 個別チャット部屋	87
7.4.9	4.9 SCR-014 ウィジェット設定	87
7.4.10	4.10 SCR-015 利用状況・課金ダッシュボード	88
7.4.11	4.11 SCR-016 設定	88
7.4.12	4.12 SCR-017 ユーザー管理	89
7.4.13	4.13 SCR-017-M1 メンバー招待 / 編集モダル	89
7.4.14	4.14 SCR-018 プライバシーポリシー / 利用規約閲覧	90

7.4.15	4.15 SCR-021 お知らせ一覧	90
7.4.16	4.16 SCR-022 お知らせ詳細	91
7.4.17	4.17 SCR-023 メール確認	91
7.4.18	4.18 SCR-024 退会申請	92
7.4.19	4.19 SCR-025 規約再同意割込み	92
7.4.20	4.20 SCR-027 エンドユーザー再入室	93
7.5	5. サイドメニュー (共通 UI)	93
7.6	6. 通知契機・テンプレート (§ 9.1/ § 9.4 を吸収、本書の中核)	94
7.6.1	6.1 通知契機 21 種 (FR-140~149b、基本設計書 § 9.1 全件)	94
7.6.2	6.2 通知テンプレート (§ 9.4 全件)	95
7.6.3	6.3 通知メール共通要件	95
7.7	7. 契約・課金関連メッセージ	95
7.8	8. エラー別メッセージ対応表	96
7.9	9. 未決事項	96
7.10	10. 変更履歴	97

8 トレーサビリティマトリクス (メイン) 97

8.1	1. 文書概要	97
8.1.1	1.1 目的	97
8.1.2	1.2 対象範囲	97
8.1.3	1.3 版数	97
8.1.4	1.4 関連ドキュメント	97
8.2	2. 要件・設計対応表 (主要 FR / NFR)	97
8.3	3. 機能・画面・API 対応表	100
8.4	4. 画面・メッセージ対応表 (主要)	101
8.5	5. API・エラー対応表	102
8.6	6. 権限・画面・API 対応表	103
8.7	7. 契約上書き × 機能対応表 (プラン別利用制限の代替)	103
8.8	8. テスト観点との対応 (基本設計書 § 14 を吸収)	104
8.8.1	8.1 テスト観点 6 列の定義	104
8.8.2	8.2 主要要件のテスト観点表	104
8.9	9. 不足・不整合一覧 (仕様同期検査.sh と同型)	105
8.10	10. 未決事項	105
8.11	11. 変更履歴	105

9 認証・認可設計書 (メイン) 105

9.1	1. 文書概要	105
9.1.1	1.1 目的	105
9.1.2	1.2 対象範囲	105
9.1.3	1.3 版数	105
9.1.4	1.4 関連ドキュメント	106
9.2	2. 認証方式	106
9.3	3. 認証フロー	106
9.3.1	3.1 ログイン (AUTH-FLOW-001)	107
9.3.2	3.2 ログアウト	107
9.3.3	3.3 パスワード再設定 (AUTH-FLOW-003)	107
9.3.4	3.4 招待受諾 (AUTH-FLOW-004)	107
9.3.5	3.5 規約再同意 (AUTH-FLOW-005)	107
9.3.6	3.6 メール確認 (AUTH-FLOW-006)	107
9.3.7	3.7 エンドユーザー再入室 (AUTH-FLOW-007)	108
9.3.8	3.8 強制ログアウト (AUTH-FLOW-008)	108
9.4	4. セッション・トークン設計	108
9.4.1	4.1 トークン用途別仕様 (§ 10.1.3 から移管)	108
9.4.2	4.2 Cookie 属性 (§ 10.1.4)	108
9.5	5. 認可モデル	108
9.5.1	5.1 認可方式	108
9.5.2	5.2 オーナー境界判定式 (共有概念正本)	109
9.5.3	5.3 ユーザー種別の DB 値 (§ 3.1 から移管)	109
9.5.4	5.4 オーナー専有機能	109
9.5.5	5.5 プラン制限との関係	109
9.6	6. 認可判定ルール	109
9.6.1	6.1 Principal 構築フロー (§ 3.3.1 から移管)	109

9.6.2	6.2 認可判定の順序	110
9.6.3	6.3 critical 通知の宛先解決 (共有概念正本)	110
9.6.4	6.4 重要操作の再認証 (FR-005)	110
9.6.5	6.5 オーナー保護 (FR-333)/ 自己操作不可 (FR-334)/ 単一オーナー所属 (FR-335)	110
9.7	7. アカウント状態	111
9.7.1	7.1 サスペンション中の認可ゲート (§ 6.2.7 から移管)	111
9.7.2	7.2 退会・解約フロー (§ 6.2.8 から移管)	111
9.7.3	7.3 規約改定フロー (§ 6.2.9 から移管)	112
9.8	8. 認証・認可エラー	112
9.9	9. 未決事項	113
9.9.1	9.1 MVP リスク受容 (§ 10.1.5)	113
9.10	10. 変更履歴	113

10 セキュリティ設計書 (メイン) 113

10.1	1. 文書概要	113
10.1.1	1.1 目的	113
10.1.2	1.2 対象範囲	113
10.1.3	1.3 版数	114
10.1.4	1.4 関連ドキュメント	114
10.2	2. セキュリティ基本方針	114
10.2.1	2.1 保護対象	114
10.2.2	2.2 想定脅威	114
10.2.3	2.3 基本対策方針	114
10.3	3. データ保護	114
10.3.1	3.1 PII 暗号化 (AES-256-GCM)+ オーナー派生 (共有概念正本 = メイン側)	114
10.3.2	3.2 保護層別方針	115
10.3.3	3.3 データ削除モード (物理削除 / 匿名化、 § 7.8 から移管)	115
10.3.4	3.4 お知らせ二層構成 (§ 7.7 から移管)	115
10.4	4. 入力値検証	116
10.5	5. Web 脆弱性対策	116
10.5.1	5.1 HTTP 応答ヘッダ (§ 10.5 から移管)	116
10.5.2	5.2 主要脅威別対策	116
10.5.3	5.3 お知らせ本文サニタイズ (2 重防御)	117
10.6	6. アクセス制御	117
10.7	7. 監査・ログ	117
10.7.1	7.1 ログ種別と保持目的 (§ 10.6 から移管)	117
10.7.2	7.2 メイン側の監査対象操作 (§ 10.6.5 から移管)	117
10.7.3	7.3 改ざん検知方式 (NFR-306)	117
10.7.4	7.4 エラーログ (error_logs)	118
10.8	8. 秘密情報管理 (共有概念正本 = メイン側)	118
10.8.1	8.1 暗号 管理 (§ 10.9 から移管)	118
10.8.2	8.2 ローテーション運用	118
10.8.3	8.3 ウィジェット API キー (projects / project_legacy_keys 、 § 8.3.4 から移管)	118
10.9	9. SaaS 特有のセキュリティ観点	118
10.10	10. 不正利用検知 (基本設計書 § 10.10 / FR-195 / NFR-308 = 共有概念正本)	119
10.10.1	10.1 検知・対応体系	119
10.10.2	10.2 検知パターン	119
10.11	11. メール配信信頼性・レピュテーション保護	119
10.11.1	11.1 メール配信信頼性 (NFR-501~507)	119
10.11.2	11.2 共通ドメインレピュテーション保護 (R-003 / FR-149b / NFR-504)	119
10.11.3	11.3 Resend Webhook 処理	120
10.11.4	11.4 サプレスリスト復帰フロー	120
10.11.5	11.5 DLQ 運用 (§ 11.9 から移管)	120
10.12	12. ウィジェット保護 (§ 10.2 から移管)	120
10.13	13. PII マスキング・プロンプト注入対策	121
10.13.1	13.1 PII マスキング (§ 10.7 から移管)	121
10.13.2	13.2 プロンプト注入対策 (§ 10.3 から移管)	121
10.14	14. バックアップ・復旧	121
10.15	15. 未決事項	121
10.16	16. 変更履歴	121

11 課金・請求設計書 (メイン) 121

11.1	1. 文書概要	121
11.1.1	1.1 目的	121
11.1.2	1.2 対象範囲	122
11.1.3	1.3 版数	122
11.1.4	1.4 関連ドキュメント	122
11.2	2. 契約モデル(MVP は単一プラン、共有概念正本)	122
11.2.1	2.1 単一プラン定義	122
11.2.2	2.2 階層プランへの拡張余地	122
11.3	3. 契約別利用上書き	122
11.4	4. 契約状態 (accounts.contract_status 4 値 = 共有概念正本)	123
11.4.1	4.1 状態遷移詳細 (付録 B.5 から移管)	123
11.5	5. 契約ライフサイクル	123
11.5.1	5.1 トライアル・本契約フロー	123
11.5.2	5.2 サスペンションフロー (§ 6.2.7 から移管)	124
11.5.3	5.3 退会・解約フロー (§ 6.2.8 から移管)	124
11.6	6. 契約とオーナーの関係	124
11.7	7. プラン変更時の仕様 (MVP は契約上書きのみ)	124
11.8	8. 課金方式 / 課金単位	125
11.8.1	8.1 課金単位 (要件 § 8.11.1 / 基本設計書 § 6.6.1 正本)	125
11.8.2	8.2 80/100/125% 三段階アクション (FR-122)	125
11.8.3	8.3 月次境界	125
11.8.4	8.4 通貨 / 税計算	125
11.9	9. 請求対象	125
11.10	10. 請求状態	125
11.11	11. 決済フロー	126
11.11.1	11.4 Stripe Smart Retries 委譲 (基本設計書 § 6.6.4)	126
11.12	12. 外部決済サービス連携 (Stripe)	126
11.13	13. Webhook 処理 (運営者側 § 13 が正本、本書は参照)	126
11.14	14. 請求書・領収書	127
11.15	15. 課金・契約エラー時の動作	127
11.16	16. 月次集計フロー (§ 6.2.10 から移管)	127
11.17	17. 未決事項	127
11.18	18. 変更履歴	127

1 基本設計 index(メインシステム)

1.1 0. 文書情報

項目	内容
文書名	基本設計 index(メインシステム)
対象システム名	FAQ AI ウィジェット SaaS / メインシステム (利用者向け)
作成日	2026-05-17
作成者	プロジェクト設計チーム
版数	v1.0
ステータス	承認済 (v1.0 初版)

1.2 1. 目的・対象範囲

項目	内容
目的	メインシステム (利用者向け FAQ ウィジェット SaaS) の全体方針 + 設計方針 + 個別設計書への索引を示す。詳細仕様は本ディレクトリ配下の 10 個別設計書を正本とする。
対象範囲	利用者 (オーナー / メンバー / エンドユーザー) 向け SaaS のシステム全体方針
対象外	運営者システム (../02_運営者システム/02_基本設計/)、実装ディレクトリ構成 (詳細設計)、デブロイ詳細 (運用設計)
想定読者	設計レビューアー / 実装担当者 / AI 駆動開発担当

1.3 2. 設計方針 (全体像)

#	方針	概要	詳細
1	画面設計方針	SaaS 標準 SPA + サーバーサイドルーティング併用。SCR-001~027(モジュール含む)を網羅。	01_画面設計.md
2	API 設計方針	REST + JSON。/v1 配下に統一。Authorization ヘッダ。連携 IF #1~#12(送信側)。	02_API 設計.md
3	データ設計方針	RDB(マルチオーナーは owner_account_id 列で分離)+ KV(セッション/トークン/レート制限)+ R2(添付・ウィジェット静的)。	03_テーブル設計.md
4	権限設計方針	オーナー専有機能 + メンバー 5 種権限フラグ + プロジェクト割当 + 契約状態による利用上書き。	04_権限設計.md
5	エラー設計方針	E-AUTH-*/E-AUTHZ-*/E-BIZ-*/E-INPUT-*/E-IF-* の ID 体系。ステータスコード対応表。	05_エラー設計.md
6	メッセージ設計方針	MSG-SCR-* の ID 体系。通知契機 + テンプレート。重要度 critical はメール強制送信。	06_メッセージ一覧.md
7	トレーサビリティ方針	要件 → 機能 → 画面 → API → DB → 権限 → エラー → メッセージ → テスト観点を縦串で追跡。	07_トレーサビリティマトリクス.md
8	認証・認可設計方針	ID/PW + メール確認 + 規約同意。セッション + アクセストークン + リフレッシュトークン。オーナー境界 + Principal。	08_認証・認可設計.md
9	セキュリティ設計方針	PII 列単位暗号化 + 管理 + 監査ログ + 不正利用検知 + メール配信信頼性 + Web 脆弱性対策。	09_セキュリティ設計.md
10	課金・請求設計方針	MVP 単一プラン (完全従量課金 + 月次無料枠 + 14 日トライアル) + Stripe Smart Retries + 契約状態 4 値。	10_課金・請求設計.md

1.4 3. システム構成 (全体像)

レイヤ	構成要素	補足
フロントエンド	SPA(Web)+ ウィジェット (エンドユーザー側 JS)	認証画面 / 管理画面 / エンドユーザー画面
API バックエンド	Cloudflare Workers + REST API	/v1 配下に統一
データストア	D1(SQLite ベース)+ KV + R2	RDB + キャッシュ + オブジェクト
外部連携	Stripe / Resend / OpenAI / 運営者システム / メール SMTP	連携 IF #1~#12 で明文化
インフラ	Cloudflare Workers + Cron Triggers + Queues	サーバーレス前提

詳細構成図と利用技術一覧は [./03_詳細設計/index.md](#) §2 を参照。

1.5 4. 機能一覧 (FRxx_*.md と基本設計成果物の対応)

FRxx ファイル	概要	主関連画面	主関連 API
./01_要件定義/FR01_アカウント管理.md	新規登録 / ログイン / 再認証 / ログアウト	SCR-001~003	POST /v1/sessions, POST /v1/accounts
./01_要件定義/FR02_ユーザー管理.md	メンバー招待 / 権限 / プロジェクト割当	SCR-017	POST /v1/members/invite, PATCH /v1/members/id
./01_要件定義/FR03_プロジェクト管理.md	プロジェクト作成 / 編集 / 削除	SCR-010	GET /v1/projects ほか
./01_要件定義/FR04_FAQ 管理.md	FAQ CRUD + 公開 + 改版	SCR-012	GET /v1/faqs ほか
./01_要件定義/FR05_AI 回答.md	AI 推論 + 信頼度しきい値判定	ウィジェット	POST /v1/widget/ai-reply
./01_要件定義/FR06_未解決質問登録.md	未解決質問の登録 / 一覧	SCR-011	GET /v1/inquiries ほか
./01_要件定義/FR07_個別チャット.md	個別チャット部屋	SCR-013	POST /v1/chats/id/messages
./01_要件定義/FR08_未解決質問から FAQ 登録.md	未解決 → FAQ 候補化 / 公開	SCR-011 / SCR-012	POST /v1/faqs/from-inquiry

FRxx ファイル	概要	主関連画面	主関連 API
../01_要件定義/FR09_処理エラー.md	エラー一覧 / 再実行	SCR-019	GET /v1/errors
../01_要件定義/FR10_利用量・課金.md	利用量メータリング / 請求書 / プラン	SCR-015	GET /v1/usage, GET /v1/invoices
../01_要件定義/FR11_管理ダッシュボード.md	KPI ダッシュボード	SCR-020	GET /v1/dashboard
../01_要件定義/FR12_通知.md	通知 / インボックス / メール	SCR-021 / SCR-022	GET /v1/inbox-messages
../01_要件定義/FR13_ウィジェット.md	ウィジェット配信 + 設定 + 許可ドメイン	SCR-014	GET /v1/widget-config ほか
../01_要件定義/FR14_プライバシー・データ管理.md	プライバシー / データ削除	SCR-018 / SCR-024	POST /v1/withdrawal-requests
../01_要件定義/FR15_セキュリティ.md	不正利用検知 / 管理 / 監査	—	—
../01_要件定義/FR16_お知らせ.md	お知らせ配信 / 既読	SCR-021 / SCR-022	GET /v1/inbox-messages
../01_要件定義/FR17_検索・全文検索.md	FTS 検索	SCR-012	GET /v1/faqs?q=
../01_要件定義/FR18_インポート・エクスポート.md	FAQ / 質問ログのインポート/エクスポート	SCR-012 / SCR-015	POST /v1/imports, GET /v1/exports
../01_要件定義/FR19_UX 細部・データ運用.md	UX 細部要件 / データ運用要件	全画面	—
../01_要件定義/FR20_アクセス制御細部.md	アクセス制御細部要件	—	—
../01_要件定義/FR21_AI 推論動作.md	AI 推論動作要件	—	POST /v1/widget/ai-reply
../01_要件定義/FR22_SCR 画面マスタ.md	SCR 画面一覧マスタ	全画面	—

1.6 5. データフロー (概観)

graph LR

```

EU[エンドユーザー] -->| 質問 | Widget[ウィジェット]
Widget -->| /v1/widget/ai-reply | API[Workers API]
API -->| FAQ 検索 | D1[(D1)]
API -->| AI 推論 | OAI[OpenAI]
API -->| 未解決 | Inquiry[(question_logs)]
Inquiry --> Admin[管理者画面]
Admin -->| 個別チャット応答 | API
API -->| チャット | ChatRoom[(chat_rooms)]
ChatRoom -->| FAQ 化 | FAQ[(faqs)]
API -->| 利用量計測 | Meter[(usage_metering)]
Meter -->| 月次集計 | Stripe[Stripe]
Stripe -->| Webhook IF#10 | Operator[運営者システム]
Operator -->| 転送 | API

```

1.7 6. 非機能要件への対応方針 (基本)

観点	対応方針	詳細
性能	API p95 < 500ms / AI 回答 p95 < 3s	../03_詳細設計/index.md § 13.1
可用性	Cloudflare グローバル分散 + マルチリージョン DB レプリケーション	§ 13.2
スケーラビリティ	サーバーレス自動スケール + KV キャッシュ	§ 13.3
アクセシビリティ	WCAG 2.1 AA 準拠	§ 13.4
国際化	i18n 基盤 (MVP は日本語のみ。将来英語追加)	§ 13.5 / ../05_future/index.md

観点	対応方針	詳細
バックアップ	D1 自動バックアップ + R2 ライフサイクル	§ 13.6 / ../04_運用設計/02_バックアップ・リストア設計.md
データ保持	テーブル別 retention class 制御	§ 13.7

1.8 7. 基本設計ファイル一覧

#	ファイル	概要
01	01_画面設計.md	SCR-001~027 + モーダルの全画面定義
02	02_API 設計.md	管理 API + 連携 IF #1~#12(送信側) の全エンドポイント
03	03_テーブル設計.md	全テーブル + DDL + コード値 + 状態遷移
04	04_権限設計.md	ロール + 5 種権限フラグ + プロジェクト割当 + 契約状態上書き
05	05_エラー設計.md	エラー ID 体系 + ステータスコード対応表 + 共通方針
06	06_メッセージ一覧.md	メッセージ / 通知 / メールテンプレート全一覧
07	07_トレーサビリティマトリクス.md	要件 → 設計 → テスト観点の対応
08	08_認証・認可設計.md	認証 / セッション / Principal / オーナー境界
09	09_セキュリティ設計.md	PII 暗号化 / 管理 / 監査ログ / 不正利用検知
10	10_課金・請求設計.md	MVP 単一プラン + 契約状態 + Stripe Smart Retries

1.9 8. SCR × ドキュメント カバレッジ表

SCR ID	画面名	画面	API	テーブル	権限	エラー	メッセージ	認証認可	セキュリティ	課金
SCR-001	ログイン	§ 5.SCR-001	POST /v1/sessions	accounts, sessions	§ 3 ロール	E-AUTH-*	MSG-SCR-001-*	§ 3 ログイン	§ 5 ロックアウト	-
SCR-002	新規登録	§ 5.SCR-002	POST /v1/accounts	accounts	-	E-AUTH-VALIDATION-*	MSG-SCR-002-*	§ 3 新規登録	-	§ 5 トライアル
SCR-003	パスワード再設定	§ 5.SCR-003	POST /v1/password/reset	accounts	-	E-AUTH-*	MSG-SCR-003-*	§ 3 パスワード再設定	§ 7 監査	-
SCR-010	プロジェクト一覧	§ 5.SCR-010	GET /v1/projects	projects, account_project	project:manage_grants	E-AUTHZ-*	MSG-SCR-010-*	§ 6 オーナー境界	-	-
SCR-010-M1	プロジェクト設定モダ	§ 5.SCR-010-M1	POST/PATCH /v1/projects	projects	project:manage	E-AUTHZ-INPUT-*	MSG-SCR-010-M1-*	§ 6 認可判定	-	-
SCR-011	未解決質問一覧 / 詳細	§ 5.SCR-011	GET /v1/inquiries	question_logs, inquiries	chat:response	E-BIZ-CASE-*	MSG-SCR-011-*	§ 6 オーナー境界	-	-
SCR-012	FAQ 管理	§ 5.SCR-012	GET /v1/faqsほか	faqs, faq_revisions, faq_search_fts	faq:manage	E-BIZ-FAQ-PUBLISHING-*	MSG-SCR-012-*	§ 6 認可判定	-	§ 3 FAQ 件数上限
SCR-013	個別チャット部屋	§ 5.SCR-013	POST /v1/chats/id/messages	chat_rooms, messages	chat:response	E-BIZ-CHAT-*	MSG-SCR-013-*	§ 6 オーナー境界	-	§ 3 チャット部屋数上限
SCR-014	ウィジェット設定	§ 5.SCR-014	PATCH /v1/widget-config	projects, allowed_domains	project:manage	E-AUTHZ-INPUT-DOMAIN-*	MSG-SCR-014-*	§ 6 API キー検証	§ 12 ウィジェット保護	-

SCR ID	画面名	画面	API	テーブル	権限	エラー	メッセージ	認証認可	セキュリティ	課金
SCR-015	利用状況・課金ダッシュボード	§ 5.5.015	GET /v1/usage, GET /v1/invoices	usage_metering, billing_invoices	オーナー専用	-	MSG-SCR-015-*	§ 6 オーナー専用判定	-	§ 9 ~ § 11
SCR-016	設定	§ 5.5.016	GET /v1/account-settings	accounts	オーナー専用	-	MSG-SCR-016-*	§ 6 オーナー専用判定	-	§ 5 退会
SCR-017	ユーザー管理	§ 5.5.017	POST /v1/members/ほか	accounts, accounts_permissions	users:manage	Page AUTHZ-MEMBER	MSG-SCR-017-*	§ 3 招待受諾	-	-
SCR-017-M1	メンバー招待モーダル	§ 5.5.017-M1	POST /v1/members/invite	accounts, accounts_permissions	users:manage	Page INPUT-*	MSG-SCR-017-M1-*	§ 3 招待トークン	-	-
SCR-018	プライバシーポリシー / 利用規約	§ 5.5.018	GET /v1/terms/current	terms_version	認証不要	-	MSG-SCR-018-*	-	-	-
SCR-021	お知らせ一覧	§ 5.5.021	GET /v1/inbox-messages	inbox_messages	全ユーザー	-	MSG-SCR-021-*	§ 6 認可判定	-	-
SCR-022	お知らせ詳細	§ 5.5.022	PATCH /v1/inbox-messages/:id/read	inbox_messages	全ユーザー	-	MSG-SCR-022-*	§ 6 認可判定	-	-
SCR-023	メール確認	§ 5.5.023	POST /v1/email-verification	accounts	-	E-AUTH-VERIFICATION-*	MSG-SCR-023-*	§ 3 メール確認	-	-
SCR-024	退会申請	§ 5.5.024	POST /v1/withdrawal-requests	withdrawal_requests	オーナー専用	E-BIZ-WITHDRAWAL	MSG-SCR-024-*	§ 6 オーナー専用	-	§ 5 退会フロー
SCR-025	規約再同意割込み	§ 5.5.025	POST /v1/terms/agree	terms_agreements	全ユーザー	E-AUTHZ-TERMS	MSG-SCR-025-*	§ 3 規約再同意	-	-
SCR-027	エンドユーザー再入室	§ 5.5.027	GET /v1/widget/session/tokens	access_tokens, sessions_tokens	エンドユーザー	E-AUTH-TOKEN	MSG-SCR-027-*	§ 3 ウィジェットトークン	§ 12 ウィジェット保護	-

1.10 9. 連携 IF × ドキュメント カバレッジ

IF #	方向	概要	API	エラー	セキュリティ	課金
#1	顧管 → メ	契約停止イベント受信	§ 5 IF #1	E-IF-001-*	-	§ 5 サスペンション
#2	顧管 → メ	強制ログアウト受信	§ 5 IF #2	E-IF-002-*	§ 7 監査	-
#4	顧管 → メ	復元実行	§ 5 IF #4	E-IF-004-*	§ 7 監査	-
#5	顧管 → メ	レート制限上書き	§ 5 IF #5	E-IF-005-*	-	§ 3 契約上書き
#6	顧管 → メ	AI パラメータ上書き	§ 5 IF #6	E-IF-006-*	-	-
#7	顧管 → メ	お知らせ生成	§ 5 IF #7	E-IF-007-*	-	-
#8	メ → 顧管	監視メトリクス取得	§ 5 IF #8	E-IF-008-*	§ 10 監視	-
#9	メ → 顧管	不正利用検知通知	§ 5 IF #9	E-IF-009-*	§ 10 不正利用検知	-

IF #	方向	概要	API	エラー	セキュリティ	課金
#10	外 → 顧管 → メ	課金 Webhook 受信・転送	§ 5 IF #10	E-IF-010-*	§ 7 監査	§ 13 Webhook 処理
#12	顧管 → メ → 利用者	運営者操作通知	§ 5 IF #12	E-IF-012-*	-	-

(#3 / #11 は要件側で予約。MVP では未割り当て)

1.11 10. 関連ドキュメント

ドキュメント	役割	リンク
要件定義	WHAT(機能要件 / 非機能要件 / 業務要件 / 受入条件)	../01_要件定義/index.md
詳細設計	実装関連の詳細(モジュール構成 / バッチ / ログ / 監視 / 実装ガイドライン)	../03_詳細設計/index.md
運用設計	監視 / バックアップ / ログ / 障害対応 / リリース / 運用手順	../04_運用設計/index.md
将来対応	MVP 範囲外	../05_future/index.md
画面遷移図(ワイヤーフレーム)	エンドユーザー UI 表現	../画面遷移図.html
運営者側ドキュメント	顧客管理システム側設計書	../02_運営者システム/02_基本設計/index.md
共有概念対応表	メイン / 運営者の正本所在	../共有/共有概念.md

1.12 11. 未確定事項・確認事項

確認事項 ID	確認内容	関連箇所	優先度	ステータス
Q-BASE-001	(現時点で未確定事項なし→v1.0 リリース時点で全項目確定済み)	-	低	確認済

\newpage

2 画面設計書 (メイン)

2.1 1. 文書概要

2.1.1 1.1 目的

メインシステム(利用者向け FAQ ウィジェット SaaS)の画面仕様を一元化する。画面一覧 / 画面遷移 / 共通 UI 部品 / サイドメニュー / 各画面の表示項目・入力項目・操作・バリデーション・状態別表示・モーダルを定義する。

2.1.2 1.2 対象範囲

- 対象 SCR(20 画面): SCR-001~003(認証) / SCR-010 / SCR-010-M1 / SCR-011~014 / SCR-015 / SCR-016 / SCR-017 / SCR-017-M1 / SCR-018 / SCR-021 / SCR-022 / SCR-023 / SCR-024 / SCR-025 / SCR-027
- 対象外: 運営者画面 (02_運営者システム/個別設計書群/02_画面設計書.md 参照)、ウィジェット内 UI(基本設計書 § 5.7 から § 7 に要約のみ)

2.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

2.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11ドキュメント体系の俯瞰	00_索引.md
API 設計書	各画面の API 呼び出し	03_API 設計書.md
メッセージ一覧	画面ラベル / エラー文言 (正本)	07_メッセージ一覧.md
権限設計書	画面別権限・表示制御	05_権限設計書.md
認証・認可設計書	ログイン / セッション / 認可判定	09_認証認可設計書.md
エラー設計書	異常系挙動	06_エラー設計書.md
テーブル定義書	状態遷移 / コード値	04_テーブル定義書.md
ワイヤーフレーム	UI 表現	../画面遷移図.html

2.2 2. 画面一覧

画面 ID	画面名	利用者	主たる関連 FR	優先度
SCR-001	ログイン	admin	FR-004, FR-007, FR-008, FR-332	P0
SCR-002	アカウント登録	admin	FR-001, FR-002	P0
SCR-003	パスワード再設定	admin	FR-004, FR-006	P0
SCR-010	プロジェクト一覧	admin	FR-030～035	P0
SCR-010-M1	プロジェクト設定モダール(新規/編集)	admin	FR-030～035, FR-033a, FR-033c	P0
SCR-011	未解決質問一覧 / 詳細	admin	FR-070～079, BR-019, BR-020	P0
SCR-012	FAQ 管理	admin	FR-040～048, FR-100～106, FR-310, FR-320～323	P0
SCR-013	個別チャット部屋	admin / end_user	FR-080～091, FR-082a～c	P0
SCR-014	ウィジェット設定	admin(project:manage)	FR-150～156, FR-193, FR-194	P0
SCR-015	利用状況・課金ダッシュボード	admin(オーナー専有)	FR-120～127, FR-129, FR-148, FR-191	P0
SCR-016	設定(退会・課金画面入口)	admin(オーナー専有)	FR-009, FR-125, FR-162, FR-167	P0
SCR-017	ユーザー管理	オーナー / users:manage 保持メンバー	FR-017, FR-021a～c, FR-333	P0
SCR-017-M1	メンバー招待 / 編集モダール	オーナー / users:manage 保持メンバー	FR-015～021, FR-333～338	P0
SCR-018	プライバシーポリシー / 利用規約	全利用者	FR-160, FR-164, FR-168	P0
SCR-021	お知らせ一覧	admin	FR-180～183, FR-323	P0
SCR-022	お知らせ詳細	admin	FR-181, FR-182	P0
SCR-023	メール確認	admin	FR-003	P0
SCR-024	退会申請	admin(オーナー専有)	FR-009	P0
SCR-025	規約再同意割込み	admin	FR-011, FR-164	P0

画面 ID	画面名	利用者	主たる関連 FR	優先度
SCR-027	エンドユーザー再入室	end_user	FR-083, FR-084, FR-174	P0

2.3 3. 画面遷移

2.3.1 3.1 Mermaid 遷移図

flowchart TD

```

Login[SCR-001 ログイン] --> RegCheck{規約改定 <br> 未同意?}
Register[SCR-002 新規登録] --> Mail[SCR-023 メール確認]
Mail --> Login
RegCheck -- Yes --> Terms[SCR-025 規約再同意]
Terms -- 同意 --> Dashboard
Terms -- 不同意 --> Withdraw[SCR-024 退会]
RegCheck -- No --> Dashboard[SCR-015 ダッシュボード]
Dashboard --> Projects[SCR-010]
Dashboard --> FAQ[SCR-012]
Dashboard --> Inquiries[SCR-011]
Dashboard --> Chat[SCR-013]
Dashboard --> Widget[SCR-014]
Dashboard --> Users[SCR-017]
Dashboard --> Settings[SCR-016]
Dashboard --> Privacy[SCR-018]
Settings --> Withdraw
Inbox[SCR-021] --> InboxDetail[SCR-022]
Reenter[SCR-027 EU 再入室] --> Chat

```

2.3.2 3.2 主要遷移ルール

観点	説明
認証フロー	SCR-001 → SCR-023(メール確認) → SCR-001 → 利用状況系画面。SCR-002 新規登録経由は SCR-023 で本人確認後にログイン
規約改定割込み	ログイン直後に未同意があれば SCR-025 強制割込み。SCR-025 で機能制限ガード (FAQ 編集とウィジェット稼働は継続、課金画面操作と新規プロジェクト作成は不可)
エンドユーザー導線	ウィジェット → メール登録 → SCR-013。再入室メールからは SCR-027 を経由(トークン検証)
お知らせ導線	ヘッダ通知ベル / サイドバー「通知 > お知らせ」 → SCR-021 → SCR-022(自動既読)

2.4 4. 共通 UI 部品 + サイドメニュー

2.4.1 4.1 既存共通部品 (§5.3.1)

部品	用途	主な仕様
Header	ロゴ、プロジェクト切替、ユーザーメニュー、通知ベル	管理画面共通
Sidebar	管理画面の主要メニュー左側表示	ユーザー種別別表示。詳細は § 4.4
ProjectSelector	対象プロジェクト切替	admin は全件
StatusBadge	FAQ 状態、案件状態、通知状態、契約状態	色 + アイコン + テキストの三重識別を必須 (FR-390)
ConfirmDialog	削除、公開、退会など	重要操作は再認証 (FR-005)。削除系には「この操作は取り消せません」必須表示 (FR-354)
ErrorAlert	入力エラー、通信エラー、処理エラー	原因 + 解決策をセットで表現 (FR-353)
Pagination	一覧画面	カーソル方式 + 件数表示「1-50 / 全 254 件」併記 (FR-358)
EmptyState	データなし	アイコン + 説明文 + CTA を必須。「データがありません」単独表示は禁止 (FR-351)
Toast	成功・失敗通知	成功 4 秒・警告 6 秒・エラーは手動閉じ (FR-382)

部品	用途	主な仕様
FormField	入力部品	必須印、補助文、エラー文を構成要素として保持 (FR-359)
NotificationBell	ヘッダの通知ベル	critical 赤色強調、high 黄色。未読件数バッジ、直近 10 件ドロップダウン、admin のみ表示
InboxItem	お知らせ一覧の行	種別バッジ、重要度インジケータ、タイトル、配信日時、未読インジケータ
AnnouncementCategory	お知らせ種別バッジ	billing(青)/ announcement(緑)/ system(オレンジ)
ImportanceIndicator	お知らせ重要度インジケータ	critical = 赤マーク + バッジ、high = 黄色マーク、normal = 無印、low = 淡色 (FR-181)
TrialBanner	トライアル残日数の警告バナー	残 3 日以内に表示、支払方法登録誘導
UsageBar	利用量バー (80%/100%/125%)	80% 黄色、100% 赤、125% アニメーション強調 (FR-390)

2.4.2 4.2 UI/UX 共通要件で追加する部品 (§5.3.2)

部品	用途	主な仕様
Breadcrumb	パンくず	認証フロー除く全画面。最大 3 階層 (FR-370)
PageHeader	画面タイトル + 説明文	全画面の最上部に配置 (FR-350)
QuickFilterChips	クイックフィルタ	一覧画面上部、URL クエリで状態保持 (FR-371)
AppliedFilterChips	適用済フィルタ表示 + クリア	「すべてクリア」リンクを常設 (FR-371)
BulkActionBar	一括操作バー	1 件以上選択時に画面下部固定表示 (FR-372)
SummaryCard	数値サマリーカード	数字 + 単位 + 補助バー + ラベル の 4 要素構成
Timeline	段階・フローの可視化	縦タイムライン、現在位置強調
AutosaveIndicator	自動保存状態の表示	緑点「30 秒前に保存しました」/ 黄点「保存中…」/ 赤点「保存できませんでした」 (FR-321)
UnsavedChangesWarning	未保存変更時の離脱警告	フォーム編集時の戻る・タブ閉じ・リロード時に警告 (FR-373)
PermissionTooltip	権限不足時のグレースアウト	ボタンをグレースアウトし tooltip で必要権限表示 (FR-356)
LoadingSkeleton	スケルトン UI	テーブルは行スケルトン、スピナー単独表示を避ける (FR-380)
ProgressText	進捗テキスト (3 秒超)	「保存中…」「処理中…(2/5 段階)」など (FR-381)
ReauthBadge	再認証必須操作の可視化	Primary ボタン横に ☒ アイコン + tooltip (FR-360)

2.4.3 4.3 文言の共通基準

詳細は [07_メッセージ一覧.md §2](#) を正本とする。

2.4.4 4.4 サイドメニュー (§5.6)

2.4.4.1 4.4.1 レイアウト方針

項目	仕様
サイドバー幅	通常 240px、折り畳み時 64px(アイコンのみ)
折り畳み	ヘッダ内トグルボタン、または画面幅 < 1024px で自動折り畳み
モバイル	ハンバーガーメニュー(オーバーレイ)
固定表示	スクロール時もサイドバーは固定。サイドバー内部は独立スクロール可
アクティブ表示	現在画面のメニュー項目を強調(背景色 + 左境界アクセント)

2.4.4.2 4.4.2 メニュー構成

グループ	メニュー項目	遷移先	表示種別
(グループなし)	ホーム(利用状況サマリ)	SCR-015	リンク
対応	未解決質問	SCR-011	リンク + バッジ(未解決件数)
対応	個別チャット	SCR-013	リンク + バッジ(未読 / 未返信件数)

グループ	メニュー項目	遷移先	表示種別
通知	お知らせ	SCR-021	リンク + バッジ(未読件数)
コンテンツ	FAQ 管理	SCR-012	リンク
プロジェクト	プロジェクト	SCR-010	リンク
プロジェクト	ユーザー管理	SCR-017	リンク
利用状況	利用量・課金	SCR-015	リンク + バッジ(警告時)
設定	設定・退会	SCR-016	リンク
設定	プライバシーポリシー / 利用規約	SCR-018	リンク

2.4.4.3 4.4.3 サイドメニューに含めない画面

画面	除外理由	アクセス手段
SCR-023 メール確認	新規登録フロー内の中継画面	SCR-002 登録 → 自動遷移
SCR-024 退会申請	重大かつ可逆性の低い操作	SCR-016 「退会申請」ボタン
SCR-025 規約再同意割込み	強制割込み画面(全画面モーダル)	ログイン時 / 操作時に自動表示
SCR-027 エンドユーザー再入室	トークン URL のみアクセス	再入室メール内リンク
SCR-010-M1 プロジェクト設定モーダル	SCR-010 から開く全画面モーダル	SCR-010 行アクション
SCR-017-M1 メンバー招待/編集モーダル	SCR-017 から開く全画面モーダル	SCR-017 行アクション

2.4.4.4 4.4.4 ヘッド部品

部品	種類	概要
ロゴ	画像 + リンク	クリックでホームへ
サイドバー折り畳みトグル	アイコンボタン	サイドバーの開閉
通知ベル	アイコンボタン + バッジ + ドロップダウン	未読件数バッジ、critical 赤バッジ + 強調アニメーション。直近 10 件ドロップダウン、admin のみ表示
ユーザーメニュー	ドロップダウン	プロフィール、アクティブセッション、ログアウト

2.4.4.5 4.4.5 動作要件

観点	仕様
キーボード操作	Tab で移動、Enter / Space で遷移、Esc でモバイル時のオーバーレイを閉じる
アクセシビリティ	aria-current="page" でアクティブ項目を示す。アイコンには aria-label を付与(NFR-1001~1003)
バッジ更新	未解決件数・未読件数は画面遷移時に再取得。長時間滞在時は定期ポーリング
折り畳み状態の保持	ローカルストレージで利用者ごとに保持

2.4.5 4.5 レスポンシブ方針

ブレイクポイント	レイアウト	主要操作
PC ☒ 1024px	3 ペイン(ヘッダ + サイドバー 200-240px + メイン)	サイドバー 常時表示、テーブル横並び
Tablet 768-1023px	サイドバー折り畳み(64px)、必要時オーバーレイ展開	テーブル重要列に絞込
SP < 768px	サイドバーはハンバーガー、テーブルはカード型、Primary CTA は固定フッタ	モーダルはフルスクリーン

タッチターゲット: PC 36x36px / SP 44x44px 以上、隣接要素間 8px 以上の余白 (FR-392)。

2.5 5. 画面詳細

各画面のメッセージ ID 体系 (MSG-SCR-XXX-*) は [07_メッセージ一覧.md §4](#) を正本とする。本書では原文の項目構造 (表示・入力・操作・バリデーション・モーダル・状態) を網羅する。

2.5.1 5.1 SCR-001 ログイン

2.5.1.1 画面概要

項目	内容
画面 ID	SCR-001
目的	利用者 (オーナー / メンバー) が認証情報を入力してセッションを確立する
利用者	未ログイン admin
関連 FR	FR-004, FR-007, FR-008, FR-332
関連 API	POST /v1/sessions
関連メッセージ ID	MSG-SCR-001-*
必要権限	不要 (認証前)

2.5.1.2 表示・入力・操作項目

区分	項目	種類	概要
入力	メールアドレス	メールアドレスボックス	必須
入力	パスワード	パスワードボックス	必須
操作	ログインボタン	ボタン	認証 → 規約再同意チェック (必要なら SCR-025) → 利用状況系画面へ
操作	パスワードを忘れた場合	リンク	SCR-003 へ遷移
操作	アカウント登録	リンク	SCR-002 へ遷移
表示	認証エラーメッセージ	エラー	失敗時の共通文言 (攻撃者にヒントを与えない)
表示	ロックアウト警告	エラー	5 回失敗後 (FR-007)
表示	アクティブセッション一覧	テーブル	ログイン後にユーザーメニューから表示可能 (FR-332)。同一アカウントの複数デバイスログインを確認

2.5.2 5.2 SCR-002 アカウント登録

2.5.2.1 画面概要

項目	内容
画面 ID	SCR-002
目的	新規利用者 (オーナー) が SaaS にアカウント登録する
利用者	未ログイン admin
関連 FR	FR-001, FR-002
関連 API	POST /v1/accounts
関連メッセージ ID	MSG-SCR-002-*

2.5.2.2 表示・入力・操作項目

区分	項目	種類	概要
入力	メールアドレス	メールアドレスボックス	必須。管理者本人のメール
入力	パスワード	パスワードボックス	必須。FR-006 強度要件 (12 文字以上、3 種類以上の文字種)
入力	パスワード (確認)	パスワードボックス	必須。一致確認
入力	利用規約同意	チェックボックス	必須チェック
入力	プライバシーポリシー同意	チェックボックス	必須チェック
入力	業種選択	プルダウン	任意。「金融」「医療」等の高規制業界を選択した場合は標準提供範囲外であることを表示し、サポート窓口を案内 (要件 §16)
表示	規約・ポリシーリンク	リンク	別ウィンドウで全文表示
操作	登録ボタン	ボタン	入力検証 → 登録 → 確認メール送信 → SCR-023 へ
操作	ログイン画面リンク	リンク	既存ユーザー向け

2.5.3 5.3 SCR-003 パスワード再設定

2.5.3.1 画面概要 / 構成 3 段階構成 + Timeline:

- ・ 段階 1: メールアドレス入力 → 再設定リンク送信
- ・ 段階 1 送信後: メール送信済み案内 (再送 5 分カウントダウン)
- ・ 段階 2: 新パスワード設定 → 完了画面

2.5.3.2 表示・入力・操作項目

区分	項目	種類	概要
表示	ステップタイムライン	Timeline	「① メールアドレス入力 → ② 受信メールのリンクをクリック → ③ 新しいパスワードを設定」。現在ステップを aria-current="step" で強調
段階 1 入力	メールアドレス	メールアドレスボックス	必須、形式チェック
段階 1 操作	「再設定リンクを送信」	ボタン (Primary)	リクエスト発行 (存在有無は同一応答、列挙攻撃対策)
段階 1 送信後 表示	完了画面	中間表示	「[メールアドレス] にメールを送信しました。1 時間以内にメールのリンクをクリックして再設定を完了してください」
段階 1 送信後 操作	「メールを再送信する」	ボタン (Secondary、レート制限カウントダウン併記)	5 分以内は disabled、残時間表示
段階 2 入力	新パスワード	パスワードボックス + 強度メーター	必須。FR-006 強度要件。入力中にリアルタイムで強度 5 段階 (極弱/弱/中/強/極強) + 不足要件を表示
段階 2 入力	新パスワード (確認)	パスワードボックス	必須。一致確認
段階 2 操作	「新しいパスワードを設定する」	ボタン (Primary)	パスワード更新 → 全セッション失効 → 完了画面 → 自動的に SCR-001 へ
段階 2 表示	トークン無効 / 期限切れエラー	アラート帯 (画面上部固定) + 再送 CTA	段階 2 でリンク不正の場合、「再設定リンクが期限切れ、または無効です (有効期限 1 時間)。新しいリンクを再送してください」
段階 2 完了 表示	完了画面	中間表示	「新しいパスワードを設定しました。ログインしてください」 + 「ログインする」 CTA (SCR-001 へ)

2.5.3.3 バリデーション

- ・メールアドレス: 形式チェック (段階 1)
- ・新パスワード: 12 文字以上、英大文字・小文字・数字・記号のうち 3 種類以上
- ・新パスワード (確認): 一致確認

2.5.4 5.4 SCR-010 プロジェクト一覧

2.5.4.1 画面概要

項目	内容
画面 ID	SCR-010
目的	ウィジェット設置サイトごとのプロジェクトを管理
利用者	admin
関連 FR	FR-030～035
必要権限	project:manage(編集・削除)/ 参照は全 admin

2.5.4.2 表示・入力・操作項目

区分	項目	種類	概要
表示	パンくず	Breadcrumb	「ホーム / プロジェクト」
表示	プロジェクト ID	テキスト表示 (テーブル列)	内部 ID (短縮表示 + tooltip でフル表示)
表示	プロジェクト名	テキスト表示 (主)	カード型レイアウト時は見出しとして強調
表示	許可ドメイン	タグバッジ群	設定値を最大 3 件まで表示、超過分は +N 件 で折り畳み。サブドメインワイルドカード *.example.com も表示
表示	連絡先メール	テキスト + 状態バッジ	「 ☒ 確認済み」(緑)/「 ☒ 確認待ち」(黄)/「未設定」(灰)。色のみ依存禁止
表示	更新日時	テキスト表示	相対表記「3 時間前」+ tooltip で絶対日時
表示	件数表示	テキスト	「1-50 / 全 N 件」
操作	+ 新規プロジェクトを作成	ボタン (Primary)	SCR-010-M1 を「新規作成」モードで開く
操作	編集	ボタン (行アクション)	SCR-010-M1 を「編集」モードで開く
操作	削除する	ボタン (Danger / 確認ダイアログ + 再認証)	管理画面からの復元手段は提供しない
表示	空状態	EmptyState	「プロジェクトがまだありません。最初のプロジェクトを作成しましょう」+「+ 新規プロジェクトを作成」CTA
表示	ローディング状態	LoadingSkeleton	テーブル/カード行スケルトン 3 行

2.5.4.3 モーダル

モーダル ID	表示タイミング	目的
SCR-010-M1	「+ 新規プロジェクトを作成」または編集ボタンクリック時	プロジェクトの新規作成 / 編集
削除確認	削除ボタンクリック時	「プロジェクトを削除しますか?」+ 再認証

2.5.5 5.5 SCR-010-M1 プロジェクト設定モーダル (新規 / 編集)

2.5.5.1 モーダル概要

項目	内容
画面 ID	SCR-010-M1
目的	プロジェクトの新規作成 / 編集を全画面割込みモーダルで実施
呼出元	SCR-010 「+ 新規プロジェクトを作成」 / 編集ボタン
モード	新規作成 / 編集 (同一画面でモード切替)

2.5.5.2 表示・入力・操作項目

区分	項目	種類	概要
表示	モード見出し	見出し	新規「新規プロジェクトを作成」 / 編集「プロジェクト設定 - {プロジェクト名}」
入力	プロジェクト名 *(必須)	テキストボックス	1~100 文字、placeholder「例: サポートサイト」、文字数カウンタ
入力	許可ドメイン *(必須)	タグ入力 (複数値)	placeholder「例: https://example.com、*.example.com」。Enter またはカンマで 1 件追加、即時検証。完全一致 + *.example.com 形式可。IP アドレス・プロトコル指定は不可
表示	許可ドメイン補足ヘルプ	helper	「ウィジェット埋め込みを許可するドメイン。サブドメインを許可するには *.example.com のように記載します」
入力	プロジェクト連絡先メール	メールアドレスボックス	任意。確認メール送信 → リンククリックで確認完了。確認完了後は SCR-013 ウィジェットチャット上の「お問い合わせ先」表示にのみ利用
表示	連絡先メール 状態バッジ	バッジ	編集モード時のみ。「 ☒ 確認済み」 / 「 ☒ 確認待ち (残 N 時間)」 / 「未設定」
操作	確認メールを再送	ボタン (Secondary、レート制限カウントダウン併記)	編集モードかつ未確認時のみ活性
操作	キャンセル	ボタン (Secondary)	変更を破棄してモーダルを閉じる。未保存変更があれば UnsavedChangesGuard で警告
操作	プロジェクトを作成 / 変更を保存	ボタン (Primary)	バリデーション通過時に値を保存。新規作成時はウィジェット公開キーの初回発行も実施

2.5.5.3 バリデーション

- ・プロジェクト名: 必須、1~100 文字
- ・許可ドメイン: 必須、形式チェック (URL or ワイルドカード)、IP / プロトコル指定不可
- ・連絡先メール: 任意、メール形式

2.5.6 5.6 SCR-011 未解決質問一覧 / 詳細

2.5.6.1 画面概要 利用者 (管理者ユーザー) がウィジェットで回答できなかった質問を確認・対応する画面。一覧 + 詳細の 2 サブ画面構成。

項目	内容
関連 FR	FR-070~079, BR-019, BR-020
必要権限	参照: 全 admin / 返信: chat:respond

2.5.6.2 一覧画面の表示・操作項目

区分	項目	種類	概要
入力	クイックフィルタチップ	チップグループ	「自分の未対応」「期日切れ」「今日来た」「すべて」の 4 プリセット。各チップに件数バッジ

区分	項目	種類	概要
入力	詳細フィルタ(折り畳み)	折り畳みパネル	状況 / 担当管理者 / 期間
表示	適用済フィルタチップ	チップ+クリア	「すべてクリア」を常設
表示	件数表示	テキスト	「1-50 / 全 248 件」
操作	CSV エクスポート	ボタン	フィルタ適用結果をエクスポート
表示	問い合わせ ID	テキスト表示	inquiry_code
表示	状況(主バッジ)	バッジ	派生値(未解決 / 対応中 / 解決済み / 終了)。色の上に依存しない
表示	質問文(抜粋)	テキスト表示	先頭 60 文字
表示	発生理由(副情報)	サブテキスト(グレー)	reason_code を補助情報として 1 行下に表示
表示	メール登録	アイコン	登録済み / 未登録
表示	最終投稿日時	テキスト表示	相対表記 + tooltip で絶対日時
表示	担当管理者ユーザー	テキスト表示	-
操作	詳細 / 行クリック	ボタン	詳細画面へ
操作	チャット	ボタン	SCR-013 へ
操作	FAQ 登録	ボタン(admin のみ)	SCR-012 FAQ 登録モードへ
操作	担当管理者ユーザー設定	プルダウン(行内)	管理者ユーザー選択
表示	空状態	EmptyState	「未解決質問はありません。ウィジェットを設置済みなら正常な状態です。」 + 「ウィジェット設定を見る」リンク

2.5.6.3 詳細画面の構成 左 6 割: 質問 + チャット / 右 4 割: 候補 FAQ + 状態管理 + 履歴 の 2 ペイン構成 (SP では縦積み + タブ)。

区分	項目	種類	概要
表示	パンくず	Breadcrumb	「ホーム / 未解決質問 / {inquiry_code}」
表示	ページタイトル	PageHeader	「未解決質問の対応—{inquiry_code}」 + 部屋状態バッジ
表示	元質問	本文ブロック	全文
表示	回答不可理由	バッジ + 補足テキスト	reason_code
表示	チャット履歴	パネル(左ペイン)	SCR-013 のサブ表示
表示	候補 FAQ	リンカー一覧(右ペイン)	関連性の高い既存 FAQ
表示	案件状態バッジ	バッジ	case_status(4 値)
表示	チャット対応	バッジ + 日時	返信済み(初回返信日時付き) / 未返信
表示	状態履歴(折り畳み)	アコーディオン	状態変更ログ。デフォルト折り畳み

区分	項目	種類	概要
入力	案件状態	プルダウン	open / resolved のみ (closed は別操作経由)
入力	FAQ 候補状態	プルダウン	none / candidate / drafted / registered
入力	担当管理者ユーザー	プルダウン	-
操作	変更を保存	ボタン (Primary)	状態遷移ガード適用
操作	チャット返信	テキストエリア + 「送信」ボタン	投稿フォーム
操作	FAQ 登録へ	ボタン (admin のみ)	SCR-012 へ
操作	その他の操作 ▼(折り畳み)	アコーディオン	危険・低頻度操作
操作	⌵ 対応不要として終了 (admin のみ)	ボタン (確認ダイアログ)	終了理由 (必須・最大500文字) 入力 → case_status=closed (FR-079 admin の明示操作のみ)
表示	終了情報	テキスト表示	case_status=closed のとき終了日時・操作者・理由を表示
表示	権限不足表示	PermissionTooltip	chat:respond なしのメンバーは返信欄をグレースアウト + tooltip

2.5.6.4 モーダル

モーダル ID	表示タイミング	目的
終了確認	「対応不要として終了する」クリック時	case_status=closed への遷移確認 + 終了理由入力

2.5.7 5.7 SCR-012 FAQ 管理

2.5.7.1 画面概要 一覧 / 編集 / インポート / 下書き生成。

項目	内容
関連 FR	FR-040～048, FR-100～106, FR-310, FR-320～323
必要権限	faq:manage

2.5.7.2 一覧画面の表示・操作項目

区分	項目	種類	概要
表示	状態サマリチップ	チップグループ	「公開中 X」「下書き Y」「非公開 Z」をクリックで状態フィルタ即適用
入力	キーワード検索	テキストボックス	質問文・回答文の全文検索
入力	カテゴリフィルタ	プルダウン	プロジェクト内のカテゴリ
入力	並び順	プルダウン	関連度 / 更新日時 / 作成日時
表示	件数表示	テキスト	「1-50 / 全 124 件」
表示	FAQ ID	テキスト表示	-
表示	質問文 (抜粋)	テキスト表示	先頭 60 文字

区分	項目	種類	概要
表示	カテゴリ	テキスト表示	-
表示	状態バッジ	バッジ	状態別。色のみ依存禁止
表示	登録元	テキスト表示 + リンク	未解決質問起源の場合
表示	更新日時	テキスト表示	相対表記 + tooltip で絶対日時
操作	+ 新規作成	ボタン (Primary)	編集モードへ
操作	編集 / 行クリック	ボタン	編集モードへ
操作	公開 / 非公開切替	トグルスイッチ	状態変更 (admin のみ)
操作	削除	ボタン (行アクション、確認ダイアログ)	論理削除
操作	一括操作バー	BulkActionBar	1 件以上選択時に下部固定。最大 50 件
操作	CSV インポート	ボタン → モーダル	競合処理 (スキップ / 上書き / 別件追加) を選択
操作	CSV エクスポート	ボタン	CSV / JSON エクスポート
表示	インポート進捗	ProgressText + プログレスバー	100 件超は非同期ジョブ化、24h タイムアウト
表示	空状態	EmptyState	「FAQ がまだありません。最初の FAQ を作成しましょう。」

2.5.7.3 編集モードの構成 左 7 割: 質問・回答エディタ / 右 3 割: AI 下書きパネル + メタ情報。

区分	項目	種類	概要
表示	パンくず	Breadcrumb	「ホーム / FAQ / {FAQ ID} 編集」
表示	自動保存インジケータ	AutosaveIndicator	「30 秒前に保存しました」 / 「保存中…」 / 「保存できませんでした」
入力	質問文 *(必須)	テキストエリア	1~500 文字
入力	回答文 *(必須)	リッチテキストエリア	1~5,000 文字。簡易ツールバー
入力	カテゴリ	テキストボックス + サジェスト	任意。100 文字以内
入力	状態	ラジオボタン	draft / published / hidden。ラベルは「下書き」「公開中」「非公開」
表示	登録元未解決質問	テキスト表示 + リンク	存在する場合
表示	改訂履歴	リンク → モーダル	直近 50 件、差分表示、任意版へのロールバック
操作	キャンセル	ボタン (Secondary)	一覧へ戻る。未保存変更時は警告
操作	下書き保存	ボタン	status=draft で保存
操作	削除する	ボタン (Danger / 確認ダイアログ)	論理削除
操作	公開する	ボタン (Primary / 確認ダイアログ)	status=published で保存 (admin のみ)

区分	項目	種類	概要
操作	AI 下書きパネル(右ペイン)	パネル	元未解決質問を選択 → 「下書きを生成する」 → プレビュー → 「採用する」「やり直す」
表示	楽観ロック衝突	エラーアラート	faqs.version 不一致時

2.5.7.4 バリデーション

- ・ 質問文: 1~500 文字
- ・ 回答文: 1~5,000 文字
- ・ カテゴリ: 100 文字以内
- ・ 公開時ガード (基本設計書 § 4.2.1): AI / Batch による **draft** → **published** 直接遷移を 3 層で禁止

2.5.8 5.8 SCR-013 個別チャット部屋

2.5.8.1 画面概要 管理者側 / エンドユーザー側の 2 視点。一覧 + 部屋画面。

項目	内容
関連 FR	FR-080~091, FR-082a~c
必要権限	参照: 全 admin / 返信: chat:respond

2.5.8.2 管理者側 一覧画面

区分	項目	種類	概要
表示	パンくず	Breadcrumb	「ホーム / 個別チャット / {問い合わせ ID}」
表示	部屋状態バッジ	バッジ	room_status(open / closed) を画面上部に固定
表示	自動クローズ進捗バー	Timeline + ProgressText	reminder_state 6 段階を「3/6 段階」のように抽象化表示
入力	プロジェクトフィルタ	プルダウン	全体 / プロジェクト別
入力	対応状態フィルタ	チェックボックスグループ	case_status
入力	部屋状態フィルタ	チェックボックスグループ	open / closed
表示	案件状態列	バッジ	色 + アイコン + テキスト
表示	自動クローズ段階列	バッジ + 残時間	段階番号と次段階までの残時間
表示	件数表示	テキスト	「1-50 / 全 N 件」
表示	空状態	EmptyState	「個別チャットはまだありません。エンドユーザーからの問い合わせが始まるところに表示されます」

2.5.8.3 管理者側 部屋画面 (左ペイン: 会話)

区分	項目	種類	概要
表示	メッセージ履歴	チャットメッセージリスト	投稿者種別 / 本文 / 時刻、ページング、aria-live="polite"
表示	機密情報注意警告帯	アラート帯(入力欄直上に常時表示)	「機密情報(電話番号・クレジットカード番号・パスワード等)は入力しないでください」
入力	本文	テキストエリア	必須。最大 2,000 文字。エンドユーザーは 10 件/分の投稿頻度制限

区分	項目	種類	概要
操作	送る	ボタン (Primary)	メッセージ保存 → 相手側に通知 Queue 投入

2.5.8.4 管理者側 部屋画面 (右ペイン: 状態・危険操作)

区分	項目	種類	概要
入力	案件状態	プルダウン	open / resolved のみ
操作	変更を保存	ボタン	案件状態更新
操作	「利用者待ち」判定 (re-minder_state=stage1_pending_admin 時のみ)	ボタン	stage2_user_check_sent へ遷移、EU へ通知送信
操作	「対応中」判定 (同上)	ボタン	active へ戻す
操作	FAQ として登録	ボタン (admin のみ)	SCR-012 へ
操作	管理者ユーザー割当	プルダウン	-
操作	その他の操作 ▼ (危険操作セクション)	アコーディオン	以下の危険操作をまとめ
操作	⌵ 部屋を閉じる	ボタン (Danger / 確認ダイアログ / 再認証)	admin のみ。room_status=closed
操作	⌵ 部屋を再オープン (admin のみ、closed 時)	ボタン (確認ダイアログ / 再認証)	クローズから 30 日以内に限り同 room_id を再オープン
表示	部屋クローズ後 帯	アラート帯	room_status=closed 時「この問い合わせは {終了日} に終了しました」

2.5.8.5 エンドユーザー側

区分	項目	種類	概要
表示	問い合わせ ID	見出し	inquiry_code
表示	残時間カウントダウン	テキスト	再入室トークン有効期限を「あと 25 日」のように相対表示
表示	元質問	参照ブロック	未解決の元質問文
表示	メッセージ履歴	チャットメッセージリスト	-
表示	機密情報注意警告帯	アラート帯	同上
表示	お問い合わせ先メール	案内ブロック	確認完了済の連絡先メール設定時のみ表示
表示	終了案内	アラート帯	room_status=closed のとき投稿フォーム非表示
入力	メールアドレス (初回のみ)	メールアドレスボックス	必須。同一契約内で同一メールが保有可能な未クローズ案件は最大 5 件。メールアドレス変更 UI は MVP 不提供
入力	利用目的への了承	チェックボックス	必須
入力	本文	テキストエリア	必須。最大 2,000 文字
操作	メッセージを送る	ボタン (Primary)	メッセージ保存 → admin に通知

2.5.8.6 モーダル

モーダル ID	表示タイミング	目的
部屋クローズ確認	「部屋を閉じる」クリック	終了確認 + 再認証
部屋再オープン確認	「部屋を再オープン」クリック	再オープン確認 + 再認証

2.5.9 5.9 SCR-014 ウィジェット設定

2.5.9.1 画面概要 左 50% に設定パネル、右 50% に **プレビュー (デバイス切替可)** を固定配置。SP では縦積み。

項目	内容
関連 FR	FR-150～156, FR-193, FR-194, FR-350
必要権限	project:manage

2.5.9.2 (1) 公開キー管理セクション

区分	項目	種類	概要
表示	ウィジェット公開キー	テキスト + コピーボタン	形式 pk_live_<32-char base62>(FR-194)。参照のみ。コピー成功時に緑チェック + トースト
表示	キー有効期限残日数	カウントダウン	残時間に応じて色変化(残 30 日以上: 通常 / 残 7-30 日: 黄 / 残 7 日以内: 赤)
入力	公開キー有効期限	プルダウン	7 日 / 30 日 / 90 日 / 180 日 / 1 年、無期限不可、デフォルト 1 年
操作	有効期限を 1 年延長する	ボタン (Secondary)	「現在の残日数 + 1 年」を新有効期限として設定
表示	旧キー使用中バッジ	バッジ + 注意文	ローテーション猶予 30 日中に旧キー使用検知時に表示
操作	公開キーを再発行 (ローテーション)	ボタン (Danger / 確認ダイアログ + 再認証 ☑)	新キー発行と同時に旧キーは 30 日猶予で失効予告 (FR-193)

2.5.9.3 (2) 見た目セクション

区分	項目	種類	概要
入力	主色 (プライマリカラー)	カラーピッカー (HEX 指定)	FR-152。プレビューにリアルタイム反映
入力	強調色 (アクセントカラー)	カラーピッカー	FR-152
入力	配置	ラジオボタン	右下 / 左下 / 中央下
入力	角丸度	ラジオボタン	0px / 4px / 8px / 16px

2.5.9.4 (3) プレビュー (右ペイン固定)

区分	項目	種類	概要
表示	プレビュー	プレビューウィンドウ	設定変更時にリアルタイム反映
入力	プレビューデバイス切替	タブ (PC / Tablet / SP)	360px / 768px / 1200px
表示	「Powered by」表示	注釈	本サービス運営者ロゴを必須表示

2.5.9.5 (4) 埋め込みコードセクション

区分	項目	種類	概要
表示	埋め込みコード	コードブロック + コピーボタン	-
操作	設定の保存	ボタン (Primary)	設定更新 + KV キャッシュ無効化

2.5.10 5.10 SCR-015 利用状況・課金ダッシュボード

2.5.10.1 画面概要

項目	内容
関連 FR	FR-120～127, FR-129, FR-148, FR-191
必要権限	オーナー専有

2.5.10.2 表示・操作項目

区分	項目	種類	概要
入力	期間選択	プルダウン + 日付ピッカー	当月 / 前月 / 任意期間
表示	TrialBanner(常時表示)	バナー	トライアル中は常時表示。残 3 日以内は赤強調 + 「支払い方法を登録」 CTA
表示	サスペンション中の表示	アラート	contract_status=suspended で「現在ご利用いただけません」 + 支払方法更新導線
表示	サマリカードグリッド	SummaryCard × 6(PC 6 列 / Tablet 3 列 / SP 2 列)	質問数 / 解決数 / 未解決数 / FAQ 件数 / チャット部屋数 / AI 利用コスト
表示	UsageBar 状態ラベル	テキスト + 色	～60%: 表示なし / 61～80%: 黄 / 81～100%: 赤 / 101～125%: 濃赤
表示	metering_billable=false 件数	カード	失敗時の課金対象外件数
表示	料金プランカード	カード	質問数: ¥0～10,000 件/月 (無料枠) + ¥0.5/件 (超過分)、FAQ 件数: 8,000 件まで (警告) / 12,000 件まで (拒否)、チャット部屋: 200 件/月まで
表示	月次予算上限	テキスト表示	管理者ユーザー設定値
操作	予算上限を変更する	ボタン (再認証必須 ☑)	設定変更画面へ
表示	請求状態	バッジ	active / trialing / past_due / canceled / suspended
表示	警告アラート	アラートバナー	上限接近 (80%) / 超過 (100%) / 追加制限 (125%)
表示	請求履歴	テーブル (折り畳み可)	月別履歴、月毎の請求書 PDF リンク
操作	最新の請求書 PDF を開く	ボタン	R2 署名 URL、有効期限 5 分
操作	支払い方法を変更する	リンク	Stripe Customer Portal へ
操作	契約を解約する	ボタン (Danger、最下部、確認ダイアログ + 再認証)	解約フローへ。誤クリック防止のため「契約管理」セクション (折り畳み) に配置
表示	空状態	EmptyState	「請求履歴はまだありません。トライアル終了後に最初の請求が発生します。」

2.5.11 5.11 SCR-016 設定 (退会・課金画面入口)

2.5.11.1 画面概要 4 セクションに分割。誤操作防止のため危険操作セクションは画面最下部に分離。

項目	内容
関連 FR	FR-009, FR-125, FR-162, FR-167
必要権限	オーナー専有

2.5.11.2 (1) 連絡先 / アカウント情報

区分	項目	種類	概要
表示	契約情報	テキスト表示 (編集不可)	オーナーアカウントの基本情報
入力	連絡先メール	メールアドレスボックス	編集可能

2.5.11.3 (2) データ保持

区分	項目	種類	概要
入力	質問ログ保持日数	数値入力 / プルダウン + helper	初期値 (365 日) 以下のみ設定可。引き上げ不可 (NFR-702、サーバー側で検証)
入力	チャット履歴保持日数	数値入力 / プルダウン + helper	初期値以下のみ
入力	通知ログ保持日数	数値入力 / プルダウン + helper	初期値以下のみ

2.5.11.4 (3) アクセス制限

区分	項目	種類	概要
入力	IP 許可リスト (FR-179 / FR-330)	テキストエリア (CIDR 複数行入力)	契約単位でオプトイン。IPv4 / IPv6 両対応の CIDR 表記、ワイルドカード不可。空欄 = 制限なし
操作	現在の IP を追加する	ボタン (Secondary)	操作中のクライアント IP を <your-ip>/32 または /128 として末尾に追加
表示	現在の IP 表示	helper	「あなたが現在使用している IP: {currentIp}」を常時表示
表示	自己ロックアウト警告	アラート	入力中の IP リストに「現在の IP」が含まれていない場合 ☑ あなたの現在の IP がリストに含まれていません」を即時表示
操作	設定を保存	ボタン (Primary)	IP 許可リスト変更時は確認ダイアログ + 再認証

2.5.11.5 (4) 契約管理 (最下部に分離)

区分	項目	種類	概要
表示	退会案内	注意文	「退会するとサービスがご利用いただけなくなります」
操作	退会を申請する	ボタン (Danger、最下部)	→ SCR-024

2.5.12 5.12 SCR-017 ユーザー管理

2.5.12.1 画面概要 オーナーおよび **users:manage** 権限フラグ保持メンバーのみアクセス可能。一覧表示と行アクション (編集 / 削除) のみ。詳細操作はすべて **SCR-017-M1** に集約。

項目	内容
関連 FR	FR-017, FR-021a～c, FR-333
必要権限	オーナー / users:manage

2.5.12.2 表示・操作項目

区分	項目	種類	概要
表示	オーナー要約バナー (折り畳み可)	情報パネル	通常「オーナー: {表示名} ({メール}) [詳細 ▼]」のみ。展開時に「オーナーは契約 1 つにつき 1 人で、課金・退会・規約再同意を専有します。MVP では降格・停止・削除・譲渡はできません」

区分	項目	種類	概要
表示	権限フラグの説明セクション	折りたたみパネル	5種フラグそれぞれの「できること」一覧と「ダッシュボードはどの権限も不要で利用可」を明示
入力	検索	テキストボックス	表示名・メール部分一致
入力	状態フィルタ	プルダウン	すべて / 有効 / 停止中 / 招待中
表示	件数表示	テキスト	「1-50 / 全 N 件」
表示	利用者表示名	テキスト表示	自分の行は「{表示名}(あなた)」と末尾に注釈
表示	メールアドレス	テキスト表示	-
表示	ロール	バッジ	オーナー (青・☑) または メンバー (灰)
表示	状態	バッジ	「☑ 招待中」「☑ 有効」「☑ 停止中」
表示	権限フラグアイコン群	アイコンバッジ × 5	☑ FAQ 管理 / ☑ チャット対応 / ☑ ユーザー管理 / ☑ プロジェクト設定 / ☑ ログ参照。付与時はカラー、未付与は淡色。各 hover で tooltip。オーナー行は「☑ 全権限」バッジ
表示	割当プロジェクト	バッジ群	3 件超は +N 件 で折り畳み。割当 0 は「ダッシュボードのみ」、オーナー行は「全プロジェクト」
表示	最終ログイン日時	テキスト表示	相対表記 + tooltip で絶対日時
表示	招待中行強調	行背景色	pending_activation は黄色背景。「☑ 招待中 (残 N 日)」、残 1 日以下は赤背景
操作	+ メンバーを招待	ボタン (Primary)	SCR-017-M1 を「招待」モード
操作	編集	ボタン (行アクション)	メンバー行のみ。SCR-017-M1 を「編集」モード
操作	削除する	ボタン (Danger / 確認ダイアログ + 再認証)	メンバー行のみ。pending_activation 行では招待取消として動作
表示	空状態	EmptyState	「メンバーがまだ招待されていません。」
表示	権限不足ガード	PermissionTooltip	users:manage なしの URL 直アクセス時 403 → ダッシュボードヘリダイレクト

2.5.13 5.13 SCR-017-M1 メンバー招待 / 編集モーダル

2.5.13.1 モーダル概要 SCR-017 の「+ メンバーを招待」または「編集」ボタンから開く全画面割込みモーダル。招待 / 編集をモード切替で扱う。

項目	内容
関連 FR	FR-015～021, FR-015a～d, FR-016a～c, FR-018a～c, FR-021c, FR-333, FR-334, FR-335, FR-336～338

2.5.13.2 表示・入力・操作項目

区分	項目	種類	概要
表示	モード見出し	見出し	招待「メンバーを招待」 / 編集「メンバー編集ー{表示名}」
表示	自己編集警告帯 (編集モードかつ自分自身編集時)	アラート帯	「あなた自身を編集集中: 権限・状態は変更できません」
入力	メールアドレス	メールアドレスボックス	必須。招待モードでのみ編集可。編集モードでは表示のみ

区分	項目	種類	概要
入力	表示名(氏名)	テキストボックス	必須。オーナーの表示名はオーナー本人のみ編集可
入力	通知設定	チェックボックス	招待時の初期値、編集時の現値を表示・更新
入力	権限テンプレ(プリセット)	ラジオボタングループ	「FAQ 担当者」「問合せ対応者」「プロジェクト管理者」「ログ参照のみ」「カスタム」の5択
入力	メンバー権限フラグ(カスタム時のみ展開)	チェックボックス × 5	☒ FAQ 管理 / ☒ 個別チャット対応 / ☒ ユーザー管理 / ☒ プロジェクト設定 / ☒ ログ参照
入力	割当プロジェクト	チェックボックス群	プロジェクト一覧から0個以上を選択。操作者自身が割当を持つ(またはオーナーである)プロジェクトのみ選択可
表示	割当0件選択時の即時警告	アラート	「 ☒ プロジェクト未選択の場合、このメンバーはダッシュボードのみ利用できます」
表示	招待状態	バッジ	編集モード時のみ
表示	変更内容プレビューパネル	パネル(編集モード)	差分を「変更前 → 変更後」形式で表示
操作	招待メールを送信	ボタン(Primary、再認証 ☒)	招待モードのみ。access_tokens.purpose='activation'(7日)発行
操作	変更を保存	ボタン(Primary、再認証 ☒)	編集モードのみ
操作	招待を再送	ボタン(再認証 ☒)	編集モードかつ pending_activation のみ。旧リンク失効・新リンク発行
操作	招待を取り消す	ボタン(Danger、確認ダイアログ、再認証 ☒)	編集モードかつ pending_activation のみ
操作	メンバーを停止	ボタン(Danger、確認ダイアログ、再認証 ☒)	編集モードかつ active のみ
操作	停止を解除	ボタン(確認ダイアログ、再認証 ☒)	編集モードかつ disabled のみ
操作	強制ログアウト	ボタン(Danger、確認ダイアログ、再認証 ☒)	編集モードかつ active のみ。対象メンバーの全セッション失効
ガード	自己権限剥奪	UI 制御	自分自身の users:manage チェックを外す操作は非活性化 + tooltip
ガード	自己状態変更	UI 制御	自分自身を編集モードで開いた場合、「停止」「強制ログアウト」「招待取消」は非活性化

2.5.13.3 権限テンプレ プリセット定義

プリセット名	含まれる権限フラグ
FAQ 担当者	faq:manage
問合せ対応者	faq:manage + chat:respond
プロジェクト管理者	faq:manage + chat:respond + project:manage + logs:view(users:manage を除く全権限)
ログ参照のみ	logs:view
カスタム	選択した個別フラグの組合せ

2.5.14 5.14 SCR-018 プライバシーポリシー / 利用規約閲覧

2.5.14.1 画面概要 上部に同意状態バッジ + 最新版見出し、下に全文(目次付き)、最下部に過去バージョン一覧(折り畳み)。

項目	内容
関連 FR	FR-160, FR-164, FR-168
必要権限	不要(認証前可)

2.5.14.2 表示項目

区分	項目	種類	概要
表示	パンくず	Breadcrumb	「ホーム / プライバシーポリシー・利用規約」
表示	同意状態バッジ(上部固定)	バッジ	「 ☒ 同意済み({同意日})」(緑)/「 ☒ 未同意」(赤、SCR-025へのリンク併記)
表示	現行版見出し	h2	「利用規約 vX.X(発効 {YYYY-MM-DD})」
表示	目次(全文の章構成)	ナビゲーション	全文の見出しをクリックで該当章へジャンプ
表示	全文	リッチテキスト表示(sanitize 済)	利用規約 / プライバシーポリシー
表示	過去バージョン一覧(折り畳み)	アコーディオン + 表	バージョン番号 + 発効日 + 「全文を見る」リンク
表示	バージョン比較リンク	リンク	過去バージョンと最新版の差分を別タブで表示(diff形式)

2.5.15 5.15 SCR-021 お知らせ一覧

2.5.15.1 画面概要

項目	内容
関連 FR	FR-180～183, FR-323
必要権限	全 admin

2.5.15.2 表示・操作項目

区分	項目	種類	概要
表示	パンくず	Breadcrumb	「ホーム / お知らせ」
表示	クイックフィルタチップ	QuickFilterChips	「未読のみ」(デフォルト選択)「重要のみ」「課金」「お知らせ」「システム」「すべて」
表示	適用済フィルタチップ	AppliedFilterChips	適用条件 + 「すべてクリア」
入力	詳細フィルタ(折り畳み)	折り畳みパネル	期間 / キーワード検索
表示	件数表示	テキスト	「1-50 / 全 24 件(未読 3 件)」
表示	未読行の背景強調	行背景色	薄い水色背景 + 行頭ドット
表示	種別バッジ	バッジ	AnnouncementCategoryBadge
表示	重要度	アイコン + テキスト	critical ☒ + 「重要」 / high ☒ + 「重要」 / normal 無印 / low 淡色
表示	タイトル	テキスト表示	行クリックで SCR-022 へ。未読タイトルは bold
表示	配信日時	テキスト表示	相対表記 + tooltip で絶対日時
操作	詳細表示	行クリック	SCR-022 へ。同時に該当行を既読化
表示	BulkActionBar(複数選択時のみ)	画面下部固定	1 件以上選択時に表示。最大 100 件
操作	一括既読化	ボタン(BulkActionBar 内)	選択した行を既読化

区分	項目	種類	概要
操作	表示中の未読をすべて既読化	ボタン(画面右上)	現在のフィルタで表示中の未読のみを既読化
操作	すべての未読を既読化	リンク(副次的)	フィルタ無視で全未読を既読化。確認ダイアログ
表示	ページング	カーソル方式	-
表示	空状態	EmptyState	「お知らせはまだありません」/「未読のお知らせはありません」

2.5.16 5.16 SCR-022 お知らせ詳細

2.5.16.1 画面概要

項目	内容
関連 FR	FR-181, FR-182
必要権限	全 admin

2.5.16.2 表示・操作項目

区分	項目	種類	概要
表示	パンくず	Breadcrumb	「ホーム / お知らせ / {タイトル(短縮)}」
表示	メタ情報バー(タイトル直下)	バッジ群	種別バッジ + 重要度バッジ + 配信日時 + 既読化日時(あれば)
表示	種別バッジ	AnnouncementCategoryBadge	billing / announcement / system
表示	重要度バッジ	ImportanceIndicator	critical(☒) / high(☒) / normal(無印) / low(淡色)
表示	タイトル	h1	-
表示	配信日時	テキスト表示	絶対日時 + 相対日時
表示	既読化日時	テキスト表示	既読の場合のみ
表示	本文	リッチテキスト表示(sanitize済 HTML)	§ 10.5.1 二重サニタイズ、許可タグ・属性ホワイトリスト
表示	関連リンク(本文末尾)	リンク一覧(目立つカード形式)	種別に応じた遷移先
操作	自動既読化	自動 + 完了トースト	詳細画面表示時に自動既読化(初回のみ)
操作	一覧へ戻る	リンク(画面下部 + パンくず)	SCR-021 へ
操作	前のお知らせ / 次のお知らせ	リンク	一覧の並び順に基づく前後

2.5.17 5.17 SCR-023 メール確認

2.5.17.1 画面概要 新規登録後のメール確認画面。送信済み / 確認成功 / 確認失敗 の 3 状態。

項目	内容
関連 FR	FR-003

2.5.17.2 表示・操作項目

区分	項目	種類	概要
表示	状態タイムライン	Timeline	「①新規登録→②確認メールのリンクをクリック→③ログイン」
表示	送信先メールアドレス	テキスト表示(強調)	確認メール送信先
表示	案内文	テキスト表示	「確認リンクの有効期限は 24 時間です」+「メールが届かない場合は迷惑メールフォルダもご確認ください」
操作	メールを再送する	ボタン(Secondary、レート制限カウントダウン併記)	レート制限 5 分以内 1 回
操作	メールアドレスを変更する	リンク(Secondary)	SCR-002 へ戻る
表示	確認成功	完了画面	☒ + 「メールアドレスの確認が完了しました」+ 「ログインする」CTA
表示	確認失敗	エラー画面 + 復旧 CTA	「確認リンクが期限切れ、または使用済みです」+ 「新規登録からやり直す」CTA
操作	ログインする	ボタン(Primary)	成功後 SCR-001 へ

2.5.18 5.18 SCR-024 退会申請

2.5.18.1 画面概要 オーナー専有機能。タイムライン形式で 3 ステップを可視化。

項目	内容
関連 FR	FR-009
必要権限	オーナー専有

2.5.18.2 表示・入力・操作項目

区分	項目	種類	概要
表示	退会フロー タイムライン	Timeline	(1) 申請(今日)→(2){当月末日}: サービス停止 → (3){当月末日 + 30 日}: データ完全削除(復元不可)
表示	退会案内	テキスト表示	月末締めで停止、データエクスポート猶予 30 日
表示	データエクスポート 強調セクション	パネル(目立つ位置)	「 ☒ すべてのデータをエクスポートする」CTA
表示	課金影響	パネル	「当月分の従量課金は通常通り請求されます。次月以降の請求は発生しません」
表示	メンバーへの影響	パネル	「全メンバーのアクセス権が当月末で失効します」
入力	退会理由(任意)	テキストエリア	任意。最大 500 文字
操作	キャンセル	ボタン(Secondary)	SCR-016 へ戻る
操作	退会を申請する	ボタン(Danger/確認ダイアログ + 再認証 ☒)	accounts.contract_status=deleted_pending
表示	データエクスポート猶予残日数	カウントダウン表示	退会確定後表示
表示	物理削除予定日	テキスト表示	退会確定後 30 日経過後の物理削除日

2.5.19 5.19 SCR-025 規約再同意割込み

2.5.19.1 モーダル概要 全画面モーダル割込み (SP / PC ともフルスクリーン)。3 段 timeline で機能制限の段階的影響を可視化。

項目	内容
関連 FR	FR-011, FR-164

2.5.19.2 表示・入力・操作項目

区分	項目	種類	概要
表示	改定内容	リッチテキスト表示 (sanitize 済)	旧 / 新の差分または要約
表示	発効日	テキスト表示 (強調)	カレンダーアイコン + 日付
表示	同意期限	カウントダウン + テキスト表示	発効日 + 14 日。緑 → 黄 → 赤
表示	影響タイムライン (3 段)	Timeline	① 発効日まで: 通常通り / ② 発効日～同意期限: 選択を促す / ③ 同意期限超過後: 課金画面操作 + 新規プロジェクト作成不可
入力	規約同意	チェックボックス	必須。「全文を読む」リンク (SCR-018 を別タブ)
入力	プライバシーポリシー同意	チェックボックス	必須
操作	同意して続行する	ボタン (Primary)	両チェック充足時のみ活性化
操作	同意しない (退会手続きへ)	リンク (Danger 文字色)	退会フロー誘導 (SCR-024 へ)。確認ダイアログ
表示	機能制限ガード案内	アラート	期限超過時「同意期限 ({期限日}) を過ぎたため、課金画面操作と新規プロジェクト作成は同意するまで制限されます」
表示	段階的实施案内	helper テキスト	「契約単位で発効日が分散されます」

2.5.20 5.20 SCR-027 エンドユーザー再入室

2.5.20.1 画面概要 エンドユーザーがメール内トークンで個別チャット部屋へ再入室するための画面。エンドユーザー向けなので簡潔で直感的な表示を最優先。

項目	内容
関連 FR	FR-083, FR-084, FR-174
状態	有効 / 期限間近 / 期限切れ の 3 状態

2.5.20.2 表示・操作項目

区分	項目	種類	概要
表示	問い合わせ ID	見出し	トークンから復号
表示	問い合わせ件名 (あれば)	テキスト表示	質問本文の冒頭 50 文字
表示	トークン有効期限	テキスト表示 + アイコン	「あと {N} 日 {H} 時間」 + カラーグラデーション (残 14 日以上: 緑 / 残 3-14 日: 黄 / 残 3 日以内: 赤)
表示	期限切れ・無効エラー	アラート + 復旧 CTA	「リンクの有効期限が切れました (または無効です)。下記から新しいリンクをメールで受け取ってください」

区分	項目	種類	概要
入力	メールアドレス (期限切れ時のみ)	メールアドレスボックス	必須。元の問い合わせと同じアドレスで本人確認
操作	新しいリンクをメールで送る (期限切れ時のみ)	ボタン (Primary、ProgressText 付き)	レート制限 5 分以内 1 回
操作	続きから再開する (有効時)	ボタン (Primary、大きく目立つ)	トークン検証 → SCR-013 へ
表示	再送後の表示	完了画面	「[メールアドレス] に新しいリンクをメールで送信しました (有効期限 30 日)」 + 「メールを確認する」ボタン

2.5.20.3 トークン形式 不透明文字列 + HMAC-SHA256(オーナー派生 で計算)。トークン内に `inquiry_id` を含めて、同一メールで複数の問い合わせ ID がある場合の識別を担保 (FR-084)。

2.6 6. ユーザー種別別表示制御 (§5.5)

画面	admin 表示	end_user 表示	service_operator 表示
Sidebar 全項目	◎	×	×
ProjectSelector	全プロジェクト	×	×
SCR-012 FAQ 管理	◎	×	×
課金・設定リンク	◎	×	×
SCR-021 / SCR-022 お知らせ・通知ベル	◎	×	△(運用調査時のみ)
SCR-024 退会申請	◎	×	×
SCR-025 規約再同意割込み	◎(自アカウント)	×	×
SCR-027 エンドユーザー再入室	×	◎(トークン保有者のみ)	×

凡例: ◎ = 主アクター、○ = 可、△ = 必要時のみ、× = 不可

end_user が管理画面 URL を直叩きした場合は API 側で 403 を返す (AC-031)。

2.7 7. エンドユーザー向け画面の共通方針 (§5.7)

ウィジェット・SCR-027 はエンドユーザーが任意のドメイン上でアクセスする可能性があるため、以下を共通方針とする。

観点	方針
iframe sandbox 属性 (NFR-314)	sandbox="allow-scripts allow-forms allow-same-origin allow-popups" を必須設定。allow-top-navigation は付与しない
CSP frame-ancestors(NFR-313)	ウィジェットは frame-ancestors *、SCR-027 は frame-ancestors 'self'(iframe 埋め込み不可)
HSTS(NFR-315)	max-age=31536000; includeSubDomains; preload を必須付与
Cookie 属性 (NFR-318)	Secure; HttpOnly; SameSite=Lax; Path=/
CSRF(NFR-311)	SCR-027 はトークン認証のため CSRF Cookie 不要だが、X-Inquiry-Token ヘッダ + URL クエリ二重送信で検証

2.8 8. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------

2.9 9. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

3 API 設計書 (メイン)

3.1 1. 文書概要

3.1.1 1.1 目的

メインシステムのすべてのAPI(管理 API / ウィジェット API / 連携 IF #1～#12 送信側 / 外部 Webhook) について、エンドポイント / 認証・認可 / リクエスト / レスポンス / ステータスコード / エラー仕様を一元化する。

3.1.2 1.2 対象範囲

- 対象: 利用者向け管理 API(認証 / プロジェクト / FAQ / 案件 / チャット / ウィジェット設定 / 利用量・課金 / ユーザー管理 / お知らせ / 規約)、エンドユーザー向けウィジェット API、AI 推論抽象化 IF、メール配信抽象化 IF、顧客管理システムとの連携 IF #1～#12(送信側)、外部 Webhook(Resend 等)
- 対象外: 運営者管理 API(02_運営者システム/個別設計書群/03_API 設計書.md)、Stripe Webhook 一次受信 (運営者側 §13)

3.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

3.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_ 索引.md
画面設計書	API を呼び出す画面	02_ 画面設計書.md
テーブル定義書	API が操作するテーブル	04_ テーブル定義書.md
認証・認可設計書	認証要否 / 認可判定ルール	09_ 認証認可設計書.md
エラー設計書	ステータスコード / エラー詳細	06_ エラー設計書.md
メッセージ一覧	エラー文言	07_ メッセージ一覧.md
課金・請求設計書	課金 API / IF #1 / IF #10	11_ 課金請求設計書.md
運営者側 API 設計書	連携 IF #1～#12 受信側	../02_運営者システム/個別設計書群/03_API 設計書.md

3.2 2. API 一覧

3.2.1 2.1 機能と API の対応 (§6.3)

機能	API エンドポイント	認可	関連画面
認証	/auth/register, /auth/login, /auth/logout, /auth/re-auth, /auth/password/reset-requests	公開 (login)、認証済み (他)	SCR-001, SCR-002, SCR-003
メール確認	/auth/email-verifications/{token}	トークン認証	SCR-023
管理者ユーザー管理	/admin-users, /admin-users/{id}, /admin-users/{id}/activation-email	admin / users:manage	SCR-017, SCR-017-M1
プロジェクト管理	/projects, /projects/{id}	admin / project:manage	SCR-010, SCR-010-M1
FAQ 管理	/projects/{id}/faqs, /projects/{id}/faqs/{faqId}, /projects/{id}/faqs/import, /projects/{id}/faqs/export	admin / faq:manage	SCR-012

機能	API エンドポイント	認可	関連画面
ウィジェット	/widget/bootstrap, /widget/ask, /widget/feedback	end_user(公開キー + セッション)	ウィジェット
未解決質問	/inquiries, /inquiries/{id}, /inquiries/{id}/close	admin / chat:respond	SCR-011
チャット	/inquiries/{code}/email-registration, /chat/rooms/{id}, /chat/rooms/{id}/messages	admin / end_user	SCR-013
FAQ 改善	/inquiries/{id}/faq-drafts	admin / faq:manage	SCR-012 / SCR-013
通知	/webhooks/resend	署名検証のみ	(Resend Webhook)
利用量・課金	/billing/summary, /billing/subscription, /billing/invoices, /billing/budget	admin / オーナー専有	SCR-015
データ管理	/data/export	admin / オーナー専有	SCR-024
お知らせ受信箱	/me/announcements, /me/announcements/{id}, /me/announcements/{id}/read	admin 限定	SCR-021, SCR-022
規約	/terms/current, /terms/agree	admin	SCR-018, SCR-025
再入室	/widget/sessions/:token	トークン認証	SCR-027

3.2.2 2.2 外部 I/F 一覧 (§8.1)

カテゴリ	接続先	プロトコル	認証方式
顧客管理システム	運営者側システム	HTTPS + mTLS + JWT	連携 IF #1~#12
Stripe	課金決済	HTTPS	API キー、Webhook 署名
Resend	メール配信	HTTPS	API キー、Webhook 署名
Cloudflare Workers AI	AI 推論	HTTPS(内部)	自動認証
ウィジェット埋込元サイト	顧客サイト	HTTPS + CORS	公開キー + セッショントークン

3.3 3. 共通仕様

3.3.1 3.1 API 共通仕様 (§8.2)

項目	値
Base URL	/api/v1(管理)/ /widget/v1(ウィジェット)/ /internal/admin-integration/v1(内部連携)
データ形式	JSON
エラー形式	RFC 7807(application/problem+json)
日時	ISO 8601 + 末尾 Z(UTC)
ID 形式	ULID(26 文字)、Stripe ID 例外
ページング	カーソル方式(cursor, limit 50~200)
CSRF	Double Submit Cookie 検証(状態変更 API)
Cookie	Secure; HttpOnly; SameSite=Lax; Path=/

3.3.2 3.2 オーナー境界判定

すべての操作で `actor.owner_account_id == target.owner_account_id` を必須(認証・認可設計書 09 § 5.2)。違反時は **404 偽装**(エラー設計書 06 § 5.3)。

3.3.3 3.3 冪等性キー

書き込み系 API は **Idempotency-Key** ヘッダ(ULID 推奨、24h 保管)を受け付ける。重複時は既存処理結果を 200 で返却(リトライ安全性)。

3.3.4 3.4 Webhook 共通仕様 (§8.7.3)

項目	仕様
署名検証	HMAC-SHA256(送信元との共有 Secret)
冪等性	event_id で重複処理防止
リトライ	3 回(指数 BO: 1m → 4m → 16m)、超過で DLQ
DLQ 保持	4 日(Cloudflare Queues)、その後 R2 退避 30 日
タイムアウト	30 秒(超過で 5xx 返却)

3.3.5 3.5 連携 IF エンドポイント命名規約 (§8.8)

- ・ 受信: `/internal/admin-integration/v1/{resource}/{action}`
- ・ 送信: `https://<admin-host>/internal/main-integration/v1/...`
- ・ リソース: snake_case 単数形
- ・ 動詞: POST(状態変更)

3.3.6 3.6 認証ヘッダ

ヘッダ	用途	例
Cookie: session=<token>	利用者セッション	管理 API
Authorization: Bearer <wst_*>	ウィジェットセッション	ウィジェット API
Authorization: Bearer <JWT>	連携 IF	内部連携
X-CSRF-Token: <token>	CSRF 対策	状態変更系
X-Inquiry-Token: <token>	エンドユーザー再入室	/widget/sessions/:token
Idempotency-Key: <ULID>	冪等性	書き込み系

3.4 4. レート制限・キャパシティ (§11.7 リミット設計表の正本)

項目	警告レベル	拒否レベル	契約上書き	超過時の挙動	正本
同時アクティブ契約	150 でシャーディング着手	200	不可	新規契約受付一時停止 + 運営者通知	NFR-110
FAQ 件数(契約共通)	8,000(80%)	12,000(120%)	不可	拒否レベルで 429	FR-046
FAQ 質問文文字数	-	500 文字	不可	超過は 400	FR-046
FAQ 回答文文字数	-	5,000 文字	不可	超過は 400	FR-046
月間質問数	80%(通知)	100%(事後課金、拒否しない)	契約別上書き可	125% で追加制限	FR-122
Workers AI 月間コスト	80%	100%(停止)	契約別上書き可	同上	FR-122
チャット投稿(EU)	-	10 件/分、2,000 字/msg	不可	429、UI 警告	FR-090
チャット投稿(admin)	-	無制限(運営者調整可)	可(IF #5)	429	FR-090
公開 API /widget/ask	-	60 req/min/IP	可(IF #5)	429	FR-128
公開 API /widget/bootstrap	-	30 req/min/IP	可(IF #5)	429	FR-128
ログイン失敗	-	5 回/15 分(IP × user_id ロック)	不可	アカウントロック	FR-007
管理者ユーザー数	80%	100%	可(プラン依存)	429、通知	FR-021
プロジェクト数	平均 × 3 超過時通知	-	-	急増検知通知のみ	FR-035
同時オンライン管理者	-	1,000 名	-	503 + Retry-After	NFR-114

項目	警告レベル	拒否レベル	契約上書き	超過時の挙動	正 本
ウィジェット同時 接続(EU)	-	10,000 並列	-	503 + Retry-After	NFR- 114
D1 容量	8GB(80%)	10GB	-	高優先度アラート + シャーデ ィング検討	NFR- 115
Workers CPU 時間	50ms 目標 / 100ms 警告	-	-	100ms 超過が 1h で 1% 超で通 知	NFR- 116

詳細は 11_課金請求設計書.md § 8 80/100/125% 三段階アクション参照。

3.5 5. API 詳細

3.5.1 5.1 認証 API

3.5.1.1 5.1.1 POST /auth/signup(新規登録)

項目	内容
機能 ID	F-001
認証要否	不要
関連画面	SCR-002
関連テーブル	accounts, terms_agreements

リクエスト:

```
{
  "email": "admin@example.com",
  "password": "P@ssw0rd123!",
  "passwordConfirm": "P@ssw0rd123!",
  "agreedTerms": true,
  "agreedPrivacy": true,
  "turnstileToken": "..."
}
```

レスポンス (202):

```
{ "ok": true }
```

エラー: 400 VALIDATION_ERROR(E-INPUT-*), 400 TURNSTILE_FAILED

3.5.1.2 5.1.2 POST /auth/login

項目	内容
機能 ID	F-002
認証要否	不要
関連画面	SCR-001
関連テーブル	accounts, sessions

リクエスト:

```
{
  "email": "admin@example.com",
  "password": "...",
  "turnstileToken": "..."
}
```

レスポンス (200):

```
{
  "accountId": "01HZ...",
  "role": "admin",

```

```

    "requireTermsAgreement": false,
    "activeSessions": [
      { "id": "...", "ipAddress": "203.0.113.x", "createdAt": "..." }
    ]
  }
}

```

エラー: 401 **INVALID_CREDENTIALS**(E-AUTH-CREDENTIAL)、423 **LOCKED_OUT**(E-AUTH-LOCKED)、400 **TURNSTILE_REQUIRED**、403 **CONTRACT_SUSPENDED**(E-BILL-CONTRACT-SUSPENDED)

3.5.1.3 5.1.3 POST /auth/logout | 認証 | Cookie + CSRF | | レスポンス | 200 { "ok": true } |

3.5.1.4 5.1.4 POST /auth/password-reset-request(パスワード再設定要求) | 機能 ID | F-004 | | 認証
要否 | 不要 | | 関連画面 | SCR-003 |

リクエスト: { "email": "admin@example.com", "turnstileToken": "..." } レスポンス (202): { "ok": true } (列挙攻撃対策で存在有無を返さない)

3.5.1.5 5.1.5 POST /auth/re-auth(再認証) | 機能 ID | F-005 | | 認証要否 | 要 |

リクエスト: { "password": "..." } レスポンス (200): { "ok": true, "token": "reauth_..." } エラー: 401 **INVALID_PASSWORD**

3.5.1.6 5.1.6 POST /auth/email-verifications/{token}(メール確認) | 機能 ID | F-003 | | 関連画面 | SCR-023 |

トークン形式 = email_verify purpose の access_tokens.token_hash 検証。レスポンス (200): { "accountId": "...", "verifiedAt": "..." } エラー: 410 **TOKEN_EXPIRED**(E-AUTH-TOKEN-EXPIRED)

3.5.2 5.2 利用者 (メンバー)API

3.5.2.1 5.2.1 GET /members | 機能 ID | F-015 | | 必要権限 | users:manage or オーナー | | 関連画面 | SCR-017 |

レスポンス (200):

```

{
  "items": [
    {
      "id": "01HZ...",
      "email": "member@...",
      "status": "active|pending_activation|disabled",
      "role": "admin",
      "is_owner": false,
      "permissions": ["faq:manage", "chat:respond"],
      "assignedProjects": ["proj_1", "proj_2"],
      "lastLoginAt": "2026-05-13T10:00:00Z",
      "invitationExpiresAt": "2026-05-20T..."
    }
  ],
  "nextCursor": "01HZ..." | null
}

```

3.5.2.2 5.2.2 POST /members/invite | 認証 | Cookie + CSRF + 再認証必須 | | 関連画面 | SCR-017-M1 |

リクエスト:

```

{
  "email": "newmember@...",
  "displayName": " 新規メンバー",
  "permissions": ["faq:manage"],
  "projectIds": ["proj_1"]
}

```

レスポンス (201):


```
{
  "id": "01HZ...",
  "status": "pending_activation",
  "invitationToken": "invite_...",
  "expiresAt": "2026-05-20T..."
}
```

エラー: 409 ALREADY_EXISTS、400 VALIDATION_ERROR、403 PERMISSION_DENIED(オーナー専有)

3.5.2.3 5.2.3 POST /members/{id}/permissions | 認証 | Cookie + CSRF + 再認証必須 | | 必要権限 | users:manage or オーナー |

リクエスト: { "permissions": ["faq:manage", "chat:respond"] } レスポンス (200): { "id": "...", "permissions": [...], "updatedAt": "..." } エラー: 404 NOT_FOUND(オーナー境界違反、E-AUTHZ-OWNER-BOUNDARY)、403 OWNER_PROTECTED

3.5.2.4 5.2.4 POST /members/{id}/disable / DELETE /members/{id} | 認証 | Cookie + CSRF + 再認証必須 |

エラー: 403 OWNER_PROTECTED、404 NOT_FOUND

3.5.3 5.3 プロジェクト管理 API

3.5.3.1 5.3.1 GET /projects | 機能 ID | F-034 | | 関連画面 | SCR-010 |

レスポンス (200):

```
{
  "items": [
    {
      "id": "01HZ...",
      "name": "...",
      "status": "active|deleted",
      "createdAt": "...",
      "faqCount": 42,
      "widgetKey": "pk_live_...",
      "allowedDomains": ["example.com", "*.example.com"],
      "contactEmail": "contact@...",
      "contactEmailVerifiedAt": "..." | null
    }
  ],
  "nextCursor": null
}
```

3.5.3.2 5.3.2 POST /projects(新規作成) リクエスト:

```
{
  "name": " 新規プロジェクト",
  "description": " 説明文",
  "allowedDomains": ["example.com"]
}
```

レスポンス (201):

```
{
  "id": "01HZ...",
  "widgetKey": "pk_live_abc123...",
  "keyExpiresAt": "2027-05-13T..."
}
```

エラー: 400 VALIDATION_ERROR、409 DUPLICATE_NAME

3.5.3.3 5.3.3 PATCH /projects/{id} / DELETE /projects/{id} | 認証 | Cookie + CSRF(削除は再認証必須) | | エラー | 404 NOT_FOUND(オーナー境界違反偽装)|

3.5.3.4 5.3.4 POST /projects/{id}/widget-key/rotate(ウィジェット鍵ローテーション) | 認証 | 再認証必須 | | 関連画面 | SCR-014 |

リクエスト: { "expiresIn": 7 | 30 | 90 | 180 | 365 } レスポンス (201): { "newKey": "pk_live_xyz789...", "expiresAt": "...", "deprecationWarning": "..." }

3.5.4 5.4 FAQ 管理 API

3.5.4.1 5.4.1 GET /faqs?status=draft&projectId=...&keyword=...&cursor=... | 必要権限 | faq:manage(編集系)/ 参照は全 admin |

3.5.4.2 5.4.2 POST /faqs / PATCH /faqs/{id} / DELETE /faqs/{id} 楽観ロック: version 必須。CONFLICT 時 409。

3.5.4.3 5.4.3 POST /faqs/{id}/publish | 関連画面 | SCR-012 |

リクエスト: { "version": 6 } レスポンス (200): { "id": "...", "status": "published", "version": 7, "publishedAt": "..." } エラー: 422 INVALID_STATE(FAQ 自動公開禁止、§ 4.2.1 ガード)、409 CONFLICT

3.5.4.4 5.4.4 POST /faqs/import リクエスト: multipart/form-data { file: <CSV> } レスポンス (202): { "jobId": "job_...", "status": "processing" }

3.5.5 5.5 ウィジェット API

3.5.5.1 5.5.1 POST /widget/v1/bootstrap | 認証 | 不要(ドメイン検証)|

リクエスト:

```
{
  "publicKey": "pk_live_abc123...",
  "origin": "https://example.com"
}
```

レスポンス (200):

```
{
  "sessionToken": "wst_...",
  "expiresIn": 3600,
  "projectConfig": {
    "headerColor": "#06c",
    "placement": "bottom-right",
    "headerTitle": " お問い合わせ",
    "contactEmail": "contact@..."
  }
}
```

エラー: 401 WIDGET_KEY_INVALID / WIDGET_KEY_EXPIRED、403 DOMAIN_NOT_ALLOWED、403 CONTRACT_SUSPENDED

3.5.5.2 5.5.2 POST /widget/v1/ask(質問送信) | 認証 | Bearer session_token | | 機能 ID | F-049-052 |

リクエスト: { "question": " 返品の手続きは?", "projectId": "proj_..." }

レスポンス (200) - answered:

```
{
  "type": "answered",
  "answer": " 返品は商品到着後 7 日以内に...",
  "confidence": 0.78,
  "referencedFaqs": [
    { "id": "faq_...", "question": " 返品ポリシー", "answer": "..." }
  ],
  "questionLogId": "qlog_..."
}
```

レスポンス (200) - unanswered:

```
{
  "type": "unanswered",
  "reason": "low_confidence" | "no_faq_match" | "pii_detected",
  "questionLogId": "qlog_..."
}
```

エラー: 429 RATE_LIMITED、403 DOMAIN_NOT_ALLOWED

3.5.5.3 5.5.3 POST /widget/v1/inquiries(未解決質問登録) リクエスト:

```
{
  "email": "user@example.com",
  "displayName": " 太郎",
  "questionId": "qlog_...",
  "idempotencyKey": "<UUIDv4>"
}
```

レスポンス (201): { "inquiryId": "inq_...", "inquiryCode": "INQ-20260513-XYZ123", "roomId": "room_..." }

3.5.5.4 5.5.4 POST /widget/v1/chat-rooms/{id}/messages リクエスト: { "body": " メッセージ本文", "idempotencyKey": "<UUIDv4>" } エラー: 429(10/分制限)、400(2,000 字超)

3.5.6 5.6 未解決質問 API

3.5.6.1 5.6.1 GET /inquiries?status=open&projectId=...&cursor=...

3.5.6.2 5.6.2 GET /inquiries/{id} / PATCH /inquiries/{id} PATCH:

```
{ "caseStatus": "resolved", "assigneeAccountId": "..." }
```

3.5.6.3 5.6.3 POST /inquiries/{id}/close(対応不要終了) | 認証 | 再認証必須 | | 重要 | case_status=closed への遷移は admin の明示操作のみ (FR-079)|

リクエスト: { "reason": "resolved_by_faq|customer_resolved|out_of_scope|duplicate" } レスポンス (200): { "id": "...", "caseStatus": "closed", "closedAt": "..." }

3.5.6.4 5.6.4 POST /inquiries/{id}/draft-faq(AI 下書き生成) レスポンス (202): { "faqDraftId": "draft_...", "status": "processing", "estimatedTimeMs": 2000 }

3.5.7 5.7 チャット API

3.5.7.1 5.7.1 GET /chat-rooms/{id}/messages / POST /chat-rooms/{id}/messages

3.5.7.2 5.7.2 POST /chat-rooms/{id}/close / POST /chat-rooms/{id}/reopen | 認証 | 再認証必須 | | 条件 (reopen)| 30 日以内の過去クローズのみ |

3.5.8 5.8 利用量・課金 API

3.5.8.1 5.8.1 GET /usage?period=current_month | 機能 ID | F-120 | | 関連画面 | SCR-015 |

レスポンス (200):

```
{
  "period": "2026-05-01T00:00:00Z",
  "questions": { "used": 750, "limit": 1000, "percentage": 75, "resetAt": "2026-06-01T..." },
  "faqs": { "used": 85, "limit": 100, "percentage": 85 },
  "chatRooms": { "used": 28, "limit": 30, "percentage": 93 }
}
```

3.5.8.2 5.8.2 GET /billing/invoices?limit=6 レスポンス (200):

```
{
  "items": [
    {
      "id": "inv_...",
      "date": "2026-05-01T...",
      "amount": 5000,
      "currency": "JPY",
      "status": "paid|failed|draft",
      "pdfUrl": "https://..."
    }
  ]
}
```

pdfUrl は R2 署名 URL(有効期限 5 分)。

3.5.8.3 5.8.3 PATCH /billing/monthly-budget-limit | 認証 | 再認証必須 | | 機能 ID | FR-127 |

リクエスト: { "limitJpy": 50000 } レスポンス (200): { "limitJpy": 50000, "updatedAt": "..." }

3.5.9 5.9 お知らせ受信箱 API

3.5.9.1 5.9.1 GET /me/announcements?cursor=... | 必要権限 | admin 限定 | | 関連画面 | SCR-021 |

レスポンス (200):

```
{
  "items": [
    {
      "id": "ann_...",
      "title": "...",
      "category": "billing|announcement|system",
      "priority": "low|normal|high|critical",
      "bodyHtml": "<p> 本文 </p>",
      "readAt": "..." | null,
      "createdAt": "..."
    }
  ],
  "nextCursor": null
}
```

3.5.9.2 5.9.2 POST /me/announcements/{id}/read レスポンス (200): { "id": "...", "readAt": "..." }

3.5.9.3 5.9.3 GET /me/announcements/unread-summary レスポンス (200): { "unreadsCount": 5, "recent": [...] }

3.5.10 5.10 規約・退会 API

3.5.10.1 5.10.1 GET /terms/current | 認証要否 | 不要 | | 関連画面 | SCR-018 |

3.5.10.2 5.10.2 POST /terms/agree | 関連画面 | SCR-025 | | 関連テーブル | terms_agreements |

3.5.10.3 5.10.3 POST /withdrawal-requests(退会申請) | 認証 | オーナー専有、再認証必須 | | 関連画面 | SCR-024 | | 関連テーブル | withdrawal_requests, accounts |

エラー: 403 PERMISSION_DENIED(メンバー)

3.5.11 5.11 AI 推論 IF(AnswerProvider 抽象化)

```
export type AnswerResult =
  | { kind: 'answered'; answer: string; cited_faq_ids: string[]; confidence: number }
  | { kind: 'unanswerable'; reason_code: 'no_match' | 'low_confidence' | 'contradiction' }
  | { kind: 'error'; reason_code: 'provider_error' | 'timeout' | 'rate_limited' };

export interface AnswerProvider {
  generate(input: {
    question: string;
    candidate_faqs: Array<{ id: string; question: string; answer: string }>;
    policy: { faq_only: true; forbid_new_facts: true; learn: false };
    locale: 'ja-JP';
    timeout_ms: 8000;
  }): Promise<AnswerResult>;

  healthcheck(): Promise<{ ok: boolean; provider: string; model: string }>;
}
```

MVP は Cloudflare Workers AI 実装 (WorkersAIAnswerProvider)。

3.5.12 5.12 メール配信 IF(EmailProvider 抽象化)

```
export interface EmailProvider {
  send(input: {
    to: string; from: string; reply_to?: string; subject: string;
    html: string; text?: string; headers?: Record<string, string>;
    idempotency_key: string;
  }): Promise<{ message_id: string }>;

  verifyWebhook(headers: Headers, body: string): Promise<{
    valid: boolean;
    event_type: 'sent' | 'delivered' | 'bounced' | 'complained' | 'failed' | 'opened' | 'clicked';
    message_id: string;
    timestamp: string;
  }>;
}
```

MVP は Resend 実装 (ResendEmailProvider)。

3.5.13 5.13 連携 IF(受信側、メイン側エンドポイント)

3.5.13.1 5.13.1 IF #1 契約停止イベント受信 (顧客 → メ)

POST /internal/admin-integration/v1/owner/suspend

認証: mTLS + JWT(aud=main、TTL 5min)

リクエスト:

```
{
  "operationId": "01HZ...",
  "ownerAccountId": "01HZ...",
  "targetStatus": "suspended",
  "reason": "payment_failed|terms_violation|manual_admin",
  "occurredAt": "2026-05-13T10:00:00Z",
  "operatorAccountId": "..."
}
```

ヘッダ: Idempotency-Key: (operation_id, owner_account_id, target_status)

レスポンス (200): { "ok": true, "newStatus": "suspended", "appliedAt": "..." }

動作:

1. JWT + Idempotency-Key 検証
2. accounts.contract_status(オーナー行) 更新

3. KV キャッシュ無効化(セッション/KV/レート制限)
4. reason に応じてセッション処理(operator_manual / tos_violation は 5 秒以内 に全セッション無効化)

エラー: 401 JWT_INVALID、409 CONFLICT

3.5.13.2 5.13.2 IF #2 強制ログアウト受信

POST /internal/admin-integration/v1/owner/forced-logout

リクエスト:

```
{
  "operationId": "...",
  "ownerAccountId": "...",
  "scope": "all|single_account",
  "accountId": "...",
  "reason": "..."
}
```

動作: sessions.revoked_at 設定 + KV キャッシュ強制 invalidate(5 秒以内)

3.5.13.3 5.13.3 IF #4 復元実行受信

POST /internal/admin-integration/v1/owner/restore

認証: mTLS + JWT + 再認証トークン

3.5.13.4 5.13.4 IF #5 レート制限上書き受信

POST /internal/admin-integration/v1/rate-limit/override

リクエスト:

```
{
  "ownerAccountId": "...",
  "overrideId": "...",
  "limits": [{ "kind": "ask", "limit": 30, "windowSec": 60, "validUntil": "..." }],
  "reason": "...",
  "operatorAccountId": "..."
}
```

動作:

1. JWT + Idempotency-Key 検証
2. owner_quota_overrides テーブル更新
3. KV キー ratelimit:{ownerAccountId}:{kind} 更新(即時反映)

3.5.13.5 5.13.5 IF #6 AI しきい値上書き受信

POST /internal/admin-integration/v1/threshold/update

リクエスト:

```
{
  "ownerAccountId": "...",
  "version": "2026-05-13T10:00:00Z",
  "projectId": null,
  "confidenceThreshold": 0.65,
  "relevanceThreshold": 0.55,
  "scope": "owner|project",
  "operatorAccountId": "..."
}
```

動作:

1. JWT + Idempotency-Key 検証
2. KV ai_threshold:{ownerAccountId}:{projectId} 更新(60s TTL)
3. ai_threshold_persistent_cache に永続化

4. IF #12 経由で管理者ユーザーに inbox 配信

3.5.13.6 5.13.6 IF #7 お知らせ生成受信

POST /internal/admin-integration/v1/announcement/inbound

リクエスト:

```
{
  "announcementId": "...",
  "ownerAccountId": null,
  "title": "...",
  "bodyHtml": "<p>...</p>",
  "importance": "low|normal|high|critical",
  "audienceOwnerAccountIds": null,
  "publishedAt": "...",
  "operatorAccountId": "..."
}
```

動作:

1. JWT + Idempotency-Key 検証
2. **service_announcements** レコード作成
3. **announcement_recipients** を宛先範囲に応じて生成
4. announcement-fanout-queue に投入、**inbox_messages** へ fan-out

3.5.13.7 5.13.7 IF #8 監視メトリクス取得 (送信側、メ → 顧管)

GET https://<admin-host>/internal/main-integration/v1/metrics?window=5m|1h|24h

認証: mTLS + JWT(aud=admin)

レスポンス (200):

```
{
  "window": "5m",
  "since": "...",
  "until": "...",
  "owners": [
    {
      "ownerAccountId": "...",
      "errorRate5xx": 0.002,
      "aiInferenceP95Ms": 1234,
      "queueDlqCount": 0,
      "emailBounceRate": 0.01,
      "emailComplaintRate": 0.0005,
      "billingWebhookFailures": 0,
      "aiAnswerableRate": 0.85
    }
  ],
  "global": { "d1UsageRatio": 0.65 }
}
```

3.5.13.8 5.13.8 IF #9 不正利用検知通知 (送信側、メ → 顧管)

POST https://<admin-host>/internal/main-integration/v1/fraud/detected

リクエスト: { "detectionId": "...", "ownerAccountId": "...", "pattern": "...", "details": {...} }

DLQ 上限: 200/30 分

3.5.13.9 5.13.9 IF #10 課金 Webhook 受信 (顧管 → メ)

POST /internal/admin-integration/v1/billing-webhook/forward

リクエスト:

```
{
  "stripeEventId": "evt_...",
  "eventType": "invoice.paid|invoice.payment_failed|customer.subscription.created|...",
  "ownerAccountId": "...",
  "payload": { /* Stripe イベント */ },
  "receivedAt": "...",
  "signatureVerifiedAt": "..."
}
```

動作:

1. JWT 検証 + event_id 冪等性
2. Stripe イベント種別に応じてハンドラ分岐:
 - **invoice.paid**: **billing_invoices.status='paid'**、**suspended** → **active** 復帰
 - **invoice.payment_failed**: 通知、7 日猶予タイマー開始
 - **customer.subscription.created**: **billing_subscriptions** 作成
 - **charge.refunded**: 訂正請求行記録
3. IF #1 経由で **accounts.contract_status** 反映

Idempotency-Key: event_id(Stripe evt_*) DLQ 滞留上限: 1000/24h

3.5.13.10 5.13.10 IF #12 運営者操作通知受信

POST /internal/admin-integration/v1/admin-operation/notify

リクエスト:

```
{
  "operationId": "...",
  "ownerAccountId": "...",
  "operationKind": "owner.restore_data|owner.suspend|rate_limit.override|...",
  "occurredAt": "...",
  "actorOperatorId": "...",
  "ticketId": "...",
  "summary": " 削除データを復元しました"
}
```

動作:

1. JWT + Idempotency-Key 検証
2. **inbox_messages** に重要度 **high** で生成 (管理者 inbox 表示)
3. メール通知 Queue 投入 (**critical** の場合はメール強制送信)

3.5.14 5.14 外部 Webhook(Resend 等)

3.5.14.1 5.14.1 POST /webhooks/resend 認証: Resend 署名検証 (HMAC-SHA256)

リクエスト (Resend 仕様準拠):

```
{
  "type": "email.delivered|email.bounced|email.complained|email.delivery_delayed",
  "data": {
    "message_id": "...",
    "to": "...",
    "subject": "...",
    "timestamp": "..."
  }
}
```

動作:

1. 署名検証 (失敗時は 401)
2. **notification_logs.delivery_state** を遷移
3. **bounced** / **complained** の場合は **email_suppression_list** に追加 (全契約横断)

エラー: 401 **SIGNATURE_INVALID**、200 + 既存処理結果 (冪等性違反)

3.6 6. 連携 IF 通信仕様一覧

IF#	連携先	方向	認証	Idempotency	DLQ 上限	TO	主管
1	顧管	→ ×	mTLS + JWT(aud=main)	(operation_id, owner_account_id, target_status)	100/30分	5s	受信
2	顧管	→ ×	mTLS + JWT	(operation_id, owner_account_id)	100/30分	3s	受信
4	顧管	→ ×	mTLS + JWT + 再認証	(restore_op_id)	50/24h	10s	受信
5	顧管	→ ×	mTLS + JWT	(owner_id, override_id)	50/30分	3s	受信
6	顧管	→ ×	mTLS + JWT	(owner_id, scope, version)	50/30分	3s	受信
7	顧管	→ ×	mTLS + JWT	(announcement_id, owner_id)	1000/h	30s	受信
8	顧管	× →	mTLS + JWT(aud=admin)	(metric_window_id)	n/a	10s	送信
9	顧管	× →	mTLS + JWT(aud=admin)	(detection_id)	200/30分	5s	送信
10	Stripe → 顧管 → ×	→ ×	Stripe 署名 + mTLS	event_id	1000/24h	10s	受信
12	顧管	→ ×	mTLS + JWT	(op_id, owner_id)	200/30分	5s	受信

詳細は運営者側 [03_API 設計書.md §5.8](#) を参照。

3.7 7. 未決事項

No	内容	確認先	期限	ステータス
1	IF #3 / #11 の用途	要件側で予約済み、MVP 範囲外	Future	既決

3.8 8. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

4 テーブル定義書 (メイン)

4.1 1. 文書概要

4.1.1 1.1 目的

メインシステムのデータベース (Cloudflare D1) に存在するすべてのテーブルについて、カラム / 型 / 制約 / インデックス / 外部キー / コード値 / 保持期間 / 保持起点 / **owner_account_id** 分離方式を一元化する。

4.1.2 1.2 対象範囲

- 対象: 利用者向けデータ 32 テーブル (認証 / プロジェクト / FAQ / 案件 / チャット / 通知 / 課金 / お知らせ / 監査 / 規約 等)
- 対象外: 運営者側専用テーブル (**operator_***, **audit_logs** (ハッシュチェーン構造の運営者部分), **web-hook_events**, **operator_approvals**, **accounts_retired** 等) — 02_ 運営者システム/個別設計書群/04_ テーブル定義書.md 参照

4.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

4.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11ドキュメント体系の俯瞰	00_索引.md
共有概念対応表	accounts.contract_status / オーナーユーザーモデルなど	../共有/共有概念.md
API 設計書	テーブルを操作する API	03_API 設計書.md
認証・認可設計書	オーナー境界判定	09_認証認可設計書.md
権限設計書	account_permissions / account_project_grants	05_権限設計書.md
セキュリティ設計書	PII 暗号化 / 監査 / 削除モード	10_セキュリティ設計書.md
課金・請求設計書	accounts.contract_status 正本 / 契約上書きテーブル	11_課金請求設計書.md
詳細設計書	実装関連の詳細 (モジュール構成 / バッチ / マイグレーション)	../03_詳細設計書.md

4.2 2. テーブル一覧

#	テーブル名	論理名	概要	主キー	owner_account	主管 FR	保持期間	保持起点	retention_class
1	accounts	アカウント	オーナー / メンバー両方を 1 表に保持 (is_owner=1 がオーナー)	id	自己参照 (オーナー行は id = owner_account_id)	FR-015a, FR-303	永久 (契約存続中) / 退会後は § 7 削除ポリシー	作成日時	billing
2	account_permissions	権限	メンバー権限フラグ (faq:manage 等)	(account_id, permission_kind)	(accounts 経由)	FR-333	紐づくアカウントに従属	-	general
3	account_project_grants	メンバープロジェクト割当	メンバーのプロジェクトアクセス	(account_id, project_id)	(accounts 経由)	FR-030-035	同上	-	general
4	sessions	セッション	セッション管理 (複数デバイス対応)	id	(accounts 経由)	FR-022, FR-332	期限切れ後 90 日	最終アクティビティ	general
5	access_tokens	アクセストークン	招待 / パスワード再設定 / 再入室等のトークン	id	(accounts 経由)	FR-004, FR-008	使用後 30 日	発行日時	general
6	projects	プロジェクト	FAQ プロジェクト / ウィジェット設定	id	あり	FR-030-035	永久 (プロジェクト存続中)	作成日時	general
7	project_registry_keys	API キー	ウィジェット ローテーション 30 日猶予	id	(projects 経由)	-	30 日	ローテーション日時	general
8	allowed_domains	許可ドメイン	ウィジェット埋め込み許可ドメイン	id	(projects 経由)	FR-150-156	プロジェクトに従属	-	general
9	faqs	FAQ	FAQ 本体	id	あり	FR-040-048, FR-322	永久 (FAQ 存続中)	作成日時	general
10	faq_revisions	FAQ 改訂履歴	全文スナップショット 50 件保持	id	(faqs 経由)	FR-322	永久 (版ごと)	改訂日時	general

#	テーブル名	論理名	概要	主キー	owner_account	主管FR	保持期間	保持起点	retention_class
11	faq_search	FAQ全文検索	FTS5 仮想テーブル (trigram)	(rowid)	(faqs 連動)	FR-300	faqs に従属	-	-
12	question_logs	質問ログ	エンドユーザーからの質問 / AI 推論	id	あり	FR-003, NFR-601	730 日 (自動匿名化)	投稿日時	general
13	question_logs_faq	質問 FAQ	質問と FAQ の M:N 関係	id	(経由)	-	question_logs に従属	-	general
14	inquiries	案件	未解決質問のグループ	id	あり	FR-070-079	永久 (case_status=closed 後は NFR-706)	作成日時 / クローズ日時	general
15	inquiry_status_history	案件状態履歴	状態変更トレース	id	(inquiries 経由)	FR-077	inquiries に従属	-	general
16	inquiry_contact	案件連絡先	エンドユーザーメール (AES-256-GCM 暗号化 + HMAC)	id	(inquiries 経由)	FR-079, NFR-319	inquiries に従属 (物理削除 / 匿名化)	-	general
17	chat_rooms	個別チャット部屋	エンドユーザーとの個別チャット (自動クローズ 6 段階)	id	(inquiries 経由)	FR-080-091	730 日 (自動匿名化)	クローズ日時と最終投稿日時の遅い方	general
18	chat_messages	チャットメッセージ	個別チャットの投稿	id	(chat_rooms 経由)	FR-080-091	chat_rooms に従属	-	general
19	notification_logs	通知ログ	メール通知の送信履歴	id	あり	NFR-506, NFR-319	1 年	送信日時	general
20	ai_threshold_persistence	AI 閾値キャッシュ	6 階層のキャッシュ値の永続	id	あり (scope=owner 時)	FR-341	30 日	更新日時	general
21	email_suppression	バウンス・苦情の全契約横断管理	バウンス・苦情の全契約横断管理	id	(全契約横断)	FR-149b	永久	サブレス日時	general
22	audit_logs	監査ログ	メイン側 API 操作ログ + 監査 (運営者側がハッシュチェーン構造の正本)	id	あり (owner_account カラム)	NFR-602a/b	retention_class 602a/b (1 / 7 / 5 年)	操作日時	general / billing / operator_high_priv
23	error_logs	エラーログ	サーバーエラー記録	id	あり (可)	NFR-704	180 日	発生日時	general
24	billing_subscription	課金サブスクリプション	Stripe Subscription 連動	id	あり	FR-148	永久 (契約存続中)	作成日時	billing
25	billing_invoice	請求書	月次請求書 (電子帳簿保存法)	id	あり	FR-148, NFR-602b	7 年	発行日時	billing
26	usage_metering	利用量計測	質問数 / FAQ 件数 / チャット部屋数	id	あり	FR-148	7 年	計測日時	billing
27	owner_contract_memo	契約別メモ	運営者上書き (SCR-093) —— レート / 予算ともに本テーブルで統一実装 (resource_kind で区別)	id	あり	IF #5	5 年	設定日時	operator_high_priv
28	service_announcement	お知らせ (Control Plane)	運営者発信のお知らせ 本体	id	(全契約横断 or 限定)	-	5 年	配信日時	operator_high_priv
29	announcement_recipient	お知らせ受信者	お知らせ配信先・配信集計・監査	id	あり	-	5 年	配信日時	general

#	テーブル名	論理名	概要	主キー	owner_account	主管FR	保持期間	保持起点	retention_class
30	inbox_messages	受信箱 (Tenant Plane)	利用者のお知らせ・通知の既読管理	id	あり	FR-182-192	1 年	既読日時	general
31	withdrawal_requests	退会申請	退会申請レコード (30 日猶予)	id	あり	FR-189	7 年	申請日時	billing
32	terms_versions	規約版数	規約 / プライバシーポリシーの版	version	(全契約横断)	-	永久	制定日時	general
33	terms_agreements	規約同意	利用者ごとの同意履歴	id	(accounts 経由)	-	7 年	同意日時	billing

4.2.1 2.1 retention_class 値の正本定義 (audit_logs.retention_class)

値	保持期間	用途	例
general	1 年 (NFR-602a)	業務監査	通常の操作 / チャット / FAQ 編集 / ログイン
billing	7 年 (NFR-602b、電子帳簿保存法)	課金・法定保管	請求 / 支払 / サブスク / 予算 / owner.suspend prefix
operator_high	5 年 (NFR-602d、SOX 類似)	運営者高権限操作	復元 / 契約停止 / 物理削除 / AI 変更 / レート上書き / ローテーション

詳細は [10_セキュリティ設計書.md §7](#)(運営者側 §7 が正本) を参照。

4.2.2 2.2 主要関係性 (§7.3 から移管)

関係	型	説明
オーナー ☒ アカウント	1:N	契約削除時にアカウントも削除対象 (オーナー行: is_owner=1)
契約 ☒ プロジェクト	1:N	-
プロジェクト ☒ FAQ	1:N	FAQ はプロジェクトに帰属
プロジェクト ☒ 未解決質問	1:N	-
未解決質問 ☒ チャット部屋	1:1	-
チャット部屋 ☒ メッセージ	1:N	-
未解決質問 ☒ FAQ	0..1:N	faqs.source_unresolved_question_id で参照可
お知らせ ☒ 受信箱	1:N	service_announcements → announcement_recipients → inbox_messages の fan-out

4.2.3 2.3 メンバー権限保持方式 (設計判断履歴、§7.1.1 から移管)

採用方式は 案 A: 別テーブル方式 (account_permissions)。(account_id, permission_kind) 複合 PK + granted_at / granted_by 保持で行レベル監査を維持。検討時の案 B(bitmask)/ 案 C(JSON 配列) は却下。

4.3 3. テーブル詳細

4.3.1 3.1 accounts(アカウント)

項目	内容
テーブル名	accounts
論理名	アカウント
概要	オーナー (is_owner=1) とメンバー (is_owner=0) の両方を 1 表に保持
主キー	id(TEXT, ULID)
設計判断	オーナー行は owner_account_id = id で自己参照。is_owner=1 行は account_permissions / account_project_grants に行を持たない (オーナーは全権)

4.3.1.1 DDL(詳細設計書 行 5827-5859 由来)

```
CREATE TABLE accounts (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
  email_encrypted TEXT NOT NULL,
  email_hmac TEXT NOT NULL,
  password_hash TEXT,
  name TEXT,
  role TEXT NOT NULL CHECK (role IN ('admin','service_operator','end_user')),
  is_owner INTEGER NOT NULL DEFAULT 0 CHECK (is_owner IN (0,1)),
  status TEXT NOT NULL DEFAULT 'pending_verification'
  CHECK (status IN ('pending_verification','pending_activation','active')),
  contract_status TEXT NOT NULL DEFAULT 'active'
  CHECK (contract_status IN ('active','suspended','deleted_pending','deleted')),
  notification_preferences TEXT NOT NULL DEFAULT '{}',
  last_login_at TEXT,
  email_verified_at TEXT,
  created_at TEXT NOT NULL,
  deleted_at TEXT,
  CHECK ((is_owner = 1 AND owner_account_id = id) OR (is_owner = 0 AND owner_account_id <> id))
);
CREATE UNIQUE INDEX uq_accounts_owner_email ON accounts(owner_account_id, email_hmac);
CREATE INDEX idx_accounts_email_hmac ON accounts(email_hmac);
CREATE INDEX idx_accounts_owner_role_status ON accounts(owner_account_id, role, status);
CREATE INDEX idx_accounts_is_owner ON accounts(is_owner) WHERE is_owner = 1;
```

4.3.1.2 コード値: role / is_owner / status / contract_status

カラム	値	説明
role	admin	利用者管理者
role	service_operator	運営者(運営者画面アクセス用、メインでも accounts に格納)
role	end_user	エンドユーザー(ウィジェット利用者)
is_owner	0	メンバー
is_owner	1	オーナー(契約あたり1つ)
status	pending_verification	メール未確認
status	pending_activation	招待中(初回パスワード未設定)
status	active	有効
status	disabled	無効化
contract_status	active	有効(オーナー行でのみ意味を持つ。共有概念正本)
contract_status	suspended	サスペンション中
contract_status	deleted_pending	退会申請中(30日猶予)
contract_status	deleted	削除済み

詳細状態遷移は [11_課金請求設計書.md §4](#) を正本とする。

4.3.2 3.2 account_permissions(メンバー権限)

4.3.2.1 DDL(行 5864-5874)

```
CREATE TABLE account_permissions (
  account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
  permission_kind TEXT NOT NULL
  CHECK (permission_kind IN ('faq:manage','chat:respond','users:manage','project:manage')),
  granted_at TEXT NOT NULL,
  granted_by TEXT NOT NULL REFERENCES accounts(id),
  PRIMARY KEY (account_id, permission_kind)
);
CREATE INDEX idx_account_permissions_kind ON account_permissions(permission_kind);
```

4.3.2.2 コード値: **permission_kind** 5 値 詳細は [05_権限設計書.md §3](#) を参照。

4.3.3 3.3 account_project_grants(メンバープロジェクト割当)

4.3.3.1 DDL(行 5879-5886)

```
CREATE TABLE account_project_grants (  
  account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,  
  project_id TEXT NOT NULL REFERENCES projects(id) ON DELETE CASCADE,  
  granted_at TEXT NOT NULL,  
  granted_by TEXT NOT NULL REFERENCES accounts(id),  
  PRIMARY KEY (account_id, project_id)  
);  
CREATE INDEX idx_account_project_grants_project ON account_project_grants(project_id);
```

4.3.4 3.4 sessions(セッション)

4.3.4.1 DDL(行 5894-5905)

```
CREATE TABLE sessions (  
  id TEXT PRIMARY KEY,  
  account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,  
  ip_address TEXT NOT NULL,  
  user_agent TEXT,  
  created_at TEXT NOT NULL,  
  last_accessed_at TEXT NOT NULL,  
  expires_at TEXT NOT NULL,  
  revoked_at TEXT  
);  
CREATE INDEX idx_sessions_account ON sessions(account_id) WHERE revoked_at IS NULL;  
CREATE INDEX idx_sessions_expires ON sessions(expires_at) WHERE revoked_at IS NULL;
```

4.3.5 3.5 access_tokens(アクセストークン)

4.3.5.1 DDL(行 5908-5920)

```
CREATE TABLE access_tokens (  
  id TEXT PRIMARY KEY,  
  account_id TEXT REFERENCES accounts(id) ON DELETE CASCADE,  
  token_hash TEXT NOT NULL,  
  purpose TEXT NOT NULL CHECK (purpose IN ('email_verify', 'password_reset', 'activation', 'reentry')),  
  meta TEXT,  
  created_at TEXT NOT NULL,  
  expires_at TEXT NOT NULL,  
  used_at TEXT  
);  
CREATE UNIQUE INDEX uq_access_tokens_hash ON access_tokens(token_hash);  
CREATE INDEX idx_access_tokens_expires ON access_tokens(expires_at) WHERE used_at IS NULL;
```

4.3.5.2 コード値: **purpose**

値	用途
email_verify	メール確認
password_reset	パスワード再設定
activation	招待受諾(初回パスワード設定)
reentry	エンドユーザー再入室

4.3.6 3.6 projects(プロジェクト)

4.3.6.1 DDL(行 5923-5944)

```

CREATE TABLE projects (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
  name TEXT NOT NULL CHECK (length(name) BETWEEN 1 AND 100),
  description TEXT,
  status TEXT NOT NULL DEFAULT 'active' CHECK (status IN ('active','de
widget_public_key TEXT NOT NULL UNIQUE,
widget_public_key_expires_at TEXT NOT NULL,
contact_email TEXT,
contact_email_verified_at TEXT,
settings TEXT NOT NULL DEFAULT '{}',
created_at TEXT NOT NULL,
updated_at TEXT NOT NULL,
deleted_at TEXT,
  CHECK (contact_email_verified_at IS NULL OR contact_email IS NOT NULL)
);
CREATE INDEX idx_projects_owner_status ON projects(owner_account_id, status);
CREATE INDEX idx_projects_widget_key ON projects(widget_public_key);

```

4.3.7 3.7 project_legacy_keys(レガシー API キー)

4.3.7.1 DDL(行 5947-5954)

```

CREATE TABLE project_legacy_keys (
  id TEXT PRIMARY KEY,
  project_id TEXT NOT NULL REFERENCES projects(id) ON DELETE CASCADE,
  public_key TEXT NOT NULL,
  grace_until TEXT NOT NULL,
  created_at TEXT NOT NULL DEFAULT (datetime('now'))
);
CREATE INDEX idx_legacy_keys_key ON project_legacy_keys(public_key);

```

4.3.8 3.8 allowed_domains(許可ドメイン)

4.3.8.1 DDL(行 5957-5963)

```

CREATE TABLE allowed_domains (
  id TEXT PRIMARY KEY,
  project_id TEXT NOT NULL REFERENCES projects(id) ON DELETE CASCADE,
  domain TEXT NOT NULL,
  created_at TEXT NOT NULL
);
CREATE UNIQUE INDEX uq_allowed_domains_project_domain ON allowed_domains(project_id, domain);

```

4.3.9 3.9 faqs(FAQ)

4.3.9.1 DDL(行 5966-5987)

```

CREATE TABLE faqs (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
  project_id TEXT NOT NULL REFERENCES projects(id) ON DELETE CASCADE,
  title TEXT NOT NULL CHECK (length(title) BETWEEN 1 AND 200),
  body TEXT NOT NULL CHECK (length(body) BETWEEN 1 AND 10000),
  category TEXT,
  status TEXT NOT NULL DEFAULT 'draft'
  CHECK (status IN ('draft','published','hidden','deleted')),
  version INTEGER NOT NULL DEFAULT 1,
  tags TEXT,
  source_unresolved_question_id TEXT REFERENCES inquiries(id),
  created_by TEXT NOT NULL REFERENCES accounts(id),
  updated_by TEXT NOT NULL REFERENCES accounts(id),
  created_at TEXT NOT NULL,

```

```

    updated_at          TEXT NOT NULL,
    deleted_at          TEXT
);
CREATE INDEX idx_faqs_owner_project ON faqs(owner_account_id, project_id);
CREATE INDEX idx_faqs_project_status ON faqs(project_id, status);
CREATE INDEX idx_faqs_source_inquiry ON faqs(source_unresolved_question_id);
CREATE INDEX idx_faqs_category ON faqs(project_id, category) WHERE category IS NOT NULL

```

4.3.9.2 コード値: **status**(状態遷移は §8 参照)

値	説明
draft	下書き (AI 下書き含む)
published	公開中
hidden	非公開
deleted	論理削除 (復元は 運営者のみ = IF #4)

4.3.10 3.10 **faq_revisions**(FAQ 改訂履歴)

4.3.10.1 DDL(行 5992-6008)

```

CREATE TABLE faq_revisions (
  id          TEXT PRIMARY KEY,
  faq_id      TEXT NOT NULL REFERENCES faqs(id) ON DELETE CASCADE,
  version     INTEGER NOT NULL,
  title       TEXT NOT NULL,
  body        TEXT NOT NULL,
  category    TEXT,
  tags        TEXT,
  status_snapshot TEXT NOT NULL CHECK (status_snapshot IN ('draft', 'published', 'hidden', 'deleted')),
  source      TEXT NOT NULL DEFAULT 'manual' CHECK (source IN ('manual', 'ai_draft', 'import')),
  created_at  TEXT NOT NULL,
  created_by  TEXT NOT NULL REFERENCES accounts(id)
);
CREATE INDEX idx_faq_revisions_faq ON faq_revisions(faq_id, version DESC);
CREATE INDEX idx_faq_revisions_source ON faq_revisions(source);

```

4.3.11 3.11 **faq_search_fts**(FAQ 全文検索、FTS5 仮想テーブル)

4.3.11.1 DDL(行 6011-6017)

```

CREATE VIRTUAL TABLE faq_search_fts USING fts5(
  title, body, category, tags,
  content='faqs',
  content_rowid='rowid',
  tokenize='trigram'
);

```

faqs テーブルへの INSERT / UPDATE / DELETE トリガで自動同期。詳細は詳細設計 § 9.9 参照。

4.3.12 3.12 **question_logs**(質問ログ)

4.3.12.1 DDL(行 6020-6042)

```

CREATE TABLE question_logs (
  id          TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL REFERENCES accounts(id),
  project_id  TEXT NOT NULL REFERENCES projects(id),
  user_question TEXT NOT NULL CHECK (length(user_question) BETWEEN 1 AND 2000),
  ai_response  TEXT,
  is_resolved  INTEGER NOT NULL DEFAULT 0,
  metering_billable INTEGER NOT NULL DEFAULT 0,
  confidence_score REAL,

```



```

relevance_score      REAL,
ai_model              TEXT,
ai_token_count_input  INTEGER,
ai_token_count_output INTEGER,
result_type           TEXT CHECK (result_type IN ('answered', 'unanswered', 'error')),
result_reason_code    TEXT,
pii_masked            INTEGER NOT NULL DEFAULT 0,
session_id            TEXT,
ip_address            TEXT,
created_at            TEXT NOT NULL
);
CREATE INDEX idx_qlog_owner_created ON question_logs(owner_account_id, created_at DESC);
CREATE INDEX idx_qlog_project_billable_created ON question_logs(project_id, metering_billable,

```

4.3.13 3.13 inquiries(案件)

4.3.13.1 DDL(行 6053-6074)—— 詳細設計の case_status CHECK 制約欠落を補正

```

CREATE TABLE inquiries (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
  project_id TEXT NOT NULL REFERENCES projects(id) ON DELETE CASCADE,
  inquiry_code TEXT NOT NULL,
  question_log_id TEXT REFERENCES question_logs(id),
  user_question TEXT NOT NULL,
  case_status TEXT NOT NULL DEFAULT 'open'
  CHECK (case_status IN ('open', 'resolved', 'closed', 'faq_registered')),
  faq_candidate_status TEXT NOT NULL DEFAULT 'none'
  CHECK (faq_candidate_status IN ('none', 'candidate', 'drafted', 'registered')),
  faq_draft TEXT,
  assignee_account_id TEXT REFERENCES accounts(id) ON DELETE SET NULL,
  created_at TEXT NOT NULL,
  updated_at TEXT NOT NULL,
  closed_at TEXT,
  deleted_at TEXT
);
CREATE INDEX idx_inquiries_contract_status_created ON inquiries(owner_account_id, case_status, created_at);
CREATE INDEX idx_inquiries_project_status ON inquiries(project_id, case_status);
CREATE INDEX idx_inquiries_assignee ON inquiries(assignee_account_id) WHERE case_status IN ('open', 'resolved');
CREATE UNIQUE INDEX uq_inquiries_code ON inquiries(inquiry_code);

```

4.3.13.2 コード値: case_status(共有概念正本 = FR-079 自動 closed 遷移禁止)

値	説明	遷移条件
open	未対応	新規作成時
resolved	解決済み	admin の「解決済み」操作のみ
closed	対応不要終了	admin の明示操作のみ。自動 retention で closed に遷移させない (FR-079)
faq-registered	FAQ 化済み	admin の「FAQ 登録完了」操作

詳細遷移は § 8.2 参照。

4.3.14 3.14 inquiry_status_history(案件状態履歴)

4.3.14.1 DDL(行 6076-6086)

```

CREATE TABLE inquiry_status_history (
  id TEXT PRIMARY KEY,
  inquiry_id TEXT NOT NULL REFERENCES inquiries(id) ON DELETE CASCADE,
  from_status TEXT NOT NULL,
  to_status TEXT NOT NULL,
  reason TEXT,

```

```

    changed_by TEXT REFERENCES accounts(id),
    changed_at TEXT NOT NULL
);
CREATE INDEX idx_isth_inquiry_changed ON inquiry_status_history(inquiry_id, changed_at DESC);

```

4.3.15 3.15 inquiry_contacts(エンドユーザー連絡先、PII 暗号化)

4.3.15.1 DDL(行 6089-6100)

```

CREATE TABLE inquiry_contacts (
    id TEXT PRIMARY KEY,
    inquiry_id TEXT NOT NULL REFERENCES inquiries(id) ON DELETE CASCADE,
    email_encrypted TEXT,
    email_hmac TEXT,
    display_name TEXT,
    verified INTEGER NOT NULL DEFAULT 0,
    notify_enabled INTEGER NOT NULL DEFAULT 1,
    created_at TEXT NOT NULL DEFAULT (datetime('now'))
);
CREATE INDEX idx_inquiry_contacts_email_hmac ON inquiry_contacts(email_hmac);
CREATE UNIQUE INDEX uq_inquiry_contacts_inquiry ON inquiry_contacts(inquiry_id);

```

email_encrypted は AES-256-GCM(オーナー派生) で暗号化。email_hmac は HMAC-SHA256 で検索用。
 詳細は [10_セキュリティ設計書.md §3](#) 参照。

4.3.16 3.16 chat_rooms(個別チャット部屋)

4.3.16.1 DDL(行 6103-6121)

```

CREATE TABLE chat_rooms (
    id TEXT PRIMARY KEY,
    inquiry_id TEXT NOT NULL REFERENCES inquiries(id) ON DELETE CASCADE,
    room_status TEXT NOT NULL DEFAULT 'open' CHECK (room_status IN ('open', 'closed')),
    reminder_state TEXT NOT NULL DEFAULT 'active'
    CHECK (reminder_state IN ('active', 'stage1_pending_admin', 'stage2_u
    'stage3_user_no_response', 'stage4_final
    'stage5_final_no_response', 'stage6_auto_

    last_message_at TEXT,
    last_message_actor_type TEXT,
    reminder_state_changed_at TEXT,
    created_at TEXT NOT NULL,
    closed_at TEXT
);
CREATE INDEX idx_chat_rooms_inquiry ON chat_rooms(inquiry_id);
CREATE INDEX idx_chat_rooms_open_reminder ON chat_rooms(reminder_state, last_message_at) WHERE

```

4.3.16.2 コード値: reminder_state(自動クローズ 6 段階) 詳細は §8.3 参照。

4.3.17 3.17 chat_messages(チャットメッセージ)

4.3.17.1 DDL(行 6124-6132)

```

CREATE TABLE chat_messages (
    id TEXT PRIMARY KEY,
    chat_room_id TEXT NOT NULL REFERENCES chat_rooms(id) ON DELETE CASCADE,
    actor_type TEXT NOT NULL CHECK (actor_type IN ('admin', 'end_user', 'system')),
    actor_id TEXT REFERENCES accounts(id) ON DELETE SET NULL,
    content TEXT NOT NULL CHECK (length(content) BETWEEN 1 AND 2000),
    created_at TEXT NOT NULL
);
CREATE INDEX idx_chat_messages_room_created ON chat_messages(chat_room_id, created_at);

```

4.3.18 3.18 notification_logs(通知ログ)

4.3.18.1 DDL(行 6241-6260)

```
CREATE TABLE notification_logs (  
  id TEXT PRIMARY KEY,  
  owner_account_id TEXT NOT NULL,  
  inquiry_id TEXT,  
  chat_message_id TEXT,  
  recipient_email_hmac TEXT,  
  notification_type TEXT NOT NULL,  
  delivery_state TEXT NOT NULL  
    CHECK (delivery_state IN ('queued','sending','sent','delivered',  
                              'failed','bounced','complained','suppressed'  
  ),  
  message_id TEXT,  
  attempt_count INTEGER NOT NULL DEFAULT 0,  
  sent_at TEXT,  
  delivered_at TEXT,  
  failed_at TEXT,  
  fail_reason TEXT,  
  created_at TEXT NOT NULL  
);  
CREATE INDEX idx_nlog_owner_created ON notification_logs(owner_account_id, created_at DESC);  
CREATE INDEX idx_nlog_message_id ON notification_logs(message_id);  
CREATE INDEX idx_nlog_state ON notification_logs(delivery_state);
```

4.3.18.2 コード値: delivery_state(状態遷移は §8.4 参照)

値	説明
queued	Queue 投入済み
sending	送信中
sent	送信成功
delivered	配信成功 (Resend Webhook 経由)
failed	失敗 (当方再送対象、最大 3 回)
bounced	バウンス (ハードまたはソフト 5 連続)
complained	スパム報告
suppressed	サプレスリスト追加済み (終了状態)

4.3.19 3.19 ai_threshold_persistent_cache(AI しきい値キャッシュ)

4.3.19.1 DDL(行 6323-6335)

```
CREATE TABLE ai_threshold_persistent_cache (  
  id TEXT PRIMARY KEY,  
  owner_account_id TEXT,  
  project_id TEXT,  
  scope TEXT NOT NULL CHECK (scope IN ('global','owner','project')),  
  confidence_threshold REAL NOT NULL,  
  relevance_threshold REAL NOT NULL,  
  version INTEGER NOT NULL,  
  received_at TEXT NOT NULL,  
  updated_at TEXT NOT NULL  
);  
CREATE UNIQUE INDEX uq_ai_threshold_scope ON ai_threshold_persistent_cache(scope, COALESCE(owne  
3 階層しきい値: global / owner / project。詳細は 03_API 設計書.md §5.5.5(IF #6) 参照。
```

4.3.20 3.20 email_suppression_list(メールサプレスリスト、全契約横断)

4.3.20.1 DDL(行 6289-6298)

```
CREATE TABLE email_suppression_list (
  id TEXT PRIMARY KEY,
  email_hmac TEXT NOT NULL UNIQUE,
  reason TEXT NOT NULL CHECK (reason IN ('bounced_hard', 'bounced_soft_5x', 'complained', '
  is_permanent INTEGER NOT NULL DEFAULT 1,
  created_at TEXT NOT NULL,
  released_at TEXT
);
```

```
CREATE INDEX idx_suppression_permanent ON email_suppression_list(is_permanent, email_hmac);
```

全契約横断テーブル (R-003 共通ドメインレピュテーション保護対策)。10_セキュリティ設計書.md §11 参照。

4.3.21 3.21 audit_logs(監査ログ、メイン側)

4.3.21.1 DDL(行 6266-6287)

```
CREATE TABLE audit_logs (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT,
  actor_account_id TEXT,
  actor_role TEXT,
  action TEXT NOT NULL,
  target_type TEXT,
  target_id TEXT,
  ip_address_masked TEXT,
  user_agent TEXT,
  metadata TEXT,
  retention_class TEXT NOT NULL DEFAULT 'general'
  CHECK (retention_class IN ('general', 'billing', 'operator_high_priv')),
  prev_hash TEXT,
  current_hash TEXT NOT NULL,
  tombstone INTEGER NOT NULL DEFAULT 0,
  created_at TEXT NOT NULL
);
CREATE INDEX idx_audit_owner_action_created ON audit_logs(owner_account_id, action, created_at)
CREATE INDEX idx_audit_retention_created ON audit_logs(retention_class, created_at);
```

- ・ハッシュチェーン構造の正本(運営者側 §7)。prev_hash / current_hash で連結
- ・3区分保持(general 1y / billing 7y / operator_high_priv 5y)
- ・保持期間経過後は tombstone 方式(本文を物理削除し、log_id / prev_hash / current_hash / deleted_at を保持してチェーン破断を防ぐ)

4.3.22 3.22 error_logs(エラーログ)

4.3.22.1 DDL(行 9052-6061、詳細設計内記載)

```
CREATE TABLE error_logs (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT,
  account_id TEXT,
  url TEXT,
  error_type TEXT,
  stack TEXT,
  occurred_at TEXT NOT NULL
);
CREATE INDEX idx_error_logs_owner_occurred ON error_logs(owner_account_id, occurred_at DESC);
```

PII / トークン / カード情報を記録禁止 (FR-114、エンドユーザー入力のは先頭 100 文字 + ハッシュのみ)。

4.3.23 3.23 billing_subscriptions(課金サブスクリプション)

4.3.23.1 DDL(行 6138-6154)

```
CREATE TABLE billing_subscriptions (
  id TEXT PRIMARY KEY,
```

```

owner_account_id    TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
stripe_subscription_id TEXT UNIQUE,
status              TEXT NOT NULL
                    CHECK (status IN ('trialing','active','past_due','canceled','unpaid',
plan_id             TEXT NOT NULL,
trial_started_at    TEXT,
trial_ends_at       TEXT,
current_period_start TEXT,
current_period_end  TEXT,
cancel_at           TEXT,
created_at          TEXT NOT NULL,
updated_at          TEXT NOT NULL
);
CREATE INDEX idx_billing_subs_owner ON billing_subscriptions(owner_account_id);
CREATE INDEX idx_billing_subs_status ON billing_subscriptions(status);

```

4.3.24 3.24 billing_invoices(請求書、7 年保持)

4.3.24.1 DDL(行 6156-6174)

```

CREATE TABLE billing_invoices (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL REFERENCES accounts(id),
  billing_year_month TEXT NOT NULL,
  status TEXT NOT NULL CHECK (status IN ('draft','issued','paid','past_due','refun
amount_total INTEGER NOT NULL,
amount_tax INTEGER NOT NULL DEFAULT 0,
currency TEXT NOT NULL DEFAULT 'JPY',
stripe_invoice_id TEXT UNIQUE,
pdf_r2_key TEXT,
issued_at TEXT,
paid_at TEXT,
refunded_at TEXT,
created_at TEXT NOT NULL
);
CREATE UNIQUE INDEX uq_billing_invoices_owner_month ON billing_invoices(owner_account_id, billi
CREATE INDEX idx_billing_invoices_status ON billing_invoices(status);

```

4.3.25 3.25 usage_metering(利用量計測)

4.3.25.1 DDL(行 6176-6190)

```

CREATE TABLE usage_metering (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
  billing_year_month TEXT NOT NULL,
  question_count INTEGER NOT NULL DEFAULT 0,
  faq_count_snapshot INTEGER NOT NULL DEFAULT 0,
  chat_room_count INTEGER NOT NULL DEFAULT 0,
  ai_token_input INTEGER NOT NULL DEFAULT 0,
  ai_token_output INTEGER NOT NULL DEFAULT 0,
  ai_cost_yen INTEGER NOT NULL DEFAULT 0,
  finalized_at TEXT,
  updated_at TEXT NOT NULL
);
CREATE UNIQUE INDEX uq_usage_metering_owner_month ON usage_metering(owner_account_id, billing_y

```

4.3.26 3.26 owner_quota_overrides(契約別レート / 予算上書き、統一実装)

重要: rate_limit_overrides / budget_limit_overrides は別テーブルではなく、本テーブル + re-source_kind 値で統一実装される。

4.3.26.1 DDL(行 6337-6350)

```
CREATE TABLE owner_quota_overrides (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
  resource_kind TEXT NOT NULL
                      CHECK (resource_kind IN ('widget_ask_per_min','widget_inquiry_per_min','widget_
                      'email_per_hour','admin_api_per_min')),
  threshold INTEGER NOT NULL,
  window_sec INTEGER NOT NULL,
  valid_until TEXT NOT NULL,
  reason TEXT,
  created_by TEXT,
  created_at TEXT NOT NULL
);
CREATE INDEX idx_tqo_owner_kind ON owner_quota_overrides(owner_account_id, resource_kind, valid_
```

4.3.26.2 コード値: resource_kind

値	用途
widget_ask_per_min	ウィジェット質問レート
widget_inquiry_per_min	ウィジェット未解決質問送信レート
widget_chat_per_min	ウィジェットチャット投稿レート
email_per_hour	メール送信レート
admin_api_per_min	管理API レート

詳細は [11_課金請求設計書.md § 3](#) / [05_権限設計書.md § 7](#) 参照。

4.3.27 3.27 service_announcements(お知らせ Control Plane)

4.3.27.1 DDL(行 6196-6208)

```
CREATE TABLE service_announcements (
  id TEXT PRIMARY KEY,
  title TEXT NOT NULL CHECK (length(title) BETWEEN 1 AND 200),
  body_html TEXT NOT NULL,
  importance TEXT NOT NULL CHECK (importance IN ('low','normal','high','critical')),
  audience_owner_account_ids TEXT,
  published_at TEXT NOT NULL,
  retracted_at TEXT,
  created_by TEXT NOT NULL,
  created_at TEXT NOT NULL
);
CREATE INDEX idx_announcements_published ON service_announcements(published_at DESC) WHERE retr
importance 4 値は共有概念正本(critical はメール強制送信)。07_メッセージ一覧.md § 2.4 参照。
```

4.3.28 3.28 announcement_recipients(お知らせ配信先 Control Plane)

4.3.28.1 DDL(行 6210-6220)

```
CREATE TABLE announcement_recipients (
  id TEXT PRIMARY KEY,
  announcement_id TEXT NOT NULL REFERENCES service_announcements(id) ON DELETE CASCADE,
  owner_account_id TEXT NOT NULL,
  account_id TEXT NOT NULL,
  sent_at TEXT NOT NULL,
  delivery_status TEXT NOT NULL CHECK (delivery_status IN ('pending','delivered','failed')),
  read_at TEXT
);
CREATE INDEX idx_ar_announcement ON announcement_recipients(announcement_id);
CREATE INDEX idx_ar_owner_account ON announcement_recipients(owner_account_id, account_id);
```

4.3.29 3.29 inbox_messages(受信箱 Tenant Plane)

4.3.29.1 DDL(行 6222-6239)

```
CREATE TABLE inbox_messages (  
  id TEXT PRIMARY KEY,  
  owner_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,  
  recipient_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,  
  category TEXT NOT NULL CHECK (category IN ('billing','announcement','system')),  
  priority TEXT NOT NULL CHECK (priority IN ('low','normal','high','critical')),  
  title TEXT NOT NULL CHECK (length(title) BETWEEN 1 AND 200),  
  body_html TEXT NOT NULL,  
  source_kind TEXT,  
  source_id TEXT,  
  dedup_key TEXT NOT NULL,  
  read_at TEXT,  
  hidden_at TEXT,  
  created_at TEXT NOT NULL  
);  
CREATE INDEX idx_inbox_owner_account_unread ON inbox_messages(owner_account_id, recipient_account_id, created_at)  
CREATE INDEX idx_inbox_dedup ON inbox_messages(owner_account_id, dedup_key, created_at)
```

4.3.29.2 お知らせ二層構成

- Control Plane(service_announcements / announcement_recipients): 運営者作成お知らせ本体 + 配信集計・監査
- Tenant Plane(inbox_messages): 利用者管理者の受信箱(既読管理)
- announcement カテゴリは Control → Tenant の二層経由。billing / system は inbox_messages 直接生成
- 重複生成対策: (owner_account_id, event_kind, dedup_key) で 60 分以内は 1 件に集約

4.3.30 3.30 withdrawal_requests(退会申請)

4.3.30.1 DDL(行 6352-6361)

```
CREATE TABLE withdrawal_requests (  
  id TEXT PRIMARY KEY,  
  owner_account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,  
  applied_at TEXT NOT NULL,  
  applied_by TEXT NOT NULL REFERENCES accounts(id),  
  reason TEXT,  
  scheduled_deletion_at TEXT NOT NULL  
);  
CREATE INDEX idx_withdrawal_owner_scheduled ON withdrawal_requests(owner_account_id, scheduled_deletion_at)
```

4.3.31 3.31 terms_versions(規約版数、全契約横断)

4.3.31.1 DDL(行 6300-6308)

```
CREATE TABLE terms_versions (  
  version TEXT PRIMARY KEY,  
  effective_date TEXT NOT NULL,  
  body_html TEXT NOT NULL,  
  diff_summary TEXT,  
  notification_sent_at TEXT,  
  consent_deadline_days INTEGER NOT NULL DEFAULT 14,  
  created_at TEXT NOT NULL  
);
```

4.3.32 3.32 terms_agreements(規約同意)

4.3.32.1 DDL(行 6310-6317)

```

CREATE TABLE terms_agreements (
  id TEXT PRIMARY KEY,
  account_id TEXT NOT NULL REFERENCES accounts(id) ON DELETE CASCADE,
  terms_version TEXT NOT NULL REFERENCES terms_versions(version),
  agreed_at TEXT NOT NULL,
  agreed_ip_masked TEXT
);
CREATE UNIQUE INDEX uq_terms_account_version ON terms_agreements(account_id, terms_version);

```

4.4 4. ER 図 (主要部分、§7.2 から移管)

```

erDiagram
  accounts ||--o{ accounts : "owner_account_id (self-ref)"
  accounts ||--o{ projects : owns
  accounts ||--o{ billing_subscriptions : has
  accounts ||--o{ inbox_messages : "1-N(オーナー配下)"
  accounts ||--o{ audit_logs : "1-N"
  accounts ||--o{ account_permissions : "0..5(メンバーのみ)"
  accounts ||--o{ account_project_grants : "0..N(メンバーのみ)"
  accounts ||--o{ sessions : has
  accounts ||--o{ access_tokens : has
  accounts ||--o{ terms_agreements : has
  projects ||--o{ faqs : contains
  projects ||--o{ question_logs : records
  projects ||--o{ inquiries : holds
  projects ||--o{ allowed_domains : authorizes
  projects ||--o{ project_legacy_keys : rotates
  faqs ||--o{ faq_revisions : versioned
  faqs }o--o{ inquiries : "source_unresolved_question_id(opt)"
  inquiries ||--|| chat_rooms : has
  inquiries ||--o{ inquiry_contacts : has
  inquiries ||--o{ inquiry_status_history : tracks
  chat_rooms ||--o{ chat_messages : contains
  service_announcements ||--o{ announcement_recipients : "fan-out"
  announcement_recipients ||--o{ inbox_messages : "copied to"
  billing_subscriptions ||--o{ billing_invoices : generates
  accounts ||--o{ usage_metering : metered
  accounts ||--o{ owner_quota_overrides : overridden
  terms_versions ||--o{ terms_agreements : agreed

```

4.5 5. テーブル間関連 (§2.2 と同期)

§2.2「主要関係性」を参照。

4.6 6. 命名規則・型方針 (§7.5 から移管)

対象	規則
テーブル	snake_case 複数形
主キー	文字列 ID(ULID)/ *_versions 等の例外あり
外部キー	{table_singular}_id
日時	TEXT(ISO 8601 UTC、NFR-1103)
状態	status または {対象}_status
真偽値	INTEGER 0/1
JSON	TEXT 列に JSON 文字列で保存
暗号化	{column}_encrypted(AES-256-GCM) + {column}_hmac(検索用) の 2 列構成

4.7 7. SaaS データ分離観点

4.7.1 7.1 オーナー境界によるデータ分離方式 (§2.6 + §7.1 から移管)

- ・全契約スコープのテーブルに `owner_account_id` カラム必須 (全契約横断テーブルを除く — §7.3 参照)
- ・API/ 認可レイヤで境界検証: `actor.owner_account_id == target.owner_account_id` (認証・認可設計書 09 §5)
- ・違反時は **404 偽装** (403 だと相手契約のリソース存在が漏れる)
- ・150 契約到達時に D1 シャーディング設計を着手予定 (Future 参照)

4.7.2 7.2 オーナー行とメンバー行の判定

- ・オーナー行: `accounts.is_owner=1` かつ `owner_account_id = id` (自己参照)
- ・メンバー行: `accounts.is_owner=0` かつ `owner_account_id <> id`
- ・`accounts` テーブルの CHECK 制約で強制: `((is_owner = 1 AND owner_account_id = id) OR (is_owner = 0 AND owner_account_id <> id))`

4.7.3 7.3 全契約横断テーブル (`owner_account_id` を持たない)

テーブル名	理由
email_suppression_list	メール bounce / 苦情の全契約横断管理 (R-003 共通ドメイン対策)
terms_versions	規約 / プライバシーポリシーの版 (全利用者共通)
service_announcements	運営者発信のお知らせ本体 (配信先は <code>announcement_recipients</code> で契約別)

4.8 8. 状態コード値・状態遷移 (§4.x から移管)

4.8.1 8.1 FAQ 状態遷移 (`faqs.status`)

From	To	トリガー	条件
-	draft	FAQ 作成	admin のみ
draft	published	公開操作	admin のみ、interactive セッション、内容確認ガード (基本設計書 §4.2.1)
draft	hidden	非公開保存	admin のみ
published	hidden	非公開化	admin のみ
hidden	published	再公開	admin のみ
any	deleted	論理削除	admin のみ
deleted	draft	復元	運営者のみ (IF #4)

ガード: AI / Batch による `draft` → `published` 直接遷移を 3 層で禁止 (API / Domain / DB)。AI 下書き (`draft`) 生成は許容。

4.8.2 8.2 案件状態遷移 (`inquiries.case_status`、共有概念正本)

From	To	トリガー	条件	通知
-	open	未解決質問登録	システム自動	エンドユーザーへ IN-QUIRY_CREATED
open	resolved	admin 「解決済み」	admin のみ	なし
open	closed	admin 「対応不要終了」	admin の明示操作のみ。自動 retention で closed に遷移させない (FR-079)	エンドユーザーへ in-box(announcement)
any	faq_registered	admin 「FAQ 登録完了」	admin のみ	エンドユーザーへ FAQ_REGISTERED

4.8.3 8.3 チャット部屋自動クローズ 6 段階 (`chat_rooms.reminder_state`)

From	To	トリガー	経過時間	通知
active	stage1_pending	最終投稿から	7 日	admin へ CHAT_HOLD_CHECK
stage1_pending	stage2_user_checked	admin「利用者待ち」判定 or 14 日未操作	即時 / 14 日	エンドユーザーへ CHAT_RESOLUTION_CHECK
stage2_user_checked	stage3_user_not_checked	投稿なし	7 日	なし (Cron 同期)
stage3_user_not_checked	stage4_final_checked	即時遷移	(同周期)	エンドユーザーへ CHAT_FINAL_CONFIRM
stage4_final_checked	stage5_final_not_checked	投稿なし	7 日	なし
stage5_final_not_checked	stage6_auto_closed	即時遷移	(3 日後)	エンドユーザーへ CHAT_AUTO_CLOSED、room_status=closed
stage6_auto_closed	active (再オープン)	エンドユーザー再アクセス	30 日以内	なし
stage6_auto_closed	access_tokens (消滅)	30 日経過	-	エンドユーザーへ「新規部屋案内」
任意の active 系	active	EU / admin 投稿	-	カウンタリセット
active 系	手動 close	admin 明示操作	-	エンドユーザーへ CHAT_CLOSED
closed	active	admin 再オープン	30 日以内	監査ログ記録必須

4.8.4 8.4 通知状態遷移 (notification_logs.delivery_state)

From	To	トリガー
-	queued	Queue 投入
queued	sending	Worker 起動
sending	sent	Resend API 成功
sending	failed	Resend API 失敗 (恒久)—— 当方再送対象 (最大 3 回、NFR-506)
sent	delivered	email.delivered Webhook(終了状態)
sent	bounced	email.bounced Webhook(ハード / ソフト 5 連続)
sent	complained	email.complained Webhook
sent	delayed	email.delivery_delayed Webhook(Resend 再送中)
delayed	delivered / bounced	後続結果
bounced	suppressed	サブプレスリスト追加
complained	suppressed	即時永久サブプレス (復帰不可)
failed	queued	当方再送 (最大 3 回、3 回失敗 + 24 時間経過で admin へ system 通知)

4.8.5 8.5 契約状態遷移 (accounts.contract_status、共有概念正本)

詳細は 11_課金請求設計書.md §4 / §5 を正本とする。本書では概要のみ:

From	To	トリガー	reason
-	active	契約作成	-
active	suspended	IF #1(支払い失敗 7 日猶予経過)	payment_failure_grace_expired
active	suspended	IF #1(運営者手動)	operator_manual / tos_violation
active	suspended	Cron(トライアル終了 + 支払方法未登録)	trial_expired_no_payment_method
suspended	active	IF #1(支払再開 / 解除)	-
active / suspended	deleted_pending	admin 退会申請 (SCR-024)	-
deleted_pending	active / suspended (元の状態)	admin 撤回 (30 日以内)	-
deleted_pending	deleted	30 日経過 + 物理削除 Batch	-

4.9 9. データ削除モード (§7.8 から移管)

設定: `accounts.notification_preferences` に `data_deletion_mode`(`physical` / `anonymize`、初期値 `physical`) を保持 (将来カラム化検討)。

対象テーブル	物理削除	匿名化
question_logs	DELETE	user_question 空字, ip_address / user_agent NULL, 集計値維持
inquiries	DELETE	user_question 空字, inquiry_code 維持, closed_reason 空字
chat_messages	DELETE	content 空字, actor_type 維持
inquiry_contacts	DELETE	email_encrypted → anon_<sha256>, display_name → 「匿名」
notification_logs	DELETE	recipient_email_hmac → SHA-256, vars → 空 JSON
access_tokens	DELETE	(常に物理削除、匿名化対象外)
audit_logs	削除しない	(tombstone 方式、匿名化対象外)

4.10 10. データ保持の調整制約 (§11.4.1 から移管)

- ・短縮は可
- ・長期化は SCR-093 経由 (運営者承認必須)—— 認証・認可設計書 09 §6 / 運営者 権限設計書 05 §7 参照

4.11 11. PII 取扱 (§7.10 から移管)

観点	仕様
暗号化方式	AES-256-GCM 列単位、オーナー派生 (NFR-319)
対象テーブル	inquiry_contacts.email_encrypted、accounts.email_encrypted
検索方式	暗号化 + *_hmac カラム (HMAC-SHA256) で復号不要
ローテーション	年次 Master Key ローテーション時に KDF 再実行。60 日 dual-decrypt 期間 (NFR-321)
カード情報	Stripe に委譲 (PCI-DSS 範囲外)

詳細は [10_セキュリティ設計書.md §3 / §8](#) を正本とする。

4.12 12. インデックス方針 (§7.6 から移管)

観点	方針
FAQ 検索 (FTS5)	faq_search_fts 仮想テーブル、(project_id, status='published') 前段フィルタ
未解決質問一覧	(owner_account_id, project_id, case_status, created_at DESC)
お知らせ一覧 (NFR-106)	(recipient_account_id, read_at) / (recipient_account_id, category, created_at DESC)
未読件数 (NFR-106)	KV キャッシュ inbox:unread:<account_id>(TTL 60 秒) + DB フォールバック
ユニーク	inquiry_code, widget_public_key, access_tokens.token_hash, (owner_account_id, billing_year_month)
監査ログ	(owner_account_id, action, created_at) (WHERE tombstone=0), (retention_class, created_at) (保持期間バッチ用)

4.13 13. 未決事項

No	内容	確認先	期限	ステータス
1	詳細設計書の inquiries.case_status に CHECK 制約欠落 (本書では補正済)	詳細設計書 行 6060	-	補正待ち
2	rate_limit_overrides / budget_limit_overrides を別テーブルに分離するか (現状 owner_quota_overrides.resource_kind で統一)	-	-	既決: 統一実装で継続
3	data_deletion_mode を accounts の独立カラムにするか (現状 notification_preferences JSON 内)	詳細設計書 §7.8	Future	確認中

4.14 14. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

5 権限設計書 (メイン)

5.1 1. 文書概要

5.1.1 1.1 目的

メインシステムの権限モデル(オーナー/メンバー/エンドユーザー)、メンバー権限フラグ5種、画面別・機能別・API別の操作可否、**契約別利用上書き**を一元化する。

5.1.2 1.2 対象範囲

- 対象: 利用者ロール(admin/service_operator/end_user)、メンバー権限フラグ5種(faq:manage/chat:respond/users:manage/project:manage/logs:view)、オーナー専有機能、契約別利用上書き
- 対象外: 運営者ロール(02_運営者システム/個別設計書群/05_権限設計書.md 参照)、認証フロー(09_認証認可設計書.md 参照)

5.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

5.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11ドキュメント体系の俯瞰	00_索引.md
認証・認可設計書	認可判定ロジック / Principal	09_認証認可設計書.md
画面設計書	画面別表示制御	02_画面設計書.md
API設計書	API別権限	03_API設計書.md
課金・請求設計書	契約別利用上書き (owner_quota_overrides 等)	11_課金請求設計書.md
エラー設計書	権限不足時のエラー	06_エラー設計書.md
テーブル定義書	account_permissions / account_project_grants	04_テーブル定義書.md

5.2 2. ロール一覧

(§3.1から移管)

ロールID	ロール名	概要	利用者	DB値
OWNER	オーナーアカウント	契約あたり1アカウント固定、全権 + オーナー専有機能	契約代表者	role='admin' AND is_owner=1 AND owner_account_id=id
MEMBER	メンバーアカウント	0..N、権限フラグ + プロジェクト割当てで制御	契約参加者	role='admin' AND is_owner=0 AND owner_account_id=<owner_id>
END_USER	エンドユーザー	ウィジェット利用者(自分の問い合わせIDのみ)	一般訪問者	role='end_user'
SERVICE_OPERATOR	運営者	本 SaaS 提供者 (運営者側)	運営事業者	role='service_operator'

5.3 3. 権限フラグ定義 (account_permissions.permission_kind 5 値)

(§3.2.0 から移管)

5.3.1 3.1 権限フラグ概要

permission_id	表示名 (UI)	できること
faq:manage	FAQ 管理	FAQ の登録・編集・削除・公開、FAQ AI 下書き生成、FAQ インポート
chat:respond	個別チャット対応	未解決質問の閲覧・対応状態更新・担当割当、個別チャット返信、対応不要終了
users:manage	ユーザー管理	メンバーの招待・権限フラグ変更・停止・削除、招待再送・取消 (オーナー対象は除く)
project:manage	プロジェクト設定	プロジェクトの作成・編集・削除、ウィジェット設定、許可ドメイン設定
logs:view	ログ参照	質問ログ閲覧、自契約分の監査ログ閲覧、データエクスポート、未解決質問・個別チャット内容の閲覧

5.3.2 3.2 主管 SCR / FR 対応

permission_id	主な操作対象	オーナーとの関係
faq:manage	SCR-012(FAQ 管理)、FR-040～046, FR-104, FR-310	オーナーは常時保持
chat:respond	SCR-011(未解決質問)、SCR-013(個別チャット)、FR-070～079, FR-086	オーナーは常時保持
users:manage	SCR-017(ユーザー管理)、FR-015～021 系列	オーナーは常時保持し、保持メンバーがいなくても運用継続可
project:manage	SCR-010 / SCR-014、FR-030～036, FR-150	オーナーは常時保持
logs:view	SCR-015、質問ログ・自契約監査ログ、FR-070, NFR-602 系列	オーナーは常時保持

5.3.3 3.3 オーナー専有機能 (メンバーには account_permissions で付与不可)

- ・ 課金 (SCR-015 の月次予算変更 / 支払い方法変更)
- ・ 退会 (SCR-024)
- ・ 規約再同意 (SCR-025 の同意 / 不同意)

UI 上は非表示 + API は 403(E-AUTHZ-OWNER-ONLY)。

5.4 4. 画面別権限マトリクス (§3.2 から移管)

操作分類	オーナー	faq:m	chat:re	users:n	project:	logs:v	end_us	service_operator
ダッシュボード (自分の通知・お知らせ受信箱)	○	○	○	○	○	○	×	×
FAQ 登録・編集・公開	○	○	×	×	×	×	×	△(運営者復元時のみ)
FAQ AI 下書き生成	○	○	×	×	×	×	×	×
プロジェクト管理	○	×	×	×	○	×	×	△(運営者復元時のみ)
メンバー招待・権限フラグ変更・停止・削除	○	×	×	○	×	×	×	×
未解決質問閲覧	○	×	○	×	×	○	×	△(障害調査時のみ)
個別チャット返信	○	×	○	×	×	×	自分のみ	×
個別チャット閲覧	○	×	○	×	×	○	自分のみ	△(障害調査時のみ)
質問ログ閲覧	○	×	×	×	×	○	×	×
監査ログ閲覧 (自契約)	○	×	×	×	×	○	×	○(全契約)
課金情報閲覧・変更	○(専有)	×	×	×	×	×	×	△(訂正・サポート時のみ)

操作分類	オーナー	faq:m	chat:re	users:n	project:l	logs:v	end_us	service_operator
退会申請・解約	○(専有)	×	×	×	×	×	×	×
規約再同意の承諾	○(専有)	×	×	×	×	×	×	×
データエクスポート	○	×	×	×	×	○	×	×
契約無効化(サスペンション)	×	×	×	×	×	×	×	○
契約物理削除	×	×	×	×	×	×	×	○(退会後の自動バッチ)
プロンプトテンプレート編集	×	×	×	×	×	×	×	○(運営者のみ)
案件「終了」確定	○	×	○	×	×	×	×	×
案件「解決済み」	○	×	○	×	×	×	×	×
お知らせ閲覧(自契約)	○	○	○	○	○	○	×	△(運用調査時のみ)
お知らせ既読化	○	○	○	○	○	○	×	×
お知らせ作成・配信	×	×	×	×	×	×	×	○

凡例: ○ = 常時可、△ = 「緊急時のみ可」 (§9 参照)、自分のみ = 自分の問い合わせ ID 範囲内のみ、× = 不可

5.5 5. 機能別権限

主要機能と権限フラグの対応:

機能 ID	機能名	必要権限	オーナー	制限事項
F-AUTH-*	認証	不要	○	-
F-PRJ-*	プロジェクト	project:manage	○	削除は再認証必須
F-FAQ-*	FAQ 管理	faq:manage	○	公開ガード (draft → published 直接遷移禁止)
F-INQ-*	未解決質問	chat:respond	○	closed 遷移は admin の明示操作のみ (FR-079)
F-CHAT-*	個別チャット	chat:respond	○	部屋クローズ / 再オープン は再認証必須
F-WIDGET-*	ウィジェット設定	project:manage	○	API キーローテーションは再認証必須
F-BILL-*	課金	オーナー専有	○	月次予算変更は再認証必須
F-USER-*	ユーザー管理	users:manage	○	招待 / 編集 / 停止 / 削除 / 強制ログアウトは再認証必須
F-ACC-*	アカウント設定 / 退会	オーナー専有	○	退会は再認証必須
F-NOTIF-*	お知らせ	全 admin	○	既読化のみ
F-LEGAL-*	規約 / 同意	オーナー専有 (同意) / 全ユーザー (閲覧)	○	-

5.6 6. API 別権限

03_API 設計書.md を正本とする。主要 API:

API	メソッド	必要権限	オーナー専有	再認証	関連エラー ID
POST /auth/login	POST	不要	-	-	E-AUTH-*
POST /projects	POST	project:manage	-	-	E-AUTHZ-FORBIDDEN
DELETE /projects/{id}	DELETE	project:manage	-	○	-
POST /faqs / PATCH / DELETE	*	faq:manage	-	DELETE のみ○	-
POST /faqs/{id}/publish	POST	faq:manage	-	-	E-BIZ-FAQ-PUBLISH(公開ガード)
POST /inquiries/{id}/close	POST	chat:respond	-	○	-
POST /chat-rooms/{id}/close	POST	chat:respond	-	○	-
GET /usage / GET /billing/invoices	GET	オーナー専有	○	-	E-AUTHZ-OWNER-ONLY
PATCH /billing/monthly-budget-limit	PATCH	オーナー専有	○	○	-
POST /members/invite / PATCH /members/{id}/*	POST/PATCH	Users:manage or オーナー	-	○	E-AUTHZ-OWNER-PROTECTED
POST /withdrawal-requests	POST	オーナー専有	○	○	-
POST /terms/agree	POST	オーナー専有 (承諾)	○	-	-

5.7 7. 契約別利用制限 / 運営者上書き

5.7.1 7.1 単一プランの利用上限 (11_課金請求設計書.md §3 参照)

MVP は単一プラン (完全従量課金 + 月次無料枠 + 14 日トライアル)。プラン階層による差別化はない。利用上限は **owner_quota_overrides.resource_kind** で統一実装される (テーブル定義書 04 § 3.26 参照)。

resource_kind	用途	主管 SCR(運営者)
widget_ask_per_min	ウィジェット質問レート	SCR-093
widget_inquiry_per_min	ウィジェット未解決質問送信レート	SCR-093
widget_chat_per_min	ウィジェットチャット投稿レート	SCR-093
email_per_hour	メール送信レート	SCR-093
admin_api_per_min	管理 API レート	SCR-093

5.7.2 7.2 80/100/125% 三段階アクション (11_課金請求設計書.md §8 の参照)

データ種別	80%	100%	125%
質問数	inbox 通知 (normal)	inbox + email(high)、拒否しない (事後課金)	翌 1 時間レート制限 1/2 + 運営者エスカレーション
FAQ 件数	inbox 通知	新規登録拒否 (編集可)	+ 運営者エスカレーション
個別チャット部屋数	inbox 通知	新規作成拒否 (返信可)	+ 運営者エスカレーション

詳細は 11_課金請求設計書.md §8 を正本とする。

5.8 8. 権限不足・契約上書き時の動作

ケース	システム動作	画面表示	メッセージ ID	関連エラー ID
権限不足 (faq:manage 未保持で SCR-012 編集)	403 統一	「権限がありません」 + オーナーへ連絡誘導	MSG-COMMON-AUTHZ-403	E-AUTHZ-FORBIDDEN
オーナー境界違反 (他契約のリソース参照)	404 偽装 (403 だと相手契約の存在が漏れる)	「リソースが見つかりません」	MSG-COMMON-NOT-FOUND	E-AUTHZ-OWNER-BOUNDARY
プロジェクト割当不足	404 偽装	「リソースが見つかりません」	MSG-COMMON-NOT-FOUND	E-AUTHZ-PROJECT-DENIED
オーナー専有機能 (is_owner=0 でアクセス)	403 + 専用コード、UI 非表示	「この機能はオーナーのみご利用いただけます」	MSG-COMMON-OWNER-ONLY	E-AUTHZ-OWNER-ONLY
オーナー保護違反 (オーナー停止 / 削除)	403	「オーナーアカウントは停止・削除できません」	MSG-COMMON-OWNER-PROTECTED	E-AUTHZ-OWNER-PROTECTED
自己操作不可 (自分の users:manage 剥奪)	403、UI 非活性	「自分の権限は剥奪できません」	MSG-COMMON-SELF-MUTATION	E-AUTHZ-SELF-MUTATION
契約停止中 (contract_status=suspended)	403 + 専用コード、課金画面 / 退会画面 / データエクスポートのみ許可	サスペンション理由 + 再決済誘導	MSG-BILL-CONTRACT-SUSPENDED	E-BIZ-CONTRACT-SUSPENDED
月次無料枠 100% 超過 (質問数以外)	429 + Retry-After	「上限に到達しました」 + 課金ダッシュボード誘導	MSG-QUOTA-*	E-BIZ-QUOTA-EXCEEDED

詳細は [06_エラー設計書.md §5](#) を正本とする。

5.9 9. 緊急時のみ可操作 (§3.2.1-2 から移管)

5.9.1 9.1 「△ 緊急時のみ可」操作の発動条件

条件	実装方針 (メイン側)
1. サポートチケット ID 必須	連携 IF #4 / #5 / #6 / #12 のリクエスト JSON に ticket_id フィールドを必須化。メイン側で空文字検証 + 監査ログ記録
2. 運営者 2 名の承認 (自己承認不可)	顧客管理側で承認を取得し、結果を連携 IF 経由で伝搬。メイン側はメタフィールド approvals[] (承認者 2 名分) の検証 (承認者 ID が異なる、承認時刻が 24 時間以内、kid 検証) を実施
3. 管理者ユーザーへの即時通知	メイン側で inbox_messages レコードを生成 (category=system、importance=high) + メール送信を Queue 投入
4. 監査ログ必須記録	<resource>.<verb>.by_operator 形式の action コードで audit_logs に記録。retention_class=operator_high_priv (5 年保持)

5.9.2 9.2 緊急区分 × 検知ハンドラ × 承認 SLA

緊急区分	検知ハンドラ	承認 SLA	エスカレーション経路
重大障害	monitoring:main_outage 監視 / 連携 IF #2 ヘルスチェック (5s × 3 連続失敗)	15 分以内に 2 名承認	RB-021 (メイン障害時の運営者側縮退運転) と連動
全員ロックアウト	audit_logs(auth.locked) 集約検知 (該当契約内全 admin が auth.locked 状態)	30 分以内に CS マネージャーへ通報	サポート窓口経由でオーナーと連絡、紙ベース回復コード (RB-014) も可

緊急区分	検知ハンドラ	承認 SLA	エスカレーション経路
セキュリティインシデント	NFR-602c 監査ログ完全性検証バッチ / SIEM / 不正アクセス検知 (FR-178)	即時 PagerDuty 起動	セキュリティ責任者 → CTO → 運営本部
法令対応	(運用側で個別判断)	個別判断	法務 → CTO

5.10 10. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------

5.11 11. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

6 エラー設計書 (メイン)

6.1 1. 文書概要

6.1.1 1.1 目的

メインシステムで発生するすべてのエラーについて、分類 / 発生条件 / システム動作 / ユーザー表示 / 復旧方法 / ログレベルを一元化する。エラーコード体系 E-< 分類 >-< 連番 > を統一する。

6.1.2 1.2 対象範囲

- 対象: 入力 / 認証 / 認可 / オーナー境界 / 契約上限 / 課金 / 業務 / システム / 外部連携 / Webhook / 規約 関連エラー
- 対象外: 運営者側エラー ([02_運営者システム/個別設計書群/06_エラー設計書.md](#) 参照、プレフィックス E-OP-*)

6.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

6.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_ 索引.md
API 設計書	ステータスコードとの対応	03_API 設計書.md
メッセージ一覧	エラー文言	07_ メッセージ一覧.md
認証・認可設計書	認証 / 認可エラーの根拠	09_ 認証認可設計書.md
権限設計書	権限不足時の動作	05_ 権限設計書.md
セキュリティ設計書	エラー時の監査 / ログ出力	10_ セキュリティ設計書.md
課金・請求設計書	課金エラーの根拠	11_ 課金請求設計書.md
テーブル定義書	error_logs テーブル	04_ テーブル定義書.md

6.2 2. エラー分類

エラー分類	概要	プレフィックス	代表例
入力エラー	バリデーション失敗	E-INPUT-*	必須項目欠落 / 形式不正 / 重複
認証エラー	認証失敗・期限切れ	E-AUTH-*	パスワード不一致 / ロックアウト / トークン期限切れ
認可エラー	権限不足	E-AUTHZ-*	権限フラグ不足 / オーナー境界違反 / オーナー専有機能
業務エラー	ビジネスルール違反	E-BIZ-*	FAQ 自動公開禁止 / case_status=closed 自動遷移禁止 / 退会済み
契約上限エラー	プラン / 契約上限到達	E-QUOTA-*	月次無料枠 100% / 125% 超過
課金エラー	決済 / 課金処理エラー	E-BILL-*	Stripe 連携失敗 / 支払い方法未登録 / サスペンション中
システムエラー	サーバー内部エラー	E-SYS-*	DB エラー / 内部例外 / OOM
外部連携エラー	外部 API エラー	E-EXT-*	Workers AI 推論失敗 / Resend 配信失敗
連携 IF エラー	連携 IF #1～#12 エラー	E-IF-NNN-*	IF 受信時の冪等性違反 / 認証失敗
Webhook エラー	外部 Webhook(Resend など) 受信エラー	E-WH-*	署名検証失敗 / 冪等性違反
規約エラー	規約・プライバシー関連	E-LEGAL-*	規約未同意状態でのアクセス

6.3 3. 主要設計原則 (エラー分類 A～D、§6.2.13 から移管)

カテゴリ	自動リトライ	利用者提示	HTTP	未解決登録
A. 透過再試行可	○ 指数 BO 3 回	「しばらくしてから再度お試しください」	200(成功)/ 503(失敗)	しない
B. ユーザー再試行	×	「再試行してください」+ 待機時間表示	429 / 423	しない
C. 即時 fail-fast	×	エラー固有メッセージ+ 是正案内	400 / 401 / 403 / 404 / 409 / 422	しない
D. 業務分岐 (正常)	(該当なし)	「個別チャットへ誘導」	200	する

6.4 4. エラー一覧

6.4.1 4.1 入力エラー (E-INPUT-*)

エラー ID	発生条件	メッセージ ID	ステータスコード	システム動作	ログレベル
E-INPUT-REQUIRED	必須項目欠落	(フィールド別)	400	フィールド単位のエラー配列を返却	INFO
E-INPUT-FORMAT	形式不正 (メール / URL / 日付等)	(フィールド別)	400	同上	INFO
E-INPUT-LENGTH	文字数超過 / 不足	(フィールド別)	400	同上	INFO
E-INPUT-DOMAIN	ドメイン形式不正	MSG-SCR-010-M1-ERROR-001	400	-	INFO
E-INPUT-OPTIMISTIC-LOCK	楽観ロック衝突 (version 不一致)	(画面別)	409	「他のユーザーが更新したため保存できませんでした」	INFO
E-INPUT-TURNSTILE	Turnstile 検証失敗 (FR-177)	-	400	再表示	WARN

6.4.2 4.2 認証エラー (E-AUTH-*)

エラー ID	発生条件	メッセージ ID	ステータスコード	システム動作	ログレベル
E-AUTH-CREDENTIAL	パスワード不一致	MSG-SCR-001-ERROR-001	401	失敗カウント +1。攻撃者にヒントを与えない	WARN
E-AUTH-LOCKED	5 回失敗 (IP × user_id)	MSG-SCR-001-ERROR-003	423	15 分ロック。本人 + オーナー + users:manage 保持者へ通知	WARN
E-AUTH-SESSION-EXPIRED	セッション期限切れ (無操作 30 分 / 絶対 12 時間)	-	401	SCR-001 へリダイレクト	INFO
E-AUTH-TOKEN-EXPIRED	トークン期限切れ (パスワード再設定 1h / 招待 7 日 / メール確認 24h / 再入室 30 日)	MSG-SCR-003-ERROR-001	410	再送 CTA を返却	INFO
E-AUTH-TOKEN-USED	トークン使用済み	(画面別)	410	同上	WARN
E-AUTH-VERIFICATION	メール未確認	MSG-SCR-023-*	403	SCR-023 へ	INFO
E-AUTH-REAUTH-REQUIRED	重要操作で再認証期限切れ (15 分超)	-	403	再認証モーダル表示	INFO

6.4.3 4.3 認可エラー (E-AUTHZ-*)

エラー ID	発生条件	メッセージ ID	ステータスコード	システム動作	ログレベル
E-AUTHZ-FORBIDDEN	権限フラグ不足	MSG-COMMON-AUTHZ-403	403 統一	「権限がありません」 + オーナーへ連絡誘導	INFO
E-AUTHZ-OWNER-BOUNDARY	オーナー境界違反 (他契約のリソース参照)	MSG-COMMON-NOT-FOUND	404 偽装	「リソースが見つかりません」 (相手契約の存在を漏らさない)	WARN (必須記録、月次自動検証 AC-017)
E-AUTHZ-PROJECT-DENIED	プロジェクト割当不足	MSG-COMMON-NOT-FOUND	404 偽装	同上	INFO
E-AUTHZ-OWNER-ONLY	オーナー専有機能 (is_owner=0 でアクセス)	MSG-COMMON-OWNER-ONLY	403	UI 非表示	INFO
E-AUTHZ-OWNER-PROTECTED	オーナー停止 / 削除 / 降格 試行 (FR-333)	MSG-COMMON-OWNER-PROTECTED	403	-	WARN
E-AUTHZ-SELF-MUTATION	自分自身の操作禁止 (FR-334)	MSG-COMMON-SELF-MUTATION	403	UI 非活性	INFO
E-AUTHZ-TERMS	規約未同意	MSG-SCR-025-*	403 → SCR-025 へリダイレクト	規約再同意フロー	INFO

6.4.4 4.4 業務エラー (E-BIZ-*)

エラー ID	発生条件	メッセージ ID	ステータスコード	システム動作	ログレベル
E-BIZ-FAQ-PUBLISH	FAQ 自動公開禁止 (§ 4.2.1 ガード)	-	422	「AI / Batch による直接 published 遷移は禁止」(3 層で防御)	WARN
E-BIZ-CASE-CLOSED-AUTO	case_status=closed の自動遷移試行 (FR-079)	-	422	「admin の明示操作のみ closed 可能」	WARN
E-BIZ-NOT-FOUND	リソース不在 (404 偽装ではない)	-	404	-	INFO
E-BIZ-CONTRACT-SUSPENDED	契約停止中の操作	MSG-BILL-CONTRACT-SUSPENDED	403	課金 / 退会 / エクスポートのみ許可	INFO
E-BIZ-CONTRACT-DELETED	退会済み契約	MSG-BILL-DELETED	403	ログイン不可	INFO
E-BIZ-WIDGET-SUSPENDED	ウィジェット応答 (サスペンション中)	-	423 (FR-138)	機能停止旨を返す	INFO
E-BIZ-QUOTA-EXCEEDED	月次無料枠 100% 超過 (FAQ / チャット部屋)	MSG-QUOTA-*	429	Retry-After (月末まで) + 課金ダッシュボード誘導	INFO
E-BIZ-CHAT-RATE	チャット投稿頻度超過 (EU 10 件/分)	-	429	UI 警告	INFO
E-BIZ-AI-CONFIDENCE	AI 信頼度しきい値未達 (< CE60、分類 D 業務分岐)	-	200	未解決登録 (branch_reason=confidence_below_threshold)	INFO
E-BIZ-AI-NO-FAQ	FAQ 参照なし (関連度 < 0.50)	-	200	同上 (branch_reason=faq_not_found)	INFO
E-BIZ-AI-CONTRADICTION	AI 矛盾検知	-	200	同上 (branch_reason=faq_contradiction)	INFO

6.4.5 4.5 契約上限エラー (E-QUOTA-*)

エラー ID	発生条件	メッセージ ID	ステータスコード	システム動作
E-QUOTA-QUESTIONS-100	月間質問数 100% 到達	MSG-QUOTA-QUESTIONS-100	200 (拒否しない、事後課金)	inbox + email (high)
E-QUOTA-FAQ-100	FAQ 件数 100% 到達	MSG-QUOTA-FAQ-100	429	新規登録拒否 (既存編集可)
E-QUOTA-CHAT-100	個別チャット部屋数 100% 到達	MSG-QUOTA-CHAT-100	429	新規作成拒否 (既存返信可)
E-QUOTA-CONTRACT-LIMIT	同時契約上限超過 (NFR-110、200 で新規受付停止)	-	503	Retry-After: 60
E-QUOTA-ONLINE-ADMIN	同時オンライン管理者 1,000 名超過	-	503	Retry-After: 60
E-QUOTA-WIDGET-PARALLEL	ウィジェット同時接続 10,000 並列超過	-	503	Retry-After: 30

6.4.6 4.6 課金エラー (E-BILL-*)

エラー ID	発生条件	メッセージ ID	ステータスコード	システム動作
E-BILL-CONTRACT-SUSPENDED	契約サスペンション中	MSG-BILL-CONTRACT-SUSPENDED	403	課金 / 退会 / エクスポートのみ許可
E-BILL-PAYMENT-FAILED	支払い失敗 Webhook 受信	MSG-BILL-PAYMENT-FAILED	(Webhook 200)	7 日猶予開始、critical メール強制送信
E-BILL-TRIAL-EXPIRED	トライアル終了 + 支払方法未登録	MSG-TRIAL-EXPIRED	(cron)	終了日翌日 00:00 JST サスペンション、critical
E-BILL-DELETED	退会済み契約のアクセス	MSG-BILL-DELETED	403	ログイン不可
E-BILL-PAYMENT-METHOD-MISSING	支払方法未登録	-	422	SCR-015 へ誘導

6.4.7 4.7 システムエラー (E-SYS-*)

エラー ID	発生条件	ステータスコード	システム動作	ログレベル
E-SYS-INTERNAL	サーバー内部エラー / 予期しない例外	500	エラー ID を利用者提示 (FR-113)、内部詳細は応答に含めない	ERROR
E-SYS-DB	DB エラー	500	同上	ERROR
E-SYS-WORKERS-AI-TIMEOUT	Workers AI 推論時間超過 (> 8s)	503	未解決登録 (分類 D)	WARN
E-SYS-NETWORK-TRANSIENT	一時ネットワーク断	503 → 200(成功)	サーバー側指数 BO 3 回 (分類 A 透過再試行可)	INFO

6.4.8 4.8 外部連携エラー (E-EXT-*)

エラー ID	発生条件	システム動作	ログレベル
E-EXT-AI-FAILED	Workers AI 推論失敗	question_logs.metering_billable=false で計測のみ	WARN
E-EXT-EMAIL-FAILED	Resend 配信失敗	notification_logs.delivery_state='failed' → 自動 BO 3 回 (最大 24h)	WARN
E-EXT-EMAIL-BOUNCED	メール bounce(hard)	email_suppression_list 即時追加 (全契約横断)	INFO
E-EXT-EMAIL-SOFT-BOUNCE	メール bounce(soft)5 連続	サブレス登録 (復帰可、SCR-093 経由)	INFO
E-EXT-EMAIL-COMPLAINT	メール苦情 (email.complained)	永久サブレス (復帰不可)	WARN

6.4.9 4.9 連携 IF エラー (E-IF-NNN-*)

エラー ID	発生条件	システム動作	ログレベル
E-IF-COMMON-AUTH	mTLS / JWT 認証失敗	401 + 監査記録	WARN
E-IF-COMMON-IDEMPOTENCY	幂等性違反	200 + 既存処理結果 (リトライ安全性)	INFO
E-IF-COMMON-SCHEMA	JSON Schema 不整合	400	WARN
E-IF-001-*	IF #1(契約停止イベント) 関連	-	WARN
E-IF-002-*	IF #2(強制ログアウト) 関連	-	WARN
E-IF-004-*	IF #4(復元実行) 関連	-	WARN

エラー ID	発生条件	システム動作	ログレベル
E-IF-005-*	IF #5(レート制限上書き) 関連	-	INFO
E-IF-006-*	IF #6(AI しきい値上書き) 関連	-	INFO
E-IF-007-*	IF #7(お知らせ生成) 関連	-	INFO
E-IF-008-*	IF #8(監視メトリクス取得、送信側) 関連	-	INFO
E-IF-009-*	IF #9(不正利用検知通知、送信側) 関連	-	WARN
E-IF-010-*	IF #10(課金 Webhook 受信) 関連	-	WARN
E-IF-012-*	IF #12(運営者操作通知) 関連	-	INFO

6.4.10 4.10 Webhook エラー (E-WH-*)

エラー ID	発生条件	システム動作	ログレベル
E-WH-SIGNATURE-INVALID	Resend / Stripe 署名 HMAC 不正	401 + 監査記録 + 運営者 high alert	WARN
E-WH-IDEMPOTENCY-VIOLATION	event_id 重複	200 + 既存処理結果	INFO
E-WH-PAYLOAD-DIFF	同 event_id + ハッシュ不一致	200 + webhook_payload_diffs INSERT + 運営者 high alert + 自動上書き禁止	WARN
E-WH-DLQ-FAILED	DLQ 自動 BO 3 回失敗	永久失敗 → 運営者手動リプレイ待ち	WARN

6.4.11 4.11 規約エラー (E-LEGAL-*)

エラー ID	発生条件	システム動作
E-LEGAL-TERMS-NOT-AGREED	規約未同意	SCR-025 ヘリダイレクト
E-LEGAL-TERMS-EXPIRED	同意期限超過(発効 + 14 日)	機能制限ガード(課金 / 新規プロジェクト不可、FAQ / ウィジェット稼働は継続)

6.5 5. 異常系共通方針

6.5.1 5.1 入力エラー時の方針

- ・必須項目欠落 / 形式不正は **400 + フィールド単位のエラー配列** を返却
- ・メッセージは画面側で項目近くにインライン表示
- ・文字数 / 範囲チェックは Zod スキーマ (API 設計書 § 3 参照)

6.5.2 5.2 認証エラー時の方針

- ・パスワード不一致 / トークン期限切れは **401 統一**
- ・ログイン失敗 5 回で (**IP × user_id**) を **15 分ロックアウト** (基本設計書 § 10.1.1 / FR-007 / FR-177)
- ・ロックアウト解除は時間経過のみ(管理者解除なし)
- ・攻撃者へのヒント禁止(メール / パスワードのどちらが誤りかを示さない)

6.5.3 5.3 認可エラー時の方針

- ・権限フラグ不足は **403 統一**
- ・オーナー境界違反は **404 偽装** (403 だと相手契約のリソース存在が漏れる)
- ・レスポンスボディには具体的な権限名を含めない(列挙攻撃対策)
- ・AC-017(クロス契約アクセス検知) は **月次自動検証**

6.5.4 5.4 業務エラー時の方針

- ・FAQ 自動公開禁止 (基本設計書 § 4.2.1) / **case_status=closed** の自動遷移禁止 (FR-079) は **422 + 専用エラーコード**
- ・ステータス遷移可否は API 側で必ず検証 (画面側だけの判定に頼らない)

6.5.5 5.5 契約上限エラー時の方針

- ・ 月次無料枠 100% / 125% 超過は **429 + Retry-After**(秒数 = 月末までの秒数)
- ・ 質問数のみ拒否しない (基本設計書 § 6.6.2 / FR-122 = 事後課金、エンドユーザー体験を優先)
- ・ 同時接続上限は **503 + Retry-After**(NFR-114)

6.5.6 5.6 課金エラー時の方針

- ・ 契約停止中 (contract_status=suspended) は **403 + 専用コード E-BILL-CONTRACT-SUSPENDED**
- ・ 課金画面 / 退会画面 / データエクスポート画面のみ許可 (基本設計書 § 6.2.7 / FR-124)
- ・ 支払い失敗 → 7 日猶予期間カウント開始 + メール通知 (**critical**)

6.5.7 5.7 外部連携エラー時の方針

- ・ **Workers AI 推論失敗**: 質問数は計測するが metering_billable=false (基本設計書 § 6.6.1)
- ・ **Resend 配信失敗**: notification_logs.delivery_state='failed' → DLQ 投入 + 自動 BO 3 回 (最大 24h)
- ・ **メール bounce**: email_suppression_list 即時追加 (全契約横断、R-003 共通ドメイン対策)
- ・ **メール苦情 (complained)**: 永久サプレス、復帰不可

6.5.8 5.8 連携 IF エラー時の方針

- ・ 幂等性違反: **200 + 既存処理結果** を返却 (リトライ安全性)
- ・ 認証失敗 (mTLS / JWT): 401 統一、署名検証失敗は別ログ出力
- ・ JSON Schema 不整合: 400 + 監査記録

6.5.9 5.9 Webhook エラー時の方針

- ・ 署名検証失敗: **401 + 監査記録 + 運営者 high alert** + 即時破棄
- ・ 幂等性違反: 200 + 既存処理結果
- ・ ペイロード差分検出: 200 + webhook_payload_diffs INSERT + **自動上書き禁止** (SCR-099 レビュー待ち)

6.5.10 5.10 システムエラー時の方針

- ・ 500 統一、内部詳細は応答に含めない
- ・ **エラー ID を利用者提示** (FR-113、カテゴリ C の 5xx 系)
- ・ **error_logs** テーブルに記録 (180 日保持、JST 05:00 Cron で自動物理削除)
- ・ 監査が必要な操作の途中で発生した場合は **audit_logs** にも記録
- ・ 再試行ボタン 3 秒クールダウン (FR-112)

6.5.11 5.11 不正利用検知エラー時の方針 (FR-195)

- ・ 不正利用検知パターン (FR-195 / NFR-308) に該当 → IF #9 送出 + 運営者通知
- ・ 閾値超過時は自動 suspension + 管理者 + email 通知

6.6 6. ステータスコード対応表

ステータスコード	用途	主なエラー ID
200	業務分岐成功 (分類 D) / Webhook 受信	E-BIZ-AI-* / E-WH-* / E-IF-COMMON-IDEMPOTENCY
400	入力エラー / Schema 不整合	E-INPUT-* / E-IF-COMMON-SCHEMA
401	認証エラー / 署名失敗	E-AUTH-* / E-WH-SIGNATURE-INVALID / E-IF-COMMON-AUTH
403	認可エラー / 契約停止 / 規約未同意	E-AUTHZ-* / E-BIZ-CONTRACT-* / E-LEGAL-*
404	リソース不在 / オーナー境界違反偽装 / プロジェクト割当不足	E-AUTHZ-OWNER-BOUNDARY / E-AUTHZ-PROJECT-DENIED / E-BIZ-NOT-FOUND
409	楽観ロック衝突	E-INPUT-OPTIMISTIC-LOCK

ステータスコード	用途	主なエラー ID
410	トークン期限切れ / 使用済み	E-AUTH-TOKEN-*
422	業務エラー (ステータス遷移不可など)	E-BIZ-FAQ-PUBLISH / E-BIZ-CASE-CLOSED-AUTO
423	ロックアウト / ウィジェット停止	E-AUTH-LOCKED / E-BIZ-WIDGET-SUSPENDED
429	契約上限到達 / レート制限	E-QUOTA-*/ E-BIZ-CHAT-RATE
500	システムエラー	E-SYS-*
502/503	外部連携エラー / 一時的サービス停止	E-EXT-*/ E-SYS-NETWORK-TRANSIENT / E-QUOTA-ONLINE-*

6.7 7. error_logs テーブル設計・運用

項目	仕様
保持期間	180 日 (NFR-704)
削除スケジュール	JST 05:00 Cron で自動物理削除 (UC-140)
記録内容	エラーコード / エラーメッセージ / スタックトレース
除外項目	個人情報 (PII) / 認証トークン / パスワードハッシュ (FR-114)
入力値ログ	先頭 100 文字 + SHA-256 ハッシュのみ記録
エラー ID 提示	カテゴリ C の 5xx 系エラーは利用者に提示 (FR-113)
再試行防止	再試行ボタン 3 秒クールダウン (FR-112)

詳細は [04_テーブル定義書.md § 3.22](#) を参照。

6.8 8. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------

6.9 9. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

7 メッセージ一覧 (メイン)

7.1 1. 文書概要

7.1.1 1.1 目的

メインシステムでユーザーに表示するすべての文言 (画面ラベル / プレースホルダー / ボタン / 説明文 / エラー / 成功 / 警告 / 確認 / 空状態 / トースト / 通知メール) を一元管理する。

7.1.2 1.2 対象範囲

- 対象: SCR-001~027 の全画面文言、エラー文言 (エラー設計書 06 と対応)、通知メールテンプレート (基本設計書 § 9.1 / § 9.4)、課金・契約関連メッセージ、サイドメニュー文言
- 対象外: 運営者側メッセージ (02_運営者システム/個別設計書群/07_メッセージ一覧.md)、コード内デバッグログ

7.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

7.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11ドキュメント体系の俯瞰	00_索引.md
画面設計書	画面別メッセージ参照	02_画面設計書.md
エラー設計書	エラーIDとメッセージIDの対応	06_エラー設計書.md
課金・請求設計書	課金・契約メッセージ	11_課金請求設計書.md
認証・認可設計書	critical通知の宛先解決(オーナー + users:manage 保持者)	09_認証認可設計書.md
共有概念対応表	通知重要度の正本	../共有/共有概念.md

7.2 2. 共通基準

7.2.1 2.1 文言トーン

- ・丁寧体(です・ます調)、ユーザーを「あなた」と呼ばない(二人称省略)
- ・専門用語は説明を併記(初出時)
- ・数値は半角、単位は和(円 / 件 / 日)

7.2.2 2.2 ボタン文言ルール

種別	テンプレート	例
主操作	具体動詞 + する	「削除する」「招待メールを送信」「変更を保存」
取消	「キャンセル」固定	-
危険操作	赤色 + 確認ダイアログ	「削除する」「退会する」

7.2.3 2.3 確認ダイアログルール

要素	テンプレート	例
タイトル	「{動詞} しますか?」	「FAQ を公開しますか?」「メンバーを削除しますか?」
本文	操作結果 + 取消可否	「公開するとウィジェット利用者に表示されます。」「削除すると元に戻せません(運営者への復元依頼が必要です)」

7.2.4 2.4 通知重要度ルール (共有概念正本)

重要度	配信先	配信チャンネル
low	inboxのみ	-
normal	inbox + email(任意)	inbox / email
high	inbox + email	inbox / email
critical	inbox + email 強制送信	inbox + email

critical の送信先解決ルール: オーナーアカウント + 同一オーナー스코ープで **users:manage** フラグを保持する全メンバー。詳細クエリは [09_認証認可設計書.md § 6.3](#) の正本を参照。

7.2.5 2.5 エラーメッセージルール

- ・エラー設計書(06)の各エラーIDに必ず1つのメッセージIDを割り当てる
- ・内部詳細(スタックトレース/DBエラー)はユーザーに見せない
- ・認可エラーは具体的な権限名を含めない(列挙攻撃対策)
- ・認証失敗時はメールアドレス/パスワードのどちらが誤りかを示さない(攻撃者にヒント与えない)

7.2.6 2.6 禁則語 (単独使用禁止)

「OK」「実行」「処理する」「確定」「送信」「こちら」「エラーが発生しました」「不正な値です」「失敗しました」

7.2.7 2.7 i18n キー化必須 (基本設計書 §11.8 から移管)

- MVP は日本語のみだが、全メッセージは i18n キー化必須
- メッセージ ID = i18n キーとして直接利用可能な形式
- 多言語対応は Future(04_ 将来拡張/01_ 将来要件定義書.md 参照)

7.3 3. メッセージ ID 体系

MSG-< 対象 ID>-< 種別 >-< 連番 >形式

種別コード	種別	用途例
TITLE	画面タイトル	ページのヘッダ
DESC	説明文	画面の説明
LBL	ラベル	フォームの項目名
PH	プレースホルダー	入力欄のヒント
BTN	ボタン	アクション
LINK	リンク	テキストリンク
STEP	ステップ	Timeline 内のステップ
HINT	ヘルプ	ツールチップ
TOOLTIP	ツールチップ	hover ヒント
WARN	警告	注意喚起
BANNER	バナー	強調帯
CHIP	チップ	クイックフィルタ
BADGE	バッジ	ステータス表示
MSG	補足メッセージ	注意書き
SUCCESS	成功	完了表示
TOAST	トースト	完了通知バナー
ERROR	エラー	エラー表示
CONFIRM_TITLE	確認ダイアログタイトル	-
CONFIRM_MSG	確認ダイアログ本文	-
CONFIRM_BTN	確認ダイアログ確定ボタン	-
CONFIRM_LBL	確認ダイアログ内のラベル	-
EMPTY	空状態	データなし時
PERMISSION	権限不足表示	-
BTN_HINT	ボタン横の補足	-
NAV	ナビゲーション	前後リンク等
NOTIF_SUBJECT	通知メール件名	-
NOTIF_BODY	通知メール本文	-

7.4 4. 画面別メッセージ全件

(基本設計書 §5.4.1~5.4.18 から移管)

7.4.1 4.1 SCR-001 ログイン

メッセージ ID	種別	表示文言	表示条件	関連エラー ID
MSG-SCR-001-TITLE-001	TITLE	ログイン	画面ヘッダ	-

メッセージ ID	種別	表示文言	表示条件	関連エラー ID
MSG-SCR-001-LBL-001	LBL	メールアドレス	入力欄ラベル(必須)	-
MSG-SCR-001-LBL-002	LBL	パスワード	入力欄ラベル(必須)	-
MSG-SCR-001-BTN-001	BTN	ログイン	送信ボタン	-
MSG-SCR-001-LINK-001	LINK	パスワードを忘れた場合	SCR-003 へ遷移	-
MSG-SCR-001-LINK-002	LINK	アカウント登録	SCR-002 へ遷移	-
MSG-SCR-001-ERROR-001	ERROR	メールアドレスまたはパスワードが正しくありません	認証失敗時(攻撃者にヒント与えない共通文言)	E-AUTH-CREDENTIAL
MSG-SCR-001-ERROR-002	ERROR	ログインに失敗しました。5 回失敗後、15 分間ロックされます	ロックアウト警告時(FR-007)	E-AUTH-LOCKOUT-WARN
MSG-SCR-001-ERROR-003	ERROR	ログイン試行回数の上限に達しました。{N} 分後にもう一度お試しください	ロックアウト中	E-AUTH-LOCKED

7.4.2 4.2 SCR-002 新規登録

メッセージ ID	種別	表示文言	表示条件	関連エラー ID
MSG-SCR-002-TITLE-001	TITLE	アカウント登録	画面ヘッダ	-
MSG-SCR-002-LBL-001	LBL	メールアドレス	必須。管理者本人のメール	-
MSG-SCR-002-LBL-002	LBL	パスワード	必須。12 文字以上、3 種類以上の文字種	-
MSG-SCR-002-LBL-003	LBL	パスワード(確認)	必須。一致確認	-
MSG-SCR-002-LBL-004	LBL	利用規約に同意する	必須チェック	-
MSG-SCR-002-LBL-005	LBL	プライバシーポリシーに同意する	必須チェック	-
MSG-SCR-002-LBL-006	LBL	業種選択	任意。高規制業界選択時は標準提供範囲外を案内	-
MSG-SCR-002-BTN-001	BTN	登録する	送信ボタン	-
MSG-SCR-002-LINK-001	LINK	ログイン画面へ	SCR-001 へ遷移	-

7.4.3 4.3 SCR-003 パスワード再設定

メッセージ ID	種別	表示文言	表示条件	関連エラー ID
MSG-SCR-003-TITLE-001	TITLE	パスワードの再設定	段階 1	-
MSG-SCR-003-DESC-001	DESC	ご登録のメールアドレスに再設定リンクをお送りします	段階 1 説明	-
MSG-SCR-003-TITLE-002	TITLE	メールを送信しました	段階 1 送信後	-
MSG-SCR-003-DESC-002	DESC	メールに記載のリンクから再設定を続けてください(リンクは 1 時間有効)	段階 1 送信後説明	-
MSG-SCR-003-TITLE-003	TITLE	新しいパスワードを設定	段階 2	-
MSG-SCR-003-DESC-003	DESC	12 文字以上、英大文字・小文字・数字・記号のうち 3 種類以上を含めてください	段階 2 説明	-
MSG-SCR-003-STEP-001	STEP	① メールアドレスを入力	Timeline	-
MSG-SCR-003-STEP-002	STEP	② 受信メールのリンクをクリック	Timeline	-
MSG-SCR-003-STEP-003	STEP	③ 新しいパスワードを設定	Timeline	-
MSG-SCR-003-BTN-001	BTN	再設定リンクを送信	段階 1 Primary	-
MSG-SCR-003-BTN-002	BTN	新しいパスワードを設定する	段階 2 Primary	-
MSG-SCR-003-MSG-001	MSG	あと {N} 文字 / あと {種類数} 種類の文字種が必要です	強度メーター	-
MSG-SCR-003-ERROR-001	ERROR	再設定リンクが期限切れ、または無効です(有効期限 1 時間)。新しいリンクを再送してください	トークン無効・期限切れ	E-AUTH-TOKEN-EXPIRED
MSG-SCR-003-SUCCESS-001	SUCCESS	新しいパスワードを設定しました。ログインしてください	完了	-
MSG-SCR-003-MSG-002	MSG	メールを再送する ({N} 分後から可能)	再送残時間	-

7.4.4 4.4 SCR-010 プロジェクト一覧

メッセージ ID	種別	表示文言	表示条件	関連エラー ID
MSG-SCR-010-TITLE-001	TITLE	プロジェクト	画面ヘッダ	-
MSG-SCR-010-DESC-001	DESC	ウィジェットを設置するサイトごとのプロジェクトを管理します	画面説明	-
MSG-SCR-010-HINT-001	HINT	☒ 確認待ち—このプロジェクトは確認完了まで連絡先メールを表示しません	連絡先メール確認待ち時	-
MSG-SCR-010-BTN-001	BTN	+ 新規プロジェクトを作成	Primary	-

メッセージ ID	種別	表示文言	表示条件	関連エラー ID
MSG-SCR-010-CONFIRM-TITLE-001	CONFIRM	プロジェクトを削除しますか？	削除確認	-
MSG-SCR-010-CONFIRM-MSG-001	CONFIRM	削除するとプロジェクト配下の FAQ・未解決質問・チャットも削除されます。元に戻せません(運営者への復元依頼が必要です)	削除確認本文	-
MSG-SCR-010-TOAST-001	TOAST	プロジェクトを削除しました	削除完了	-
MSG-SCR-010-EMPTY-001	EMPTY	プロジェクトがまだありません。最初のプロジェクトを作成しましょう	空状態	-

7.4.5 4.5 SCR-010-M1 プロジェクト設定モダール

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-010-M1-TITLE-001	TITLE	新規プロジェクトを作成	新規作成モード
MSG-SCR-010-M1-DESC-001	DESC	ウィジェットを埋め込むサイトのドメインと連絡先メールを設定します	新規作成説明
MSG-SCR-010-M1-TITLE-002	TITLE	プロジェクト設定—{プロジェクト名}	編集モード
MSG-SCR-010-M1-DESC-002	DESC	プロジェクトの設定を変更します	編集モード説明
MSG-SCR-010-M1-LBL-001	LBL	プロジェクト名 *	必須。1～100 文字
MSG-SCR-010-M1-PH-001	PH	例: サポートサイト	プレースホルダ
MSG-SCR-010-M1-LBL-002	LBL	許可ドメイン *	必須。複数値
MSG-SCR-010-M1-PH-002	PH	例: https://example.com、*.example.com	プレースホルダ
MSG-SCR-010-M1-HINT-001	HINT	ウィジェット埋め込みを許可するドメイン。サブドメインを許可するには *.example.com のように記載します	許可ドメイン補足
MSG-SCR-010-M1-LBL-003	LBL	プロジェクト連絡先メール	任意。メール確認要
MSG-SCR-010-M1-PH-003	PH	例: support@example.com	プレースホルダ
MSG-SCR-010-M1-HINT-002	HINT	設定時に確認メール送信 → リンククリックで確認完了。確認完了後、ウィジェット表示に利用	連絡先メール説明
MSG-SCR-010-M1-BTN-001	BTN	プロジェクトを作成	新規 Primary
MSG-SCR-010-M1-BTN-002	BTN	変更を保存	編集 Primary
MSG-SCR-010-M1-TOAST-001	TOAST	プロジェクトを作成しました。ウィジェット設定を確認してください	新規作成完了
MSG-SCR-010-M1-TOAST-002	TOAST	変更を保存しました	編集完了
MSG-SCR-010-M1-MSG-001	MSG	連絡先メールに確認メールを送信しました。メールに記載のリンクから確認を完了するまで、ウィジェット上に連絡先は表示されません	メール確認案内
MSG-SCR-010-M1-MSG-002	MSG	確認メールを再送する ({N} 分後から可能)	再送中表示
MSG-SCR-010-M1-ERROR-001	ERROR	許可ドメインの形式が正しくありません(例: https://example.com、*.example.com)	ドメインバリデーション

7.4.6 4.6 SCR-011 未解決質問一覧 / 詳細

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-011-TITLE-001	TITLE	未解決質問	画面ヘッダ
MSG-SCR-011-DESC-001	DESC	ウィジェットで回答できなかった質問を確認・対応します	画面説明
MSG-SCR-011-CHIP-001	CHIP	自分の未対応 / 期日切れ / 今日来た / すべて	クイックフィルタ
MSG-SCR-011-BADGE-001	BADGE	☒ 未対応 / ☒ 対応中 / ☒ 解決済み / ☒ 終了	状況バッジ
MSG-SCR-011-CONFIRM_TITLE-001	CONFIRM	対応不要として終了しますか？	終了確認
MSG-SCR-011-CONFIRM_MSG-001	CONFIRM	終了するとエンドユーザーに通知が送信され、再オープンには運営者への依頼が必要になります。	終了確認本文
MSG-SCR-011-CONFIRM_LBL-001	CONFIRM	終了理由	必須。最大 500 文字
MSG-SCR-011-CONFIRM_BTN-001	CONFIRM	対応不要として終了する	終了確認 Primary
MSG-SCR-011-TOAST-001	TOAST	対応不要として終了しました。エンドユーザーへ通知を送信しています。	終了完了
MSG-SCR-011-EMPTY-001	EMPTY	未解決質問はありません。ウィジェットを設置済みなら正常な状態です。	空状態
MSG-SCR-011-PERMISSION-001	PERMISSION	閲覧のみ可能 (返信権限がありません)。担当者へ権限付与をご依頼ください。	権限不足

7.4.7 4.7 SCR-012 FAQ 管理

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-012-TITLE-001	TITLE	FAQ	一覧画面ヘッダ
MSG-SCR-012-DESC-001	DESC	ウィジェットで自動回答される FAQ を管理します	画面説明
MSG-SCR-012-TITLE-002	TITLE	FAQ 編集	編集画面ヘッダ
MSG-SCR-012-TITLE-003	TITLE	新規 FAQ 作成	作成画面ヘッダ
MSG-SCR-012-DESC-002	DESC	{FAQ ID} の内容を編集します。30 秒ごとに自動保存されます	編集説明
MSG-SCR-012-LBL-001	LBL	質問文 *	必須。1～500 文字
MSG-SCR-012-LBL-002	LBL	回答文 *	必須。1～5,000 文字。リッチテキスト
MSG-SCR-012-LBL-003	LBL	カテゴリ	任意。100 文字以内
MSG-SCR-012-LBL-004	LBL	状態	draft / published / hidden
MSG-SCR-012-CONFIRM_TITLE-001	CONFIRM	FAQ を公開しますか？	公開確認
MSG-SCR-012-CONFIRM_MSG-001	CONFIRM	公開するとウィジェット利用者 (エンドユーザー) に表示されます。誤公開時は同画面から「非公開化」できます。	公開確認本文
MSG-SCR-012-CONFIRM_TITLE-002	CONFIRM	FAQ を削除しますか？	削除確認

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-012-CONFIRM_MSG-002	CONFIRM	削除すると元に戻せません(運営者への復元依頼が必要です)。	削除確認本文
MSG-SCR-012-WARN-001	WARN	生成結果は下書きとして保存されます。内容を必ず確認してから公開してください。	AI 下書き注意
MSG-SCR-012-BTN-001	BTN	下書きを生成する	AI 下書き Primary
MSG-SCR-012-TOAST-001	TOAST	FAQ を公開しました。ウィジェットで利用可能です	公開完了
MSG-SCR-012-EMPTY-001	EMPTY	FAQ がまだありません。最初の FAQ を作成しましょう。	空状態

7.4.8 4.8 SCR-013 個別チャット部屋

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-013-TITLE-001	TITLE	個別チャットー{問い合わせ ID}	管理者側
MSG-SCR-013-DESC-001	DESC	利用者の返答待ち (あと {N} 日で自動クローズ次段階へ)	管理者側説明
MSG-SCR-013-TITLE-002	TITLE	お問い合わせー{問い合わせ ID}	エンドユーザー側
MSG-SCR-013-DESC-002	DESC	ご質問にお答えします	エンドユーザー側説明
MSG-SCR-013-WARN-001	WARN	機密情報(電話番号・クレジットカード番号・パスワード等)は入力しないでください	機密情報警告(常時)
MSG-SCR-013-MSG-001	MSG	自動クローズまで: 残 N 日(現在 X/6 段階)	自動クローズ進捗
MSG-SCR-013-CONFIRM_TITLE-001	CONFIRM	この問い合わせを終了しますか?	部屋クローズ確認
MSG-SCR-013-CONFIRM_MSG-001	CONFIRM	終了するとエンドユーザーに通知され、再オープンには運営者への依頼が必要になります。	部屋クローズ確認本文
MSG-SCR-013-CONFIRM_TITLE-002	CONFIRM	この問い合わせを再オープンしますか?	再オープン確認
MSG-SCR-013-CONFIRM_MSG-002	CONFIRM	再オープンするとエンドユーザーへ通知され、自動クローズタイマーが再開します。	再オープン確認本文
MSG-SCR-013-TOAST-001	TOAST	問い合わせを終了しました。エンドユーザーへ通知を送信中です	終了完了
MSG-SCR-013-MSG-002	MSG	この問い合わせは{終了日}に終了しました。再オープンが必要な場合は運営者へご依頼ください	部屋クローズ後
MSG-SCR-013-BTN_HINT-001	BTN_HINT	利用者の返答待ちと判定し、自動クローズタイマーを進めます	「利用者待ち」ボタン tooltip
MSG-SCR-013-EMPTY-001	EMPTY	個別チャットはまだありません。エンドユーザーからの問い合わせが始まるとここに表示されます	空状態

7.4.9 4.9 SCR-014 ウィジェット設定

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-014-TITLE-001	TITLE	ウィジェット設定	画面ヘッダ
MSG-SCR-014-DESC-001	DESC	サイトに埋め込むウィジェットの公開キー・見た目・配置を設定します	画面説明
MSG-SCR-014-TOAST-001	TOAST	公開キーをコピーしました	キーコピー成功

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-014-TOAST-002	TOAST	埋め込みコードをコピーしました	コードコピー成功
MSG-SCR-014-WARN-001	WARN	☒ 公開キーの有効期限が残り {N} 日です。有効期限を延長するか、再発行してください	キー期限残 7 日以内
MSG-SCR-014-WARN-002	WARN	旧公開キーがまだ使われています。{N} 件のアクセスを検知 (最終 {timestamp})	旧キー使用
MSG-SCR-014-CONFIRM_TITLE-001	CONFIRM	公開キーを再発行しますか？	ローテーション確認
MSG-SCR-014-CONFIRM_MSG-001	CONFIRM	新公開キーが発行されます。旧キーは 30 日間有効ですが、サイト側で新キーへの差し替えを早めに行ってください	ローテーション確認本文
MSG-SCR-014-TOAST-003	TOAST	ウィジェット設定を保存しました。サイト側に反映されるまで最大 60 秒かかります	保存完了

7.4.10 4.10 SCR-015 利用状況・課金ダッシュボード

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-015-TITLE-001	TITLE	利用状況	画面ヘッダ
MSG-SCR-015-DESC-001	DESC	お使いの量と料金、契約状況を確認できます	画面説明
MSG-SCR-015-BANNER-001	BANNER	☒ 無料トライアル 残 N 日 / 30 日トライアル中は全機能が無料です	Trial Banner(4 日以上、青)
MSG-SCR-015-BANNER-002	BANNER	☒ 無料トライアル 残 N 日ー支払い方法を登録しないと自動停止します	Trial Banner(3 日以内、赤)
MSG-SCR-015-MSG-001	MSG	☒ もうすぐ予算到達 (残 N 件で月次予算上限)	UsageBar 80%
MSG-SCR-015-MSG-002	MSG	☒ 月次予算に到達しました	UsageBar 100%
MSG-SCR-015-MSG-003	MSG	☒ 月次予算超過 (超過分は次月請求)	UsageBar 125% 超過
MSG-SCR-015-CONFIRM_TITLE-001	CONFIRM	契約を解約しますか？	解約確認
MSG-SCR-015-CONFIRM_MSG-001	CONFIRM	{N} 日までサービスをご利用いただけます。データのエクスポートは退会画面から実施してください。	解約確認本文
MSG-SCR-015-EMPTY-001	EMPTY	請求履歴はまだありません。トライアル終了後に最初の請求が発生します。	空状態

7.4.11 4.11 SCR-016 設定

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-016-TITLE-001	TITLE	設定	画面ヘッダ
MSG-SCR-016-DESC-001	DESC	契約・データ保持・アクセス制限などの設定を変更します	画面説明
MSG-SCR-016-HINT-001	HINT	設定日数を超えた質問ログは自動削除されます。引き下げのみ可能で、後から引き上げはできません	ログ保持日数 helper
MSG-SCR-016-PH-001	PH	例: 203.0.113.0/24(社内ネットワーク)、2001:db8::/32(IPv6 範囲)	IP 許可リストプレースホルダ
MSG-SCR-016-MSG-001	MSG	あなたが現在使用している IP: {currentIp}	IP 表示
MSG-SCR-016-WARN-001	WARN	☒ あなたの現在の IP がリストに含まれていません。保存するとアクセスできなくなります	自己ロックアウト警告

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-016-CONFIRM_TITLE-001	CONFIRM	IP許可リストを保存しますか？	IP 変更確認
MSG-SCR-016-CONFIRM_MSG-001	CONFIRM	保存後、IP 許可リスト外からはアクセスできなくなります。現在の IP({currentIp}) がリストに含まれていることを必ず確認してください	IP 変更確認本文
MSG-SCR-016-TOAST-001	TOAST	設定を保存しました	保存完了

7.4.12 4.12 SCR-017 ユーザー管理

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-017-TITLE-001	TITLE	ユーザー管理	画面ヘッダ
MSG-SCR-017-DESC-001	DESC	契約のオーナー・メンバーを管理します	画面説明
MSG-SCR-017-MSG-001	MSG	オーナー: {表示名}({メールアドレス})[詳細 ▼]	オーナーバナー折畳
MSG-SCR-017-MSG-002	MSG	オーナーは契約1つにつき1人で、課金・退会・規約再同意を専有します。MVP では降格・停止・削除・譲渡はできません	オーナーバナー展開
MSG-SCR-017-TOOLTIP-001	TOOLTIP	FAQ の登録・編集・削除・公開ができます	権限フラグ (FAQ)
MSG-SCR-017-TOOLTIP-002	TOOLTIP	未解決質問への返信・対応ができます	権限フラグ (チャット)
MSG-SCR-017-TOOLTIP-003	TOOLTIP	メンバーの招待・権限変更・停止ができます	権限フラグ (ユーザー)
MSG-SCR-017-TOOLTIP-004	TOOLTIP	プロジェクト作成・編集・ウィジェット設定ができます	権限フラグ (プロジェクト)
MSG-SCR-017-TOOLTIP-005	TOOLTIP	監査ログを閲覧できます (返信権はありません)	権限フラグ (ログ)
MSG-SCR-017-CONFIRM_TITLE-001	CONFIRM	メンバーを削除しますか？	削除確認
MSG-SCR-017-CONFIRM_MSG-001	CONFIRM	削除すると元に戻せません。アクセス権が即時失われ、再招待が必要になります。	削除確認本文
MSG-SCR-017-TOAST-001	TOAST	メンバーを削除しました	削除完了
MSG-SCR-017-TOAST-002	TOAST	招待を取り消しました。リンクは無効になりました	招待取消完了
MSG-SCR-017-EMPTY-001	EMPTY	メンバーがまだ招待されていません。メンバーを招待するとあなたと一緒に運用できます	空状態

7.4.13 4.13 SCR-017-M1 メンバー招待 / 編集モダル

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-017-M1-WARN-001	WARN	あなた自身を編集中: 権限・状態は変更できません	自己編集警告
MSG-SCR-017-M1-HINT-001	HINT	よく使う組み合わせから選べます。後から個別に調整できます。	権限テンプレ説明
MSG-SCR-017-M1-WARN-002	WARN	☒ プロジェクト未選択の場合、このメンバーはダッシュボードのみ利用できます	割当 0 件警告
MSG-SCR-017-M1-TOAST-001	TOAST	招待メールを送信しました。有効期限は 7 日間です	招待送信完了
MSG-SCR-017-M1-TOAST-002	TOAST	招待メールを再送しました (旧リンクは失効しました)	招待再送完了

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-017-M1-CONFIRM_TITLE-001	CONFIRM	招待を取り消しますか？	招待取消確認
MSG-SCR-017-M1-CONFIRM_MSG-001	CONFIRM	取消すると招待リンクが失効します。再招待には新しいリンクを発行する必要があります。	招待取消確認本文
MSG-SCR-017-M1-CONFIRM_TITLE-002	CONFIRM	メンバーを停止しますか？	メンバー停止確認
MSG-SCR-017-M1-CONFIRM_MSG-002	CONFIRM	停止したメンバーはログインできません。停止解除はいつでも可能です。	メンバー停止確認本文
MSG-SCR-017-M1-CONFIRM_TITLE-003	CONFIRM	強制ログアウトしますか？	強制ログアウト確認
MSG-SCR-017-M1-CONFIRM_MSG-003	CONFIRM	現在のセッションをすべて終了します。次のログイン時に再認証が必要です。	強制ログアウト確認本文
MSG-SCR-017-M1-TOOLTIP-001	TOOLTIP	自分の権限は剥奪できません(他のユーザー管理権限保持者に依頼してください)	自己権限剥奪ガード

7.4.14 4.14 SCR-018 プライバシーポリシー / 利用規約閲覧

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-018-TITLE-001	TITLE	プライバシーポリシー / 利用規約	画面ヘッダ
MSG-SCR-018-DESC-001	DESC	最新の利用規約とプライバシーポリシー、および過去の改訂履歴を確認できます	画面説明
MSG-SCR-018-BADGE-001	BADGE	☒ 同意済み ({同意日})	同意済みバッジ(緑)
MSG-SCR-018-BADGE-002	BADGE	☒ 未同意—同意手続きを行ってください	未同意バッジ(赤)
MSG-SCR-018-LINK-001	LINK	同意手続きへ	SCR-025 へ
MSG-SCR-018-LINK-002	LINK	過去のバージョン履歴を表示	-
MSG-SCR-018-LINK-003	LINK	v{old} と v{new} の差分を見る	バージョン比較

7.4.15 4.15 SCR-021 お知らせ一覧

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-021-TITLE-001	TITLE	お知らせ	画面ヘッダ
MSG-SCR-021-DESC-001	DESC	サービス運営者からの通知を確認します(未読 {N} / 全 {M})	画面説明
MSG-SCR-021-CHIP-001	CHIP	未読のみ / 重要のみ / 課金 / お知らせ / システム / すべて	クイックフィルタ
MSG-SCR-021-BTN-001	BTN	表示中の {N} 件を既読化	表示中既読化
MSG-SCR-021-LINK-001	LINK	すべての未読 ({M} 件) を既読化	全未読既読化
MSG-SCR-021-CONFIRM_TITLE-001	CONFIRM	{N} 件のお知らせを既読化しますか？	全既読化確認

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-021-CONFIRM-MSG-001	CONFIRM	既読化したお知らせも、お知らせ一覧から引き続き閲覧できます	全既読化確認本文
MSG-SCR-021-TOAST-001	TOAST	{N} 件のお知らせを既読化しました	既読化完了
MSG-SCR-021-EMPTY-001	EMPTY	未読のお知らせはありません	空状態 (未読のみ)
MSG-SCR-021-EMPTY-002	EMPTY	お知らせはまだありません	空状態 (全て)

7.4.16 4.16 SCR-022 お知らせ詳細

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-022-TITLE-001	TITLE	お知らせ-{タイトル}	画面ヘッダ (動的)
MSG-SCR-022-TOAST-001	TOAST	このお知らせを既読化しました	自動既読化トースト
MSG-SCR-022-LINK-001	LINK	利用状況ダッシュボードを見る →	関連リンク (billing)
MSG-SCR-022-LINK-002	LINK	詳しくはこちら →	関連リンク (announcement)
MSG-SCR-022-LINK-003	LINK	関連設定画面を開く →	関連リンク (system)
MSG-SCR-022-NAV-001	NAV	← 前のお知らせ / 次のお知らせ →	前後ナビ

7.4.17 4.17 SCR-023 メール確認

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-023-TITLE-001	TITLE	メールを送信しました	送信済み状態
MSG-SCR-023-DESC-001	DESC	{メールアドレス} に確認メールを送信しました。メールに記載のリンクから登録を完了してください	送信済み説明
MSG-SCR-023-TITLE-002	TITLE	メールアドレスの確認が完了しました	確認成功
MSG-SCR-023-DESC-002	DESC	ログインしてサービスをご利用ください	確認成功説明
MSG-SCR-023-TITLE-003	TITLE	確認リンクが無効です	確認失敗
MSG-SCR-023-DESC-003	DESC	リンクが期限切れか、すでに使用されています	確認失敗説明
MSG-SCR-023-MSG-001	MSG	確認リンクの有効期限は 24 時間です	有効期限案内
MSG-SCR-023-MSG-002	MSG	メールが届かない場合は迷惑メールフォルダもご確認ください	迷惑メール案内
MSG-SCR-023-BTN-001	BTN	メールを再送する (あと {N} 分 {S} 秒)	再送残時間中 (disabled)
MSG-SCR-023-BTN-002	BTN	メールを再送する	再送可能時
MSG-SCR-023-BTN-003	BTN	ログインする	確認成功画面 Primary
MSG-SCR-023-BTN-004	BTN	新規登録からやり直す	確認失敗画面 Primary
MSG-SCR-023-ERROR-001	ERROR	メール再送の上限に達しました。{N} 分後にもう一度お試しください	再送上限超過

7.4.18 4.18 SCR-024 退会申請

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-024-TITLE-001	TITLE	退会申請	画面ヘッダ
MSG-SCR-024-DESC-001	DESC	退会するとサービスがご利用いただけなくなります	画面説明
MSG-SCR-024-STEP-001	STEP	① 申請(今日)	Timeline ステップ 1
MSG-SCR-024-STEP-002	STEP	② {cutoffDate} 末日: サービス停止	Timeline ステップ 2
MSG-SCR-024-STEP-003	STEP	③ {deletionDate}: すべてのデータを完全削除(復元不可)	Timeline ステップ 3
MSG-SCR-024-BTN-001	BTN	☒ すべてのデータをエクスポートする	データエクスポート CTA
MSG-SCR-024-MSG-001	MSG	当月分の従量課金は通常通り請求されます。次月以降の請求は発生しません	課金影響案内
MSG-SCR-024-MSG-002	MSG	全メンバーのアクセス権が当月末で失効します。招待中のメンバーは自動的にキャンセルされます	メンバー影響案内
MSG-SCR-024-PH-001	PH	サービス改善のため、よろしければご記入ください…	退会理由プレースホルダ
MSG-SCR-024-CONFIRM_TITLE-001	CONFIRM_TITLE	本当に退会しますか?	退会確認
MSG-SCR-024-CONFIRM_MSG-001	CONFIRM_MSG	{cutoffDate} にサービスが停止し、{deletionDate} にすべてのデータが完全削除されます。この操作は取り消せません。	退会確認本文
MSG-SCR-024-SUCCESS-001	SUCCESS	退会申請を受け付けました。{cutoffDate} までは通常通りご利用いただけます	完了

7.4.19 4.19 SCR-025 規約再同意割込み

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-025-TITLE-001	TITLE	【重要】利用規約改定のお知らせ	モーダルヘッダ
MSG-SCR-025-DESC-001	DESC	契約継続のため、改定内容をご確認のうえご同意ください	モーダル説明
MSG-SCR-025-STEP-001	STEP	① 現在: 通常通り全機能をご利用いただけます	Timeline ①
MSG-SCR-025-STEP-002	STEP	② {発効日} 以降: 同意 / 不同意の選択をお願いします	Timeline ②
MSG-SCR-025-STEP-003	STEP	③ {同意期限} 以降: 同意するまで一部機能を制限します	Timeline ③
MSG-SCR-025-MSG-001	MSG	制限される機能: 課金画面操作、新規プロジェクト作成	機能制限内容
MSG-SCR-025-MSG-002	MSG	継続される機能: FAQ 編集、ウィジェット稼働、お知らせ閲覧	継続機能案内
MSG-SCR-025-LBL-001	LBL	{利用規約 vX.X} に同意します [全文を読む]	規約同意チェック (必須)
MSG-SCR-025-LBL-002	LBL	{プライバシーポリシー vX.X} に同意します [全文を読む]	プライバシー同意チェック (必須)
MSG-SCR-025-BTN-001	BTN	同意して続行する	Primary(両チェック充足時のみ活性)
MSG-SCR-025-LINK-001	LINK	同意しない(退会手続きへ)	不同意リンク (赤)
MSG-SCR-025-CONFIRM_TITLE-001	CONFIRM_TITLE	退会手続きへ進みますか?	不同意確認

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-025-CONFIRM-MSG-001	CONFIRM	同意しない場合、退会手続き画面へ移動します。退会手続き画面でも改めて同意を選択できます	不同意確認本文
MSG-SCR-025-WARN-001	WARN	同意期限 ({期限日}) を過ぎたため、課金画面操作と新規プロジェクト作成は同意するまで制限されます	期限切れ警告 (③)
MSG-SCR-025-SUCCESS-001	SUCCESS	利用規約に同意しました。引き続きサービスをご利用いただけます	完了

7.4.20 4.20 SCR-027 エンドユーザー再入室

メッセージ ID	種別	表示文言	表示条件
MSG-SCR-027-TITLE-001	TITLE	お問い合わせを再開	有効状態
MSG-SCR-027-DESC-001	DESC	以前のお問い合わせ内容を確認・続きを送信できます	有効状態説明
MSG-SCR-027-TITLE-002	TITLE	お問い合わせを再開 (期限間近)	期限間近
MSG-SCR-027-DESC-002	DESC	リンクの有効期限が残り {N} 日です。期限切れ後は新しいリンクをメールで再送できます	期限間近説明
MSG-SCR-027-TITLE-003	TITLE	リンクの有効期限が切れています	期限切れ
MSG-SCR-027-DESC-003	DESC	メールアドレスを入力して新しいリンクを受け取ってください	期限切れ説明
MSG-SCR-027-MSG-001	MSG	☒ あと {N} 日 {H} 時間 ご利用いただけます	残時間 (14 日以上、緑)
MSG-SCR-027-MSG-002	MSG	☒ あと {N} 日 {H} 時間 ご利用いただけます (期限間近)	残時間 (3-14 日、黄)
MSG-SCR-027-MSG-003	MSG	☒ 残り {N} 日です。お早めにご確認ください	残時間 (3 日以内、赤)
MSG-SCR-027-BTN-001	BTN	続きから再開する	有効時 Primary
MSG-SCR-027-BTN-002	BTN	新しいリンクをメールで送る	期限切れ時 Primary
MSG-SCR-027-MSG-004	MSG	メールを送信しています…	再送中 ProgressText
MSG-SCR-027-TITLE-004	TITLE	メールを送信しました	再送完了画面
MSG-SCR-027-MSG-005	MSG	{メールアドレス} に新しいリンクをメールで送信しました (有効期限 30 日)。メールに記載のリンクから再開してください	再送完了本文
MSG-SCR-027-ERROR-001	ERROR	メール再送の上限に達しました。{N} 分後にもう一度お試しください	再送上限超過

7.5 5. サイドメニュー (共通 UI)

メッセージ ID	種別	表示文言	表示先
MSG-NAV-MAIN-001	LBL	ホーム (利用状況サマリ)	→ SCR-015
MSG-NAV-MAIN-002	LBL	未解決質問	→ SCR-011(バッジ: 未解決件数)
MSG-NAV-MAIN-003	LBL	個別チャット	→ SCR-013(バッジ: 未読/未返信)
MSG-NAV-MAIN-004	LBL	お知らせ	→ SCR-021(バッジ: 未読件数)
MSG-NAV-MAIN-005	LBL	FAQ 管理	→ SCR-012

メッセージ ID	種別	表示文言	表示先
MSG-NAV-MAIN-006	LBL	プロジェクト	→ SCR-010
MSG-NAV-MAIN-007	LBL	ユーザー管理	→ SCR-017
MSG-NAV-MAIN-008	LBL	利用量・課金	→ SCR-015(バッジ: 警告時)
MSG-NAV-MAIN-009	LBL	設定・退会	→ SCR-016
MSG-NAV-MAIN-010	LBL	プライバシーポリシー / 利用規約	→ SCR-018

7.6 6. 通知契機・テンプレート (§9.1 / §9.4 を吸収、本書の中核)

7.6.1 6.1 通知契機 21 種 (FR-140~149b、基本設計書 §9.1 全件)

通知 ID	契機	対象	強制送信	配信先	重要度	チャネル	テンプレート ID
NOTIF-EMAIL_VERIFY	アカウント登録	admin	○	admin	critical	email	TPL-EMAIL_VERIFY
NOTIF-PASSWORD_RESET	パスワード再設定要求	admin	○	admin	critical	email	TPL-PASSWORD_RESET
NOTIF-ADMIN_USER_REGISTER	管理者ユーザー登録	admin	○	admin	critical	email	TPL-ADMIN_USER_REGISTER
NOTIF-INQUIRY_CREATED	問い合わせ ID 発行	エンドユーザー	○	end_user	normal	email	TPL-INQUIRY_CREATED
NOTIF-CHAT_REPLY_TO_USER	admin 返信	エンドユーザー	○	end_user	normal	email	TPL-CHAT_REPLY_TO_USER
NOTIF-CHAT_REPLY_TO_STAFF	エンドユーザー投稿	admin	×	admin	normal	inbox/email	TPL-CHAT_REPLY_TO_STAFF
NOTIF-CHAT_HOLD_CHECK	最終投稿から 7 日経過 (段階 3)	admin	×	admin	normal	inbox	TPL-CHAT_HOLD_CHECK
NOTIF-CHAT_RESOLUTION_CHECK	admin 「利用者待ち」 判定 (段階 3)	エンドユーザー	○	end_user	normal	email	TPL-CHAT_RESOLUTION_CHECK
NOTIF-CHAT_FINAL_CONFIRM	段階 2 から 7 日 EU 投稿なし (段階 4)	エンドユーザー	○	end_user	normal	email	TPL-CHAT_FINAL_CONFIRM
NOTIF-CHAT_AUTO_CLOSED	段階 4 から 3 日経過 (段階 5)	エンドユーザー	○	end_user	normal	email	TPL-CHAT_AUTO_CLOSED
NOTIF-CHAT_CLOSED	チャット手動終了 (管理者操作)	エンドユーザー	○	end_user	normal	email	TPL-CHAT_CLOSED
NOTIF-FAQ_REGISTERED	FAQ 登録完了	エンドユーザー (関連 inquiry)	×	end_user	normal	email	TPL-FAQ_REGISTERED
NOTIF-DELETION_REMINDER	退会猶予期間案内	admin	○	admin	high	email	TPL-DELETION_REMINDER
NOTIF-BILLING_INVOICE_ISSUED	月次請求確定 (FR-148)	admin	○	admin	high	email	TPL-BILLING_INVOICE_ISSUED
NOTIF-BILLING_PAYMENT_FAILED	支払い失敗	admin	○	admin	high	email	TPL-BILLING_PAYMENT_FAILED
NOTIF-BILLING_SUSPENSION	サスペンション開始/解除	admin	○	admin	critical	email	TPL-BILLING_SUSPENSION
NOTIF-TRIAL_START	トライアル開始 (FR-129)	admin	○	admin	normal	email	TPL-TRIAL_START
NOTIF-TRIAL_3DAY	トライアル残 3 日	admin	○	admin	high	email	TPL-TRIAL_3DAY
NOTIF-TRIAL_END	トライアル終了 (+ サスペンション)	admin	○	admin	critical	email	TPL-TRIAL_END
NOTIF-SERVICE_ANNOUNCEMENT	運営からののお知らせ (連携イベント)	admin(範囲指定可)	配信時運営者選択	admin	normal/high/low/critical	inbox/email	TPL-SERVICE_ANNOUNCEMENT

通知 ID	契機	対象	強制送信	配信先	重要度	チャネル	テンプレート ID
NOTIF-TERMS_REVISION	規約改定告知 (発効 30 日前)	admin	○	admin	critical	email/inbox	TPL-TERMS_REVISION
NOTIF-SYSTEM_NOTICE	上限接近・超過等 (CR-149a)	admin	×	admin	normal/high	inbox/email	TPL-SYSTEM_NOTICE
NOTIF-LOCKOUT_NOTIFY	ログインロックアウト 発動 (FR-007)	ロック本人 + オーナー + users:manage 保持者	○	admin	critical	email	TPL-LOCKOUT_NOTIFY

7.6.2 6.2 通知テンプレート (§9.4 全件)

テンプレート ID	件名	本文必須項目	リンク	備考
TPL-EMAIL_VERIFY	メール確認をお願いします	確認リンク、有効期限 24h、不審リクエスト連絡先	確認 URL(24h)	-
TPL-PASSWORD_RESET	パスワード再設定のご案内	再設定リンク、有効期限 1h、覚えがない場合の案内	再設定 URL(1h)	-
TPL-PROJECT_CONFIRMATION	{プロジェクト名} のお問い合わせ先を確認してください	プロジェクト名、確認リンク、有効期限 24h、ウィジェット表示用に確認必須の旨	確認 URL(24h)	-
TPL-ADMIN_USER_REGISTER	open-faq の管理者ユーザー登録を完了しました	登録元オーナー、登録者名、有効期限 7 日	登録完了 URL(7d)	-
TPL-INQUIRY_CREATE	お問い合わせを受け付けました (問い合わせ ID: {inquiry_code})	問い合わせ ID、元質問抜粋、再入室 URL、保管期間 30 日	再入室 URL(30d)	-
TPL-CHAT_REPLY_TO_USER	お問い合わせに返信がありました	返信本文抜粋 (機密情報除く、200 字制限)、再入室 URL	再入室 URL	-
TPL-CHAT_AUTO_CLOSE	お問い合わせ {inquiry_code} を自動的にクローズしました	自動クローズの理由、再開希望時の連絡先	再開フォーム URL	-
TPL-BILLING_INVOICE_ISSUED	{年月} の請求書が発行されました (Webhook あり)	対象期間、請求金額、内訳 (質問数・チャット数・上限超過分)、明細 PDF リンク、SCR-015 deeplink	請求画面 URL	必須: PDF 明細を添付
TPL-TERMS_REVISION_EFFECTIVE	【重要】利用規約改定のお知らせ (発効日: {effective_date})	改定要約、新規約 URL、同意期限 (発効日 + 14 日)、機能制限ガード案内	SCR-025 deeplink	critical 重要度
TPL-SERVICE_ANNOUNCEMENT	(運営者入力)	運営者入力本文 (HTML sanitize 済)、関連リンク、配信元署名	運営者入力 URL	-
TPL-SYSTEM_NOTICE	(サブ契機ごとの定型文)	発火条件、対応方法、関連画面リンク	SCR-015 / SCR-016 等	-

7.6.3 6.3 通知メール共通要件

- 送信元 From: **noreply@<service-domain>** 固定、Reply-To なし
- メール末尾に「このメールに直接返信せず、お手数ですが問い合わせ画面または各プロジェクトのお問い合わせ先からご返信ください」案内を含める
- エンドユーザー入力 (質問本文等) は直接埋め込まない (FR-145)
- 引用時は HTML sanitize + 文字数制限 200 字 + サフィックスで明示
- HTML 版とテキスト版を両方生成
- 全テンプレートは i18n キー化、本文時刻表示は JST 固定 (NFR-1103)

7.7 7. 契約・課金関連メッセージ

メッセージ ID	利用箇所	表示文言	表示条件	関連エラー ID	重要度
MSG-BILL-CONTRACT-SUSPENDED	SCR-* 全画面	お支払いが確認できなかったため、一部機能を制限しています。	accounts.contract_status = suspended	MSG-BILL-CONTRACT-SUSPENDED	critical (初回)

メッセージ ID	利用箇所	表示文言	表示条件	関連エラー ID	重要度
MSG-QUOTA-QUESTIONS-80	SCR-015 / inbox	今月の質問数が無料枠の 80% に達しました。	80% 到達	-	normal
MSG-QUOTA-QUESTIONS-100	SCR-015 / inbox / email	今月の質問数が無料枠を超過しました。125% までは事後課金で継続利用できます。	100% 到達	E-QUOTA-QUESTIONS-100	high
MSG-QUOTA-FAQ-100	SCR-012 / inbox / email	FAQ 件数が上限に達したため、新規登録を停止しました。既存 FAQ の編集は可能です。	100% 到達	E-QUOTA-FAQ-100	high
MSG-QUOTA-CHAT-100	SCR-013 / inbox / email	個別チャット部屋数が上限に達したため、新規作成を停止しました。既存への返信は可能です。	100% 到達	E-QUOTA-CHAT-100	high
MSG-TRIAL-EXPIRING	SCR-015 / inbox / email	無料トライアルがあと N 日で終了します。	終了 3 日前	-	high
MSG-TRIAL-EXPIRED	SCR-015 / inbox / email	無料トライアルが終了し、サスペンション状態になりました。お支払い方法を登録してください。	終了日翌日 00:00 JST	E-TRIAL-EXPIRED	critical
MSG-BILL-DELETE-PENDING	SCR-*	退会申請を受け付けました。{cutoffDate} までサービスをご利用いただけます。	accounts.contract_status=deleted	high	high
MSG-BILL-DELETED	SCR-001	アカウントが削除されています	ログイン試行時	E-BILL-DELETED	-
MSG-BILL-PAYMENT-FAILED	SCR-015 / inbox / email	お支払いが確認できませんでした。{N} 日以内にお支払い方法を更新してください。	支払失敗イベント受信時	E-BILL-PAYMENT-FAILED	critical

7.8 8. エラー別メッセージ対応表

(エラー設計書 06 の全エラー ID に対するメッセージ ID の対応)

エラー ID	メッセージ ID	表示文言 (再掲)	補足
E-AUTH-CREDENTIAL	MSG-SCR-001-ERROR-001	(上記)	ログイン画面
E-AUTH-LOCKED	MSG-SCR-001-ERROR-003	(上記)	ログイン画面
E-AUTH-TOKEN-EXPIRED	MSG-SCR-003-ERROR-001	(上記)	再設定リンク無効
E-AUTHZ-FORBIDDEN	MSG-COMMON-AUTHZ-403	権限がありません (オーナーまたは権限保持者にご相談ください)	認可エラー統一
E-AUTHZ-OWNER-BOUNDARY	MSG-COMMON-NOT-FOUND	リソースが見つかりません	404 偽装
E-BIZ-CONTRACT-SUSPENDED	MSG-BILL-CONTRACT-SUSPENDED	(上記)	契約停止
E-QUOTA-*	MSG-QUOTA-*	(上記)	各上限到達
E-BILL-*	MSG-BILL-*/MSG-TRIAL-*	(上記)	課金エラー
(他多数)			

7.9 9. 未決事項

No	内容	確認先	期限	ステータス
1	多言語対応 (MVP 日本語のみ)	基本設計書 § 11.8	Future	既決 (04_ 将来拡張/01_ 将来要件定義書.md 参照)
2	エラー別メッセージ対応表 (§ 8) の全件埋め込み	エラー設計書 06	-	主要項目のみ初版収載

7.10 10. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

8 トレーサビリティマトリクス (メイン)

8.1 1. 文書概要

8.1.1 1.1 目的

メインシステムの要件 → 機能 → 画面 → API → DB → 権限 → エラー → メッセージ → テスト観点 の対応関係を一元化する。要件漏れ、設計漏れ、ID 不整合の機械検出を可能にする。

8.1.2 1.2 対象範囲

- 対象: メインシステムの全要件 (FR / NFR / BR / AC)、機能 (F-)、画面 (SCR-001~027)、API (API-)、テーブル (32 個)、権限フラグ 5 種、エラー ID (**E-***)、メッセージ ID (**MSG-***)
- 対象外: 運営者側要件 (02_ 運営者システム/個別設計書群/08_ トレーサビリティマトリクス.md 参照)

8.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

8.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_ 索引.md
要件定義書	要件 ID の正本	../01_ 要件定義書.md
画面設計書	SCR ID	02_ 画面設計書.md
API 設計書	API ID	03_ API 設計書.md
テーブル定義書	テーブル名	04_ テーブル定義書.md
権限設計書	権限フラグ	05_ 権限設計書.md
エラー設計書	エラー ID	06_ エラー設計書.md
メッセージ一覧	メッセージ ID	07_ メッセージ一覧.md
認証・認可設計書	認証フロー / 認可判定	09_ 認証認可設計書.md
セキュリティ設計書	セキュリティ対策	10_ セキュリティ設計書.md
課金・請求設計書	課金・契約	11_ 課金請求設計書.md
共有概念対応表	SCR ID / AC ID 体系の正本	../共有/共有概念.md
仕様同期検査.sh	自動整合チェック	../99_ スクリプト/仕様同期検査.sh

8.2 2. 要件・設計対応表 (主要 FR / NFR)

要件 ID	要件名	機能 ID	画面 ID	API ID	テーブル名	権限フラグ	エラー ID	メッセージ ID	契約/課金関連
FR-001	アカウント登録	F-AUTH-002	SCR-002	POST /auth/signup	accounts, terms_agreements	-	E-INPUT-*	MSG-SCR-002-*	トライアル開始
FR-002	ログイン	F-AUTH-001	SCR-001	POST /auth/login	accounts, sessions	-	E-AUTH-CREDENTIALS / E-AUTH-LOCKED	MSG-SCR-001-*	-
FR-003	メール確認	F-AUTH-004	SCR-023	POST /auth/email-verifications/{token}	accounts, access_tokens	-	E-AUTH-TOKEN-EXPIRED	MSG-SCR-023-*	-
FR-004	ログアウト / セッション管理	F-AUTH-001	(グローバル)	POST /auth/logout	sessions	-	E-AUTH-SESSION-EXPIRED	-	-
FR-005	重要操作の再認証	F-AUTH-005	(モジュール)	POST /auth/re-auth	sessions	-	E-AUTH-REAUTH-REQUIRED	-	-
FR-006	パスワード再設定	F-AUTH-003	SCR-003	POST /auth/password-reset-request, POST /auth/password/reset	accounts, access_tokens	-	E-AUTH-TOKEN-EXPIRED	MSG-SCR-003-*	-
FR-007	ログイン失敗ロックアウト (5 回/15 分)	F-AUTH-001	SCR-001	(グローバル)	accounts	-	E-AUTH-LOCKED	MSG-SCR-001-ERROR-003	-
FR-008	無操作 30 分 / 絶対 12 時間	F-AUTH-001	(グローバル)	(セッション middleware)	sessions	-	E-AUTH-SESSION-EXPIRED	-	-
FR-009	退会申請	F-ACC-002	SCR-024	POST /withdrawal-requests	withdrawal_requests, accounts	オーナー専有	E-BILL-*	MSG-SCR-024-*	退会フロー
FR-011	規約再同意	F-LEGAL-002	SCR-025	POST /terms/agree	terms_agreements	オーナー専有	E-LEGAL-*	MSG-SCR-025-*	-
FR-015a~d	メンバー権限管理	F-USER-001	SCR-017, SCR-017-M1	POST /members/*	accounts, account_permissions, account_project_grants	users:manage	E-AUTHZ-FORBIDDEN	MSG-SCR-017-*	-
FR-030~036	プロジェクト管理	F-PRJ-001	SCR-010, SCR-010-M1	POST/PATCH/DELETE /projects	projects, allowed_domains	project:manage	E-AUTHZ-FORBIDDEN	MSG-SCR-010-*	-
FR-040~046	FAQ 管理	F-FAQ-001	SCR-012	POST/PATCH/DELETE /faqs	faqs, faq_revisions, faq_search_fts	faq:manage	E-AUTHZ-FORBIDDEN / E-AUTHZ-PUBLISH	MSG-SCR-012-*	FAQ 件数上限
FR-049~052	AI 推論	F-AI-001	(ウィジェット)	POST /widget/v1/ask	question_logs, ai_threshold_persistent_cache	-	E-BIZ-EXT-AI-FAILED	-	-
FR-053	未解決質問登録	F-INQ-001	(ウィジェット)	POST /widget/v1/inquiries	inquiries, inquiry_contacts	-	-	-	-

要件 ID	要件名	機能 ID	画面 ID	API ID	テーブル名	権限 フラグ	エラー ID	メッセージ ID	契約/課金関連
FR-070~079	未解決質問対応	F-INQ-001	SCR-011	GET/PATCH /inquiries/*	inquiries, inquiry_status_history	chatroom	E-BIZ-CASE-CLOSED-AUTO	MSG-SCR-011-*	-
FR-079	case_status=closed の自動禁止	F-INQ-001	SCR-011 詳細	POST /inquiries/{id}/close	inquiries	-	E-BIZ-CASE-CLOSED-AUTO	-	-
FR-080~091	個別チャット	F-CHAT-001	SCR-013	POST /chat-rooms/{id}/*	chat_rooms, chat_messages	chatroom	E-BIZ-CHAT-RATE	MSG-SCR-013-*	-
FR-114	エラーログ PII / トークン除外	F-AUDIT-002	-	(全 API)	error_logs	-	-	-	-
FR-120~127	利用量・課金	F-BILL-001	SCR-015	GET /usage, GET /billing/invoices	usage_metering, billing_invoices	オーナー専有	E-QUOTA-*	MSG-SCR-015-*	月次集計
FR-122	80/100/125% 三段階 (質問数は拒否しない)	F-BILL-001	SCR-015	(各 API でレート判定)	usage_metering, owner_quota_overrides	-	E-QUOTA-*	MSG-QUOTA-*	課金
FR-124	支払い失敗時の利用制限	F-BILL-001	SCR-015	(IF #1 受信)	accounts.contract_status	-	E-BILL-PAYMENT-FAILED	MSG-BILL-PAYMENT-FAILED	サスペンション
FR-128	レート制限	F-WIDGET-001	-	(全 API)	owner_quota_overrides	-	E-QUOTA-*	-	契約上書き
FR-129	トライアル 14 日	F-BILL-001	SCR-015	(cron)	accounts.contract_status	-	E-BILL-TRIAL-EXPIRED	MSG-TRIAL-*	トライアル
FR-138	ウィジェット応答停止 (suspended)	F-WIDGET-001	(ウィジェット)	POST /widget/v1/*	accounts.contract_status	-	E-BIZ-WIDGET-SUSPENDED	-	サスペンション
FR-145	エンドユーザー入力をメール件名・本文に使わない	F-NOTIF-001	-	(メール配信 worker)	notification_logs	-	-	-	-
FR-149 / FR-149b	お知らせ配信 + 全契約横断サプレス	F-NOTIF-001	SCR-021, SCR-022	GET /me/announcements	service_announcements, inbox_messages, email_suppression_list	-	-	MSG-SCR-021-, MSG-SCR-022-	-
FR-150~156	ウィジェット設定	F-WIDGET-001	SCR-014	POST /projects/{id}/widget/key/rotate	projects, project_legacy_keys, allowed_domains	projectmanage	E-INPUT-DOMAIN	MSG-SCR-014-*	-
FR-177	Turnstile(CAPTCHA)	F-AUTH-001	SCR-001, SCR-002, SCR-003	(Turnstile middleware)	-	-	E-INPUT-TURNSTILE	-	-
FR-178	不正アクセス検知	F-AUDIT-003	-	-	audit_logs	-	-	-	-
FR-179	IP 許可リスト	F-ACC-001	SCR-016	PATCH /account-settings/ip-allowlist	accounts.notification_preferences	オーナー専有	-	MSG-SCR-016-*	-

要件 ID	要件名	機能 ID	画面 ID	API ID	テーブル名	権限フラグ	エラー ID	メッセージ ID	契約/課金関連
FR-180~183	お知らせ受信箱	F-NOTIF-002	SCR-021, SCR-022	GET/POST /me/announcements/ announcement_recipients	inbox_messages, announcement_recipients	-	-	MSG-SCR-021-*	-
FR-195	不正利用検知	F-SEC-001	-	(IF #9 送信)	audit_logs	-	E-BIZ-*	-	-
FR-220~232	運営者責務 / 監査	(運営者側)	-	-	-	-	-	-	-
FR-302	Stripe Webhook 受信	(運営者側 §13)	-	(運営者 API)	(webhook_events, 運営者側)	-	E-OP-WEBHOOK-*	-	-
FR-333	オーナー保護	F-USER-001	SCR-017-M1	POST /members/*	accounts.is_owner=1	-	E-AUTHZ-OWNER-PROTECTED	-	-
FR-334	自己操作不可	F-USER-001	SCR-017-M1	同上	-	-	E-AUTHZ-SELF-MUTATION	-	-

8.3 3. 機能・画面・API 対応表

機能 ID	機能名	画面 ID	API ID	テーブル名
F-AUTH-001	ログイン / セッション / 強制ログアウト	SCR-001	POST /auth/login, POST /auth/logout, POST /auth/re-auth	accounts, sessions
F-AUTH-002	アカウント登録	SCR-002	POST /auth/signup	accounts, terms_agreements
F-AUTH-003	パスワード再設定	SCR-003	POST /auth/password-reset-request, POST /auth/password/reset	accounts, access_tokens
F-AUTH-004	メール確認	SCR-023	POST /auth/email-verifications/{token}	accounts, access_tokens
F-PRJ-001	プロジェクト管理	SCR-010, SCR-010-M1	GET/POST/PATCH/DELETE /projects	projects, allowed_domains
F-INQ-001	未解決質問	SCR-011	GET/PATCH /inquiries, POST /inquiries/{id}/close, POST /inquiries/{id}/draft-faq	inquiries, inquiry_status_history, inquiry_contacts, question_logs
F-FAQ-001	FAQ 管理	SCR-012	GET/POST/PATCH/DELETE /faqs, POST /faqs/{id}/publish, POST /faqs/import	faqs, faq_revisions, faq_search_fts
F-CHAT-001	個別チャット (管理者)	SCR-013(管理側)	GET/POST /chat-rooms/{id}/messages, POST /chat-rooms/{id}/close, POST /chat-rooms/{id}/reopen	chat_rooms, chat_messages
F-WIDGET-001	ウィジェット設定	SCR-014	POST /projects/{id}/widget-key/rotate	projects, project_legacy_keys, allowed_domains
F-WIDGET-002	ウィジェット動作	(ウィジェット)	POST /widget/v1/bootstrap, POST /widget/v1/ask, POST /widget/v1/inquiries, POST /widget/v1/chat-rooms/{id}/messages	question_logs, inquiries, chat_rooms

機能 ID	機能名	画面 ID	API ID	テーブル名
F-BILL-001	利用量・課金	SCR-015	GET /usage, GET /billing/invoices, PATCH /billing/monthly-budget-limit	usage_metering, billing_invoices, billing_subscriptions
F-ACC-001	設定	SCR-016	(各種 API)	accounts
F-ACC-002	退会申請	SCR-024	POST /withdrawal-requests	withdrawal_requests, accounts
F-USER-001	ユーザー管理	SCR-017, SCR-017-M1	GET /members, POST /members/invite, POST/PATCH /members/{id}/*	accounts, account_permissions, account_project_grants
F-LEGAL-001	規約閲覧	SCR-018	GET /terms/current	terms_versions
F-LEGAL-002	規約再同意	SCR-025	POST /terms/agree	terms_agreements
F-NOTIF-001	通知配信	(各画面)	(Queue 経由)	notification_logs, email_suppression_list
F-NOTIF-002	お知らせ受信箱	SCR-021, SCR-022	GET /me/announcements, POST /me/announcements/{id}/read	inbox_messages, service_announcements, announcement_recipients
F-WIDGET-EU-RE	エンドユーザー再入室	SCR-027	GET /widget/sessions/:token	access_tokens, chat_rooms
F-AI-001	AI 推論	(ウィジェット)	POST /widget/v1/ask(内部 Answer-Provider IF)	question_logs, ai_threshold_persistent_cache
F-AUDIT-001	監査ログ	(グローバル)	-	audit_logs
F-AUDIT-002	エラーログ	(グローバル)	-	error_logs
F-SEC-001	不正利用検知	(グローバル)	POST /internal/main-integration/v1/fraud/detected(IF #9)	audit_logs

8.4 4. 画面・メッセージ対応表 (主要)

画面 ID	画面名	主要メッセージ ID	種別
SCR-001	ログイン	MSG-SCR-001-TITLE-001 / LBL-001-002 / BTN-001 / ERROR-001-003	TITLE/LBL/BTN/ERROR
SCR-002	新規登録	MSG-SCR-002-TITLE-001 / LBL-001-006 / BTN-001	TITLE/LBL/BTN
SCR-003	パスワード再設定	MSG-SCR-003-TITLE-001-003 / STEP-001-003 / BTN-001-002 / ERROR-001 / SUCCESS-001	TITLE/STEP/BTN/ERROR/SUCCESS
SCR-010	プロジェクト一覧	MSG-SCR-010-TITLE-001 / DESC-001 / BTN-001 / CONFIRM_*-001 / TOAST-001 / EMPTY-001	12 メッセージ
SCR-010-M1	プロジェクト設定モデル	MSG-SCR-010-M1-*	17 メッセージ
SCR-011	未解決質問	MSG-SCR-011-*	11 メッセージ

画面 ID	画面名	主要メッセージ ID	種別
SCR-012	FAQ 管理	MSG-SCR-012-*	17 メッセージ
SCR-013	個別チャット	MSG-SCR-013-*	14 メッセージ
SCR-014	ウィジェット設定	MSG-SCR-014-*	9 メッセージ
SCR-015	利用状況・課金	MSG-SCR-015-*	10 メッセージ
SCR-016	設定	MSG-SCR-016-*	9 メッセージ
SCR-017	ユーザー管理	MSG-SCR-017-*	15 メッセージ
SCR-017-M1	メンバー招待 / 編集	MSG-SCR-017-M1-*	12 メッセージ
SCR-018	規約閲覧	MSG-SCR-018-*	7 メッセージ
SCR-021	お知らせ一覧	MSG-SCR-021-*	10 メッセージ
SCR-022	お知らせ詳細	MSG-SCR-022-*	6 メッセージ
SCR-023	メール確認	MSG-SCR-023-*	13 メッセージ
SCR-024	退会申請	MSG-SCR-024-*	13 メッセージ
SCR-025	規約再同意	MSG-SCR-025-*	16 メッセージ
SCR-027	EU 再入室	MSG-SCR-027-*	15 メッセージ

詳細は [07_メッセージ一覧.md § 4](#) を正本とする。

8.5 5. API・エラー対応表

API	エラー ID	メッセージ ID	ステータスコード
POST /auth/login	E-AUTH-CREDENTIAL	MSG-SCR-001-ERROR-001	401
POST /auth/login	E-AUTH-LOCKED	MSG-SCR-001-ERROR-003	423
POST /auth/login	E-BIZ-CONTRACT-SUSPENDED	MSG-BILL-CONTRACT-SUSPENDED	403
POST /auth/password/reset	E-AUTH-TOKEN-EXPIRED	MSG-SCR-003-ERROR-001	410
POST /faqs/{id}/publish	E-BIZ-FAQ-PUBLISH	-	422
POST /inquiries/{id}/close	(admin の明示操作のみ)	-	(FR-079)
POST /widget/v1/ask	E-EXT-AI-FAILED	-	503
POST /widget/v1/ask	E-BIZ-AI-CONFIDENCE	-	200(業務分岐 D)
POST /widget/v1/inquiries	E-INPUT-*	-	400
POST /chat-rooms/{id}/messages	E-BIZ-CHAT-RATE	-	429
GET /usage / GET /billing/invoices	E-AUTHZ-OWNER-ONLY	MSG-COMMON-OWNER-ONLY	403
POST /members/invite	E-AUTHZ-FORBIDDEN	MSG-COMMON-AUTHZ-403	403

API	エラー ID	メッセージ ID	ステータスコード
POST /members/{id}/permissions	E-AUTHZ-OWNER-PROTECTED	MSG-COMMON-OWNER-PROTECTED	403
POST /withdrawal-requests	E-AUTHZ-OWNER-ONLY	-	403
(全 API)	E-AUTHZ-OWNER-BOUNDARY	MSG-COMMON-NOT-FOUND	404 偽装
(全 API、月次無料枠 100%)	E-BIZ-QUOTA-EXCEEDED	MSG-QUOTA-*	429
(全 API、契約停止中)	E-BIZ-CONTRACT-SUSPENDED	MSG-BILL-CONTRACT-SUSPENDED	403
(Resend Webhook)	E-WH-SIGNATURE-INVALID	-	401 + 監査 + high alert
IF #1 受信	E-IF-001-*	-	200 / 401 / 409
IF #10 受信	E-IF-010-*	-	200 / 401

詳細は [06_エラー設計書.md](#) と [07_メッセージ一覧.md § 8](#) を正本とする。

8.6 6. 権限・画面・API 対応表

権限フラグ	ロール	主要画面 ID	主要 API ID	操作可否
(オーナーのみ)	OWNER	SCR-015 / SCR-016 / SCR-024 / SCR-025 同意	GET /usage / POST /withdrawal-requests / POST /terms/agree	オーナー専有
faq:manage	MEMBER / OWNER	SCR-012	POST/PATCH/DELETE /faqs	編集可
chat:respond	MEMBER / OWNER	SCR-011, SCR-013	PATCH /inquiries/{id}, POST /chat-rooms/{id}/messages	返信可
users:manage	MEMBER / OWNER	SCR-017, SCR-017-M1	POST /members/*	招待 / 編集可
project:manage	MEMBER / OWNER	SCR-010, SCR-010-M1, SCR-014	POST/PATCH/DELETE /projects, POST /projects/{id}/widget-key/rotate	プロジェクト管理可
logs:view	MEMBER / OWNER	SCR-015(監査参照部)	(Future)	監査ログ閲覧可
(権限不要)	END_USER	SCR-027	GET /widget/sessions/:token	エンドユーザー

詳細は [05_権限設計書.md § 4-6](#) を正本とする。

8.7 7. 契約上書き × 機能対応表 (プラン別利用制限の代替)

MVP は単一プランのため、プラン階層対応表ではなく **契約別上書き × 機能対応表**。

契約上書きテーブル (owner_quota_overrides.reso)	機能 ID	影響対象	上書き可能項目	主管 SCR
widget_ask_per_min	F-WIDGET-002 / F-AI-001	ウィジェット 質問レート	RPS / RPM	SCR-093(運営者)
widget_inquiry_per_min	F-INQ-001	未解決質問送信レート	同上	SCR-093
widget_chat_per_min	F-CHAT-001	チャット投稿レート (EU)	同上	SCR-093
email_per_hour	F-NOTIF-001	メール送信レート	件数/時間	SCR-093

契約上書きテーブル (owner_quota_overrides.reso)	機能 ID	影響対象	上書き可能項目	主管 SCR
admin_api_per_min	F-AUTH-*/F-PRJ-*/F-FAQ-*等	管理 API レート	RPS / RPM	SCR-093
(月次無料枠 = 1,000 件 / 100 FAQ / 30 チャット部屋)	F-BILL-001	月次無料枠	(運営者側で別管理予定 / 現状 owner_quota_overrides で吸収)	SCR-093
(月次予算上限 = 円)	F-BILL-001	予算上限	円 / 月	SCR-093

詳細は 11_課金請求設計書.md §3 を参照。

8.8 8. テスト観点との対応 (基本設計書 §14 を吸収)

8.8.1 8.1 テスト観点 6 列の定義

列	観点	説明
正常系	ハッピーパス	標準ユースケースの動作確認
異常系	エラーパス	エラー設計書 06 の各エラーが正しく発火するか
境界値	上限・下限	入力長 / レート / 件数の境界での挙動
権限	認可テスト	権限フラグ未保持時の 403 / オーナー境界違反時の 404 偽装
オーナー境界	データ分離自動テスト (基本設計書 §14.3、月次 50 ケース)	契約 A のリソースに契約 B からアクセスして 404 が返ることを全 API で検証
契約上限・課金	80/100/125% 三段階 / contract_status 遷移	月次無料枠到達時の挙動、contract_status 各状態での操作可否

8.8.2 8.2 主要要件のテスト観点表

要件 ID	機能 ID	正常系	異常系	境界値	権限	オーナー境界	契約上限・課金
FR-007(ロックアウト)	F-AUTH-001	5 回未満で正常ログイン	5 回失敗で 423	4 回 → 5 回境界	-	-	-
FR-079(case_status=closed 自動禁止)	F-FAQ-001	admin 明示操作で closed	自動 retention で closed 試行で 422	-	admin 必須	-	-
FR-122(80/100/125%)	F-BILL-001	79% で通常	100% 質問数: 200 / FAQ: 429 / チャット: 429	79 / 80 / 100 / 125%	オーナー専有	-	全種別
FR-124(支払い失敗時の利用制限)	F-BILL-001	通常時 active	suspended 中は 403(課金 / 退会 / エクスポート以外)	7 日猶予境界	オーナー専有	-	サスペンション
FR-129(トライアル 14 日)	F-BILL-001	トライアル中は無料	14 日翌日 00:00 サスペンション	13 / 14 / 15 日	オーナー専有	-	トライアル
FR-138(ウィジェット応答停止)	F-WIDGET-001	active で応答	suspended で 423	-	-	-	サスペンション
FR-333(オーナー保護)	F-USER-001	オーナー以外を停止	オーナー停止試行で 403	-	-	-	-
FR-334(自己操作不可)	F-USER-001	他メンバー編集	自分自身の users:manage 剥奪試行で 403	-	-	-	-
(オーナー境界、AC-017)	(全機能)	自契約リソース	他契約リソース参照で 404 偽装	-	-	全 API、月次 50 ケース	-

要件 ID	機能 ID	正常系	異常系	境界値	権限	オーナー境界	契約上限・課金
AC-019 × AC-035(プロンプト注入)	F-AI-001	通常質問	注入試行で安全側に倒す	-	-	-	-
FR-149b(全契約横断サプレス)	F-NOTIF-001	サプレス前は配信	サプレス後は配信停止	-	-	-	-

8.9 9. 不足・不整合一覧 (仕様同期検査.sh と同型)

99_ スクリプト/仕様同期検査.sh の出力フォーマットと同型で機械処理可能とする。

No	種別	対象 ID	内容	影響	推奨対応
1	DB 未定義	owner_registration_reviews / webhook_replay_requests / pii_rules_revisions	運営者側基本設計のみ言及、詳細設計に DDL なし	正式定義待ち	運営者側 04_ テーブル定義書.md §12 未決事項 参照
2	DB 内容不整合	inquiries.case_status	詳細設計書 DDL に CHECK 制約欠落	データ整合性リスク	テーブル定義書 04 §3.13 で補正済、詳細設計反映待ち

種別: 要件未対応 / 画面未定義 / API 未定義 / DB 未定義 / 権限未定義 / エラー未定義 / メッセージ未定義 / 認証未定義 / セキュリティ未定義 / 契約上書き未定義 / 課金未定義 / ID 不一致 / 内容不整合 / 要確認

8.10 10. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------

8.11 11. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

9 認証・認可設計書 (メイン)

9.1 1. 文書概要

9.1.1 1.1 目的

メインシステムの認証(ログイン/ログアウト/パスワード再設定/招待受諾/規約再同意/メール確認)、セッション・トークン、認可モデル(オーナー境界判定/Principal 構築)、認可判定ルール、アカウント状態、認証・認可エラーを一元化する。

9.1.2 1.2 対象範囲

- 対象: 利用者(オーナー/メンバー/エンドユーザー)の認証・認可全般
- 対象外: 運営者の認証・認可(MFA/IP allowlist/4-eyes は [02_運営者システム/個別設計書群/09_認証認可設計書.md](#) 正本)、エンドユーザーのウィジェット内認証詳細は API 設計書(03)に委譲

9.1.3 1.3 版数

項目	値
版数	1.0

項目	値
更新日	2026-05-17

9.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_ 索引.md
権限設計書	権限フラグ / 画面別権限	05_ 権限設計書.md
セキュリティ設計書	Argon2id / HMAC / 監査 / Cookie 属性	10_ セキュリティ設計書.md
API 設計書	認証 API 仕様	03_API 設計書.md
エラー設計書	認証・認可エラー	06_ エラー設計書.md
メッセージ一覧	通知重要度 / critical メール強制送信	07_ メッセージ一覧.md
テーブル定義書	accounts / sessions / terms_agreements	04_ テーブル定義書.md
課金・請求設計書	サスペンション時のアクセス制限	11_ 課金請求設計書.md
運営者側 認証・認可設計書	IP allowlist(契約単位オプトインの参照元)	../02_ 運営者システム/個別設計書群/09_ 認証認可設計書.md

9.2 2. 認証方式

認証方式	利用有無	概要	備考
メールアドレス / パスワード	○	メイン 認証方式 (Argon2id m=64MB, t=3, p=4, salt=16B)	パスワード要件は § 4
Google ログイン	×	MVP 範囲外	Future
SSO / SAML	×	MVP 範囲外	Future
OAuth / OIDC	×	MVP 範囲外	Future
MFA(利用者側 admin)	×(MVP 受容)	MVP では admin にも MFA 必須化しない	§ 10 でリスク受容、Future 移行
招待トークン	○	メンバー招待時に短期トークンで初回パスワード設定	§ 3.4
パスワード再設定トークン	○	メール経由の短期トークン(有効期限 1 時間)	§ 3.3
規約再同意	○	規約改定時に割込みフロー (SCR-025)	§ 3.5
メール確認	○	新規登録後の本人確認 (SCR-023)	§ 3.6
ウィジェット再入室トークン	○	エンドユーザー再入室用(有効期限 30 日)	§ 3.7
Turnstile(reCAPTCHA 相当)	○	アカウント単位 3 回失敗 または 同一 IP 1 分 10 回失敗で発動 (FR-177)	§ 10.1

9.3 3. 認証フロー

フロー ID	フロー名	概要	関連画面 ID	関連 API ID
AUTH-FLOW-001	ログイン	メール + パスワード	SCR-001	POST /auth/login
AUTH-FLOW-002	ログアウト	セッション削除	(グローバル)	POST /auth/logout
AUTH-FLOW-003	パスワード再設定	メール経由トークン	SCR-003	POST /auth/password-reset-request, POST /auth/password/reset
AUTH-FLOW-004	招待受諾	招待トークン + 初回パスワード	SCR-017-M1 → SCR-001 派生	POST /invitations/:token/accept

フロー ID	フロー名	概要	関連画面 ID	関連 API ID
AUTH-FLOW-005	規約再同意	規約改定時の割込み	SCR-025	POST /terms/agree
AUTH-FLOW-006	メール確認	新規登録後のメール確認	SCR-023	POST /auth/email-verifications/{token}
AUTH-FLOW-007	エンドユーザー再入室	アクセストークン経由	SCR-027	GET /widget/sessions/:token
AUTH-FLOW-008	強制ログアウト (連携 IF #2)	運営者起動	(グローバル)	(IF #2 受信)

9.3.1 3.1 ログイン (AUTH-FLOW-001)

1. メール+パスワード入力 → Turnstile 検証 (FR-177 発動時)
2. Argon2id 検証 → **sessions** レコード作成 + Cookie 発行
3. 規約再同意状態確認 → 未同意なら SCR-025 へリダイレクト
4. 契約状態確認 (**accounts.contract_status**) → **suspended** で許可機能外なら 403、**deleted** なら 403
5. SCR-015 ダッシュボードへ

エラー: 401 **INVALID_CREDENTIALS**(E-AUTH-CREDENTIAL)、423 **LOCKED_OUT**(E-AUTH-LOCKED)、403 **CONTRACT_SUSPENDED**

9.3.2 3.2 ログアウト

セッション失効 + Cookie 削除。SCR-001 へ。

9.3.3 3.3 パスワード再設定 (AUTH-FLOW-003)

1. SCR-003 段階 1: メール入力 → **POST /auth/password-reset-request**(列挙攻撃対策で存在有無を返さない)
2. メール送信 (**access_tokens.purpose='password_reset'**、HMAC-SHA256、有効期限 1 時間、1 回限り、FR-006)
3. SCR-003 段階 2: トークン検証 + 新パスワード入力 → **POST /auth/password/reset**
4. 全セッション失効 → SCR-001 へ

9.3.4 3.4 招待受諾 (AUTH-FLOW-004)

1. SCR-017-M1 から **POST /members/invite** → 招待メール送信 (**access_tokens.purpose='activation'**、有効期限 7 日、FR-016)
2. メール内リンク → 初回パスワード設定画面 → **POST /invitations/:token/accept**
3. **accounts.status='active'** + 全権限フラグ + プロジェクト割当を反映
4. SCR-001 へ

9.3.5 3.5 規約再同意 (AUTH-FLOW-005)

1. ログイン直後に未同意があれば SCR-025 強制割込み
2. 規約 + プライバシーポリシー同意 (両必須) → **POST /terms/agree**
3. **terms_agreements** レコード作成
4. 同意期限超過後の機能制限ガード: 課金画面操作 + 新規プロジェクト作成は不可、FAQ 編集とウィジェット稼働は継続

9.3.6 3.6 メール確認 (AUTH-FLOW-006)

1. SCR-002 新規登録 → 確認メール送信 (**access_tokens.purpose='email_verify'**、有効期限 24 時間)
2. メール内リンク → **POST /auth/email-verifications/{token}**
3. **accounts.email_verified_at** 設定 → SCR-001 へ

9.3.7 3.7 エンドユーザー再入室 (AUTH-FLOW-007)

1. 案件メール内リンク → SCR-027
2. トークン形式: 不透明文字列 + HMAC-SHA256(オーナー派生、`access_tokens.purpose='reentry'`、有効期限 30 日)
3. トークン検証 → `inquiry_id` 復号 → SCR-013 個別チャット部屋へ
4. 期限切れ時は新リンクをメールで再送可能

9.3.8 3.8 強制ログアウト (AUTH-FLOW-008)

連携 IF #2 受信時、`operator_manual / tos_violation` の場合は **5 秒以内** に全セッション無効化 (FR-022)。
`payment_failure_grace_expired` 等は既存セッション継続。

9.4 4. セッション・トークン設計

項目	内容
セッション方式	Cookie + DB セッション (sessions テーブル)
無操作タイムアウト	30 分 (FR-008(a))
絶対タイムアウト	12 時間 (FR-008(b))
再認証 (FR-005)	重要操作前に要求 (パスワード変更 / 退会 / 課金情報変更 / 管理者ユーザー登録・停止・削除 / 月次予算上限変更)。有効期間 = 当該操作 1 回のみかつ 15 分以内
Cookie 属性	Secure; HttpOnly; SameSite=Lax; Path=/、Domain 明示せず
CSRF	Double Submit Cookie + X-CSRF-Token ヘッダ突合
パスワードハッシュ	Argon2id(admin/end_user: m=64MB, t=3, p=4, salt=16B)
HMAC	HMAC-SHA256(各種トークン署名)
ログイン失敗ロックアウト	5 回失敗 → (IP × user_id) を 15 分ロック (FR-007 / FR-177)
強制ログアウト	連携 IF #2 受信時、アクセストークン全失効 (5 秒以内)
アクティブセッション一覧	SCR-001 ログイン後にユーザーメニューから表示可能 (FR-332)
複数デバイス同時ログイン	可能 (FR-332)

9.4.1 4.1 トークン用途別仕様 (§10.1.3 から移管)

用途	鍵	トークン形式	有効期限
登録完了トークン	オーナー派生	不透明文字列 + HMAC	7 日
再入室トークン	オーナー派生	不透明文字列 + HMAC + <code>inquiry_id</code> 内包	30 日
削除確認トークン	オーナー派生	不透明文字列 + HMAC	24 時間
パスワードリセットトークン	グローバル派生	不透明文字列 + HMAC	1 時間
API キー (ウィジェット公開キー)	グローバル派生	<code>pk_live_<32-char base62></code>	7 / 30 / 90 / 180 / 365 日 選択

9.4.2 4.2 Cookie 属性 (§10.1.4)

Cookie 種別	属性
メインシステム セッション Cookie	Secure; HttpOnly; SameSite=Lax; Path=/、Domain 明示せず
CSRF Cookie	Secure; SameSite=Lax; Path=/(HttpOnly なし、JS から読取可)

9.5 5. 認可モデル

9.5.1 5.1 認可方式

ロールベース (`admin / service_operator / end_user`) + メンバー権限フラグ (`faq:manage` 等) + プロジェクト割当 (`account_project_grants`)

9.5.2 5.2 オーナー境界判定式 (共有概念正本)

すべての操作で以下の判定式を必須:

`actor.owner_account_id == target.owner_account_id`

- **actor** = 操作するアカウント (セッションから取得)
- **target** = 操作対象リソース (テーブルの **owner_account_id** カラム)
- 一致しない場合は **404 偽装** (403 を返すと相手契約の存在が漏れる、エラー設計書 06 §5.3)

9.5.3 5.3 ユーザー種別の DB 値 (§3.1 から移管)

ユーザー種別	DB 値	概要
オーナーアカウント	<code>accounts.role='admin' AND accounts.is_owner=1 AND accounts.owner_account_id = accounts.id(自己参照)</code>	契約あたり 1 オーナー固定。全権 + オーナー専有機能
メンバーアカウント	<code>accounts.role='admin' AND accounts.is_owner=0 AND accounts.owner_account_id に所属オーナーの id</code>	権限フラグ + プロジェクト割当てで操作範囲が決まる
エンドユーザー	<code>accounts.role='end_user'</code>	自分の問い合わせ ID に紐づくチャットのみ
サービス運営者	<code>accounts.role='service_operator'</code>	本 SaaS 提供者 (運営者側)

accounts.role 値域: `admin / service_operator / end_user` の 3 値固定 **accounts.is_owner** 値域: `0 / 1`
accounts.contract_status 値域: `active / suspended / deleted_pending / deleted` の 4 値固定 (オーナー行のみ意味を持つ)

9.5.4 5.4 オーナー専有機能

メンバーには **account_permissions** で付与不可な機能:

- 課金 (SCR-015 の月次予算変更 / 支払い方法変更)
- 退会 (SCR-024)
- 規約再同意 (SCR-025 の同意 / 不同意)

UI 上は非表示 + API は 403。

9.5.5 5.5 プラン制限との関係

MVP は単一プラン。契約別利用上書き (**owner_quota_overrides** の **resource_kind** で統一実装) は認可判定の **次段** で適用される (まず認可 → 通過したら上限チェック → 通過したら処理実行)。詳細は [11_課金請求設計書.md §3](#) 参照。

9.6 6. 認可判定ルール

9.6.1 6.1 Principal 構築フロー (§3.3.1 から移管)

9.6.1.1 Principal オブジェクト構造

```
Principal {
  accountId:      string
  ownerAccountId: string // accounts.owner_account_id(オーナー行は自己参照)
  role:           'admin' | 'service_operator' | 'end_user'
  isOwner:        boolean // accounts.is_owner = 1
  permissions:    Set<'faq:manage' | 'chat:respond' | 'users:manage' | 'project:manage' | 'logs'>
  projectGrants:  Set<string> // 空 Set かつ isOwner=true は全プロジェクト可
}
```

9.6.1.2 認可ミドルウェア実装

- リクエスト毎に **accounts** と **account_permissions** と **account_project_grants** を 1 クエリで結合
- 認可判定ヘルパ:
 - `requirePermission(kind): principal.isOwner || principal.permissions.has(kind)`
 - `requireProjectAccess(projectId): principal.isOwner || principal.projectGrants.has(projectId)`
- Principal: KV キャッシュ (TTL 60 秒) 経由で読み取り
- 権限変更時の即時反映よりも認可レイテンシ最適化を優先 (FR-338)

9.6.2 6.2 認可判定の順序

1. セッション検証 (sessions テーブル参照、無操作 30 分 / 絶対 12 時間)—— 失敗 → 401
2. 規約再同意状態確認 (terms_agreements 最新版)—— 未同意 → SCR-025 ヘリダイレクト
3. 契約状態確認 (accounts.contract_status、オーナー行)—— **suspended** で許可機能外なら 403、**deleted_pending / deleted** なら 403
4. アカウント状態確認 (accounts.status='active')—— **disabled** なら 403
5. オーナー境界判定 (actor.owner_account_id == target.owner_account_id)—— 違反 → **404 偽装**
6. プロジェクト境界判定 (新規):
 - ・ principal.isOwner=true のとき自オーナー配下の全プロジェクトに無条件アクセス可
 - ・ isOwner=false(メンバー) のとき対象 project_id が principal.projectGrants に含まれていること
 - ・ 違反 → 403(PROJECT_ACCESS_DENIED)
7. オーナー専有機能判定 (is_owner=0 で課金 / 退会 / 規約再同意にアクセス)—— 違反 → 403
8. メンバー権限フラグ判定 (account_permissions に必要フラグ存在)—— 不足 → 403
9. 再認証判定 (重要操作の場合、FR-005)—— 5 分以内 + 1 回限り、未保持なら 403
10. inquiry 境界判定 (end_user の場合)—— 再入室トークンが紐づく inquiry_id のみアクセス可
11. 契約別利用上限判定 (owner_quota_overrides)—— 上限到達 → 429 + Retry-After

9.6.3 6.3 critical 通知の宛先解決 (共有概念正本)

critical 重要度の通知 = メール強制送信。送信先は以下のクエリで解決:

```
SELECT a.id, a.email_encrypted, a.email_hmac
FROM accounts a
WHERE a.owner_account_id = :owner
      AND a.status = 'active'
      AND (
        a.is_owner = 1
        OR EXISTS (
          SELECT 1 FROM account_permissions ap
          WHERE ap.account_id = a.id AND ap.permission_kind = 'users:manage'
        )
      )
```

詳細は [07_メッセージ一覧.md § 2.4](#) も参照。

9.6.4 6.4 重要操作の再認証 (FR-005)

重要操作	関連画面	API
パスワード変更	(グローバル)	POST /auth/password/change
退会申請	SCR-024	POST /withdrawal-requests
課金情報変更	SCR-015	PATCH /billing/payment-method
メンバー招待 / 編集 / 停止 / 削除 / 強制ログアウト	SCR-017-M1	POST /members/*
月次予算上限変更	SCR-015	PATCH /billing/monthly-budget-limit
プロジェクト削除	SCR-010	DELETE /projects/{id}
ウィジェット ローテーション	SCR-014	POST /projects/{id}/widget-key/rotate
FAQ 削除	SCR-012	DELETE /faqs/{id}
IP 許可リスト変更	SCR-016	PATCH /account-settings/ip-allowlist

有効期間: 当該操作 1 回のみかつ 15 分以内

9.6.5 6.5 オーナー保護 (FR-333)/ 自己操作不可 (FR-334)/ 単一オーナー所属 (FR-335)

ルール	内容
オーナー保護	オーナー (is_owner=1) に対する停止・削除・降格・is_owner=0 への変更操作はすべて 403。1 アカウント = 1 オーナー
自己操作不可	自分自身の利用状態変更・削除・権限フラグ剥奪・プロジェクト割当変更は API 403。特に users:manage の自己剥奪は不可
単一オーナー所属	同一メールでも別オーナー配下は別アカウントとして扱う

9.7 7. アカウント状態

状態	説明	ログイン可否	操作制限
有効	accounts.contract_status='active' + アカウント自体が status='active'	○	なし
招待中	status='pending_activation'(招待トークン送信済、未受諾)	×	招待トークンで初回パスワード設定のみ
メール未確認	status='pending_verification'	△(SCR-023のみ)	メール確認のみ
停止中(契約)	accounts.contract_status='suspended'	○(オーナーのみ)	課金画面 / 退会画面 / データエクスポート画面のみ
ロック中	ログイン失敗 5 回	×(15 分間)	-
退会申請中(契約)	accounts.contract_status='deleted_pending'	△(オーナーのみ)	データエクスポート + 退会キャンセル
退会済み(契約)	accounts.contract_status='deleted'	×	-
無効化	status='disabled'(メンバーの停止)	×	-

9.7.1 7.1 サスペンション中の認可ゲート (§6.2.7 から移管)

accounts.contract_status='suspended' 中(オーナー行):

操作	認可
課金画面 (SCR-015)	許可
データエクスポート画面	許可
退会画面 (SCR-024)	許可
その他	403
ウィジェット応答	423(FR-138)

reason 別のセッション扱い:

- ・ operator_manual / tos_violation: 5 秒以内に全セッション無効化 (FR-022)
- ・ payment_failure_grace_expired / trial_expired_no_payment_method: 既存セッション継続 (課金 / エクスポート / 退会のみ)

解除条件: 顧客管理側の連携 IF #1 受信 (支払い成功 / 運営者解除) で accounts.contract_status='active'(オーナー行)へ。

9.7.2 7.2 退会・解約フロー (§6.2.8 から移管)

admin が SCR-024 で退会申請

- 再認証 FR-005
- accounts.contract_status='deleted_pending'(オーナー行)
- ウィジェット応答停止、新規 FAQ 登録不可
- 当月末まで利用可
- 月末締めで利用停止(月割りなし)
- 30 日エクスポート猶予開始
- 物理削除バッチ実行: accounts.contract_status='deleted'(オーナー行)
- 全データ削除 + announcement_recipients 削除

詳細は [11_課金請求設計書.md §5](#) 参照。

9.7.3 7.3 規約改定フロー (§6.2.9 から移管)

運営者が新規約を準備

- 発効 30 日前: `inbox(announcement/critical)+ メール + ステータスページ`
- 契約単位で段階的に発効(全契約同日強制ではない)
- 新規約発効
- ログイン時に同意状況チェック
 - └ Yes(同意済み): 通常画面へ
 - └ No: SCR-025 規約再同意割込み
 - └ 同意期限 14 日以内
 - └ Yes(同意): 通常画面へ
 - └ No(不同意): 退会フロー(SCR-024)へ誘導
- └ 同意期限超過時: 機能制限ガード(課金画面操作と新規プロジェクト作成は不可、FAQ 編集とウィジ

観点	仕様
通知タイミング	改定発効日の 30 日前
通知経路	<code>inbox(announcement/critical)+ メール (強制送信)+ ステータスページ</code>
同意期限	発効日 + 14 日(計 44 日の余裕)
同意期限超過時	SCR-025 強制割込み。ログイン自体は可能、機能制限
段階的实施	契約単位で発効日を分散
非同意時	退会フロー(SCR-024)へ誘導

9.8 8. 認証・認可エラー

詳細は [06_エラー設計書.md § 4.2-4.3](#) を正本とする。本書では主要エラーのみ。

エラー ID	発生条件	メッセージ ID	ステータスコード	システム動作
E-AUTH-CREDENTIAL	パスワード不一致	MSG-SCR-001-ERROR-001	401	失敗カウント +1。攻撃者にヒントを与えない
E-AUTH-LOCKED	5 回失敗	MSG-SCR-001-ERROR-003	423	15 分ロック。本人 + オーナー + <code>users:manage</code> 保持者へ通知
E-AUTH-TOKEN-EXPIRED	トークン期限切れ	MSG-SCR-003-ERROR-001	410	再送 CTA を返却
E-AUTHZ-FORBIDDEN	権限フラグ不足	MSG-COMMON-AUTHZ-403	403	統一文言
E-AUTHZ-OWNER-BOUNDARY	オーナー境界違反	MSG-COMMON-NOT-FOUND	404 偽装	リソース存在を漏らさない
E-AUTHZ-PROJECT-DENIED	プロジェクト割当不足	MSG-COMMON-NOT-FOUND	404 偽装	同上
E-BIZ-CONTRACT-SUSPENDED	契約停止中	MSG-BILL-CONTRACT-SUSPENDED	403	課金 / 退会 / エクスポートのみ許可
E-AUTHZ-OWNER-ONLY	オーナー専有機能をメンバーが操作	MSG-COMMON-AUTHZ-403	403	UI 非表示
E-AUTHZ-REAUTH-REQUIRED	再認証期限切れ	MSG-COMMON-REAUTH	403	再認証モーダル表示
E-AUTHZ-OWNER-PROTECTED	オーナー停止 / 削除 / 降格	MSG-COMMON-OWNER-PROTECTED	403	(FR-333)

エラー ID	発生条件	メッセージ ID	ステータスコード	システム動作
E-AUTHZ-SELF-MUTATION	自分自身の操作禁止	MSG-COMMON-SELF-MUTATION	403	(FR-334)
E-AUTHZ-TERMS	規約未同意	MSG-SCR-025-*	403 → SCR-025 へリダイレクト	規約再同意フロー

9.9 9. 未決事項

No	内容	確認先	期限	ステータス
1	利用者側 admin への MFA	基本設計書 §10.1.5 で MVP 範囲外宣言	Future	既決 (MVP リスク受容、Future 移行)—— 04_将来拡張/01_将来要件定義書.md 参照

9.9.1 9.1 MVP リスク受容 (§10.1.5)

リスク	MVP の補完策	残留リスクレベル
admin 認証情報漏洩(フィッシング/クレデンシャルスタッフィング)	(a) FR-007 ロックアウト (5 回失敗 × 15 分)、(b) FR-177 Turnstile 発動、(c) NFR-505 ログイン通知メール、(d) FR-005 重要操作前再認証、(e) FR-332 アクティブセッション一覧での異常検知	中 (MFA 導入で「低」へ低減可能)
退会・データエクスポート等の不可逆操作の不正実行	(a) FR-005 再認証必須、(b) NFR-505 操作通知メール、(c) 監査ログ (audit_logs、NFR-602a) による事後追跡	中 (MFA 導入で「低」へ)
課金情報変更の不正実行	(a) FR-005 再認証必須、(b) Stripe Elements による PCI スcope 縮小、(c) NFR-505 課金操作通知メール、(d) サスペンション解除には支払成功 Webhook 必須 (§ 6.2.7)	中 (MFA + Stripe 3DS で「低」へ)
orphan admin による単一障害点	FR-333 オーナー保護、FR-334 自己操作不可	低

運用方針: 利用者側 admin はパスワード認証で運用。リスク受容は本節および NFR-330 系セキュリティ管理で文書化。

9.10 10. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

10 セキュリティ設計書 (メイン)

10.1 1. 文書概要

10.1.1 1.1 目的

メインシステムのセキュリティ対策(データ保護/入力値検証/Web 脆弱性対策/アクセス制御/監査ログ/秘密情報管理/不正利用検知/メール配信信頼性/ウィジェット保護/PII マスキング/プロンプト注入対策)を一元化する。

10.1.2 1.2 対象範囲

- 対象: 利用者向けシステムのセキュリティ全般、**PII 暗号化 (共有概念正本)** / **暗号鍵管理 (共有概念正本)**
- 対象外: 運営者側のハッシュチェーン監査構造・3 区分保持の物理実装 ([02_運営者システム/個別設計書群/10_セキュリティ設計書.md §7](#) 正本)

10.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

10.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_索引.md
共有概念対応表	監査ログ / / PII の正本所在	../共有/共有概念.md
認証・認可設計書	認証・認可の根拠	09_認証認可設計書.md
権限設計書	アクセス制御	05_権限設計書.md
テーブル定義書	暗号化対象カラム / 監査ログテーブル	04_テーブル定義書.md
API 設計書	IF #9 不正利用検知通知	03_API 設計書.md
エラー設計書	エラー時の監査 / ログ出力	06_エラー設計書.md
運営者側 セキュリティ設計書	監査ログハッシュチェーン構造の正本	../02_運営者システム/個別設計書群/10_セキュリティ設計書.md

10.2 2. セキュリティ基本方針

10.2.1 2.1 保護対象

- ・ 利用者の PII(メール / 名前 / 個人識別情報)
- ・ エンドユーザー PII(メール)—— 基本設計書 § 7.10 / FR-114 対象
- ・ 認証情報 (パスワード / セッション / トークン)
- ・ 暗号 (マスター / バックアップ / オーナー派生 / グローバル派生)
- ・ 課金・決済情報 (Stripe 連携、カード情報は Stripe に委譲)
- ・ 監査ログ (改ざん検知必須)

10.2.2 2.2 想定脅威

- ・ 不正アクセス (クレデンシャルスタッフィング / ブルートフォース / R-005)
- ・ データ漏洩 (他契約データ参照 / R-004)
- ・ インジェクション (SQLi / XSS / プロンプト注入)
- ・ メールレピュテーション悪化 (R-003 / 共通ドメイン使用)
- ・ DDoS / Bot 暴走
- ・ AI 出力経由の機密漏洩 / PII 漏洩

10.2.3 2.3 基本対策方針

- ・ **多層防御** (認証 → 認可 → 入力検証 → 出力検査 → 監査)
- ・ **最小権限原則** (オーナー専有 / 権限フラグ / プロジェクト割当の三段階)
- ・ **監査の網羅性** (変更系操作は全て監査、参照系は高権限操作のみ)
- ・ **改ざん検知** (ハッシュチェーン + 完全性検証バッチ、運営者側 § 7 正本)

10.3 3. データ保護

10.3.1 3.1 PII 暗号化 (AES-256-GCM)+ オーナー派生鍵 (共有概念正本 = メイン側)

(基本設計書 § 10.4 + § 7.10 から移管)

対象データ	暗号化方式	鍵	保存先	ログ出力
エンドユーザーメール	AES-256-GCM	オーナー派生 (deriveOwnerKey())	inquiry_contacts.email_encrypted + email_hmac(HMAC で検索用)	不可

対象データ	暗号化方式	鍵	保存先	ログ出力
利用者メール	AES-256-GCM	オーナー派生	accounts.email_encrypted + email_hmac	不可
招待トークン / 各種トークン	HMAC-SHA256	オーナー派生 / グローバル派生	直接保存しない(ハッシュのみ)	不可

10.3.2 3.2 保護層別方針

層	方式	関連
通信	HTTPS 必須	NFR-301
HSTS	Strict-Transport-Security: max-age=31536000; includeSubDomains; preload	NFR-315
パスワード	Argon2id m=64MB, t=3, p=4, salt=16B	NFR-304
トークン	HMAC-SHA256 ハッシュ保存、オーナー / グローバル派生 使い分け	NFR-305
監査ログ	最小限情報、PII 除外	FR-114 / § 10.6.5
オーナー境界	全 API で境界検証、自動テスト月次 50 ケース + 年次手動レビュー	NFR-302
個人情報マスキング	AI 出力・チャット表示で § 13 PII Scrubber 層適用	FR-060 / NFR-805
AI 学習利用禁止	AnswerProvider learn=false 強制、Workers AI ログ無効化	NFR-405
チャット本文平文保存	DB 操作者 2 名以下 + 月次棚卸し + 全クエリ監査ログ + チケット ID 必須 (4 補完策)	NFR-319

10.3.3 3.3 データ削除モード (物理削除 / 匿名化、§7.8 から移管)

オーナー設定 `data_deletion_mode`(`physical`/`anonymize`、初期値 `physical`)

対象テーブル	物理削除	匿名化
question_logs	DELETE	user_question 空字、ip_address / user_agent NULL、集計値維持
inquiries	DELETE	user_question 空字、inquiry_code 維持、closed_reason 空字
chat_messages	DELETE	content 空字、actor_type 維持
inquiry_contacts	DELETE	email_encrypted → anon_<sha256>、display_name → 「匿名」
notification_logs	DELETE	recipient_email_hmac → SHA-256、vars → 空 JSON
access_tokens	DELETE	(常に物理削除、匿名化対象外)
audit_logs	削除しない	(tombstone 方式、匿名化対象外)

担保事項:

- ・ **不可逆性**: メールアドレスハッシュ化など、原文復元不可な置換のみ
- ・ 設定管理: SCR-016 設定画面、再認証必須
- ・ 監査: `audit_logs.action='owner.data_deletion_mode.change'`

10.3.4 3.4 お知らせ二層構成 (§7.7 から移管)

二層構造:

- ・ **配信元層 (Control Plane)**: `service_announcements` テーブル
- ・ **配信宛先層**: `announcement_recipients`(送信日時・配信失敗フラグ等、監査用)
- ・ **受信箱層 (Tenant)**: `inbox_messages`(管理者のアプリ内閲覧用)

種別	トリガー	二層構成経由	特記
announcement	運営者がお知らせを公開 (IF #7)	<code>service_announcements</code> → <code>announcement_recipients</code> → <code>inbox_messages</code>	配信集計が必要
billing	月次請求確定	直接 <code>inbox_messages</code>	契約内で完結

種別	トリガー	二層構成経由	特記
system	上限接近・超過等	直接 inbox_messages	ヘッダベル+メール (high/critical)

重複生成対策 (R-012): 同一 (owner_account_id, event_kind, dedup_key) で 60 分以内の複数発火は 1 件に集約

10.4 4. 入力値検証

対象	検証内容	対策する脅威	備考
API リクエスト	Zod スキーマ (詳細設計書)	入力エラー / 型混乱	全 API 必須
URL パラメータ	型強制 + 範囲チェック	パストラバーサル	-
ファイルアップロード	(MVP 範囲外)	-	Future
ウィジェット入力	エンドユーザー入力は先頭 100 文字 + ハッシュのみログ	PII 漏洩 / ログ膨張	FR-114
お知らせ本文	入稿時 + 表示時の 2 重サニタイズ	XSS	NFR-309
FAQ 質問文	1~500 文字	バリデーション	FR-046
FAQ 回答文	1~5,000 文字	バリデーション	FR-046

10.5 5. Web 脆弱性対策

10.5.1 5.1 HTTP 応答ヘッダ (§10.5 から移管)

Content-Security-Policy:

```
default-src 'self';
script-src 'self' 'nonce-<random>';
style-src 'self' 'nonce-<random>';
img-src 'self' data: https;;
object-src 'none';
frame-ancestors 'none';
base-uri 'self';
form-action 'self'
```

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

X-Content-Type-Options: nosniff

X-Frame-Options: DENY

Referrer-Policy: strict-origin-when-cross-origin

Permissions-Policy: camera=(), microphone=(), geolocation=()

ウィジェット側は frame-ancestors *(顧客サイト埋め込みのため)。

10.5.2 5.2 主要脅威別対策

脅威	対策	対象箇所
XSS	CSP script-src 'self' 'nonce-<random>' + 自動エスケープ + お知らせ本文 2 重サニタイズ	全画面
CSRF	Double Submit Cookie + X-CSRF-Token ヘッダ突合	全更新系 API
SQL インジェクション	プリペアドステートメント / ORM	全 DB アクセス
SSRF	外部 URL 取得時のホワイトリスト	(該当機能なし、MVP)
クリックジャッキング(管理画面)	X-Frame-Options: DENY / frame-ancestors 'none'	管理画面
クリックジャッキング(ウィジェット)	frame-ancestors を allowed_domains で制限	ウィジェット iframe
ブルートフォース	ログイン失敗 5 回ロックアウト	SCR-001 / SCR-003
HSTS	Strict-Transport-Security	全レスポンス

10.5.3 5.3 お知らせ本文サニタイズ (2 重防御)

- ・ 入稿時: 連携 IF #7 受信時にサーバ側 sanitize(許可タグ・属性ホワイトリスト)
 - ・ 表示時: GET /me/announcements/{id} 時に再度 sanitize
 - ・ 許可タグ: <p><div><h2-4><blockquote><pre><a><code>

- ・ 禁止: <script><iframe><object><embed><form><input><style> + on* イベント属性
- ・ エンドユーザー入力: お知らせ本文に一切含めない (NFR-309)

10.6 6. アクセス制御

対象	制御方法	関連設計書
利用者管理画面	セッション + 権限フラグ + オーナー境界	09_認証認可設計書.md
ウィジェット API	API キー + 署名 + allowed_domains 検証	§ 12 / 03_API 設計書.md
連携 IF	mTLS + JWT	03_API 設計書.md § 3
監査ログ参照	logs:view フラグ	05_権限設計書.md

10.7 7. 監査・ログ

(運営者側 § 7 が正本、本書はメイン側固有部分のみ)

10.7.1 7.1 ログ種別と保持目的 (§10.6 から移管)

ログ種別	対象	保持目的	保持期間
監査ログ	重要操作 (認証 / 認可境界 / 状態変更 P0 機能 / 課金 / 連携 IF / データ削除復元 / 一括操作 / セキュリティ運用 / DB 直接クエリ)	監査・不正対応	§ 7.9(1y / 5y / 7y、general / billing / operator_high_priv)
エラーログ	例外・障害	運用確認	180 日
通知ログ	メール送受信	配信状態追跡	1 年
アクセスログ	API 呼出	分析・不正検知	90 日

10.7.2 7.2 メイン側の監査対象操作 (§10.6.5 から移管)

カテゴリ	action 例	retention_class
認証関連	auth.login_success / login_failed / locked / unlocked / re_auth / password_change / token_issued / revoked	general
認可境界	<resource>.<verb>.by_operator	operator_high_priv
状態変更 P0 機能	faq.create / update / publish / delete、case.close、member.invite / activate / disable / delete	general
課金関連	billing.invoice.issued、payment.success/failure、subscription.created/cancelled、owner.suspend/resume	billing
連携 IF	integration.if1.received、integration.if10.forwarded	general(内容に応じて operator_high_priv も)
データ削除復元	data.delete.execute、<resource>.restore.by_operator、audit_log.tombstone	operator_high_priv
一括操作	inbox.read.bulk、faq.bulk_status_change、data.export	general
セキュリティ運用	key.rotation、webhook.signature_failed、abuse.detection_fired	operator_high_priv
DB 直接クエリ	db.query.execute(操作者 / クエリ / 実行時刻 / 件数記録)	operator_high_priv

10.7.3 7.3 改ざん検知方式 (NFR-306)

詳細は運営者側 10_セキュリティ設計書.md § 7 を正本とする。本書では概要のみ:

- ・ハッシュチェーン実装: 各行に prev_hash(直前行の current_hash) と current_hash(SHA-256(id, owner_account_id, actor_account_id, action, target_type, target_id, payload, created_at, prev_hash))
- ・日次ダイジェスト保管: JST 03:00 に当日分最終 current_hash 抽出 + HMAC-SHA256 署名 + R2 へ書き出し
- ・IP マスク: IPv4 末オクテット 0、IPv6 末 80 ビット 0

10.7.4 7.4 エラーログ (error_logs)

- ・180 日保持 (JST 05:00 Cron で自動物理削除、UC-140)
- ・スタックトレース / リクエスト ID を記録
- ・PII / トークン / カード情報を記録禁止 (FR-114)
- ・入力値ログ: 先頭 100 文字 + SHA-256 ハッシュのみ
- ・カテゴリ C の 5xx 系エラーは利用者にエラー ID を提示 (FR-113)

10.8 8. 秘密情報管理 (共有概念正本 = メイン側)

10.8.1 8.1 暗号鍵管理 (§10.9 から移管)

鍵種別	保管場所	用途	ローテーション周期
Master Key	Cloudflare Secrets Store	オーナー派生 ・ グローバル派生 のベース	年次
オーナー派生	動的生成 (HKDF-SHA256, info=owner:<id>)	エンドユーザーメール暗号化 ・ トークン HMAC	Master Key 更新時に再 KDF
グローバル派生	動的生成 (HKDF-SHA256, info=global)	パスワードリセット ・ API キー生成	Master Key 更新時に再 KDF
API キー	動的生成 ・ 管理者操作で選択	ウィジェット公開キー (pk_live_<32-char base62>)	7 / 30 / 90 / 180 / 365 日選択 (無期限不可)
Backup Key	別管理 (Master Key と分離)	復旧用 (AES-256-GCM 暗号化)	年次ローテーション (NFR-324)

10.8.2 8.2 ローテーション運用

操作	方式
Master Key ローテーション中	60 日 dual-decrypt(旧 と新 の両方で復号を試行)(NFR-321)、MVP ハードゲート 4-eyes 対象 (要件 §6.2.3)
API キーローテーション猶予	30 日 (FR-193)、SCR-014 に「旧キー使用中」バッジ表示
外部プロバイダ API キー (Resend / Stripe)	Workers Secrets Store 保管、90 日ローテーション を目標 (NFR-323)
漏洩検知時	(a)Secrets Store 即時ローテーション、(b)該当プロバイダ管理画面から旧キー revoke、(c)影響契約へ inbox/high 通知、(d)全運営者 ・ 管理者セッション無効化

10.8.3 8.3 ウィジェット API キー (projects / project_legacy_keys、§8.3.4 から移管)

- ・形式: pk_live_<32-char base62>
- ・有効期限: 7 / 30 / 90 / 180 / 365 日選択
- ・ローテーション: 旧キー 30 日併存
- ・旧キー使用検知: SCR-014 に警告バッジ + 件数 + 最終アクセス時刻

10.9 9. SaaS 特有のセキュリティ観点

観点	対策	関連設計書
オーナー間データ漏洩防止	全テーブルに owner_account_id + API 層でオーナー境界判定 (404 偽装) + 自動テスト (基本設計書 §14.3、月次 50 ケース)	04_ テーブル定義書.md / 09_ 認証認可設計書.md
管理者権限の濫用防止	監査ログ全件 + メンバー権限フラグの最小化 + オーナー専有機能の account_permissions 付与不可	05_ 権限設計書.md / §7

観点	対策	関連設計書
契約停止中の利用制御	contract_status=suspended で課金 / 退会 / データエクスポートのみ許可	09_ 認証認可設計書.md § 6 / 11_ 課金請求設計書.md § 5
支払い情報の取り扱い	カード情報は Stripe に委譲、自システムでは保持しない	11_ 課金請求設計書.md § 11
連携 IF の改ざん防止	mTLS + JWT + ペイロード SHA-256(運営者側 Web-hook 差分検出と連携)	03_API 設計書.md § 3.4

10.10 10. 不正利用検知 (基本設計書 §10.10 / FR-195 / NFR-308 = 共有概念正本)

10.10.1 10.1 検知・対応体系

観点	仕様
検知ロジック	メインシステム側で実装 (FR-195(a))
しきい値	IF #5 / #6 経由で契約別に上書き可能 (FR-195(b))。初期値は要件 FR-055 / FR-061
自動ブロック	レート制限緊急引き下げ・契約 suspended 遷移をメインシステム側で実行 (FR-195(c))
通知	自動ブロック発火時、管理者ユーザーへ inbox(system/high)+ email 即時通知、申し立て窓口案内 (FR-195(d) / NFR-317)
運営者手動停止	顧客管理 FR-224 から実行 (IF #1 経由)
監査	audit_logs.action='abuse.detection_fired'(retention_class='operator_high_priv')

10.10.2 10.2 検知パターン

検知パターン	検知ロジック	アクション	関連 IF
異常リクエスト	Rate limit 突破 / 異常パス	レート制限強化 + 運営者通知	IF #9
メール bounce 多発	bounce 率しきい値超過	サブレスリスト追加 + 運営者通知	§ 11
不正ログイン	同一 IP 多数 user_id ロックアウト	IP 単位ブロック + 運営者通知	IF #9
プロンプト注入試行	§ 13.2 検出パターン	ブロック + 監査 + 運営者通知	IF #9

10.11 11. メール配信信頼性・レピュテーション保護

(基本設計書 § 9.2 / § 9.3 / R-003 / FR-149b から移管)

10.11.1 11.1 メール配信信頼性 (NFR-501~507)

項目	方針
送信	API 同期処理に含めず Queue 経由 (NFR-507)
一時失敗時の自動再送	Queue Consumer による自動再送 (指数バックオフ)、最大 3 回、最大遅延 24 時間
Resend 自動再送	email.delivery_delayed で Resend が裏で再送中。当方の再送カウンタに含めない (NFR-506)
バウンス	Resend Webhook 検知、対象アドレスを通知停止 (email_suppression_list 追加)
苦情	Resend Webhook 検知、即時永久サブレス (復帰不可)
監視	契約別レート・バウンス率・苦情率をしきい値監視 (NFR-804)
サンドボックス	開発・検証環境は Resend サンドボックス使用
冪等性	event_id で重複処理を防止 (NFR-505)
DLQ	Cloudflare Queues DLQ、1 時間以内に運営者へアラート (NFR-507)

10.11.2 11.2 共通ドメインレピュテーション保護 (R-003 / FR-149b / NFR-504)

項目	方針
送信レート制限	契約別時間あたり通数の上限設定 (運営者調整可、IF #5)
バウンス率監視	しきい値超過時にアラート / 送信抑制
苦情率監視	同上

項目	方針
件名・本文	エンドユーザー入力をそのまま使わない (FR-145、なりすまし対策)
通知停止	バウンス・苦情・オプトアウトの即時反映
異常検知	短時間急増・未配信率急上昇を運営者に通知
全契約横断サプレス	email_suppression_list を全契約横断で共有 (FR-149b)
復帰承認	サプレスリスト復帰承認は運営者の SCR-093 経由 (顧客管理基本設計 § 9.4)

10.11.3 11.3 Resend Webhook 処理

イベント	処理
email.sent	notification_logs.delivery_state='sent'
email.delivered	delivery_state='delivered'
email.bounced(hard)	サプレス + 管理者ユーザー inbox 通知
email.bounced(soft)	カウンタ +1、5 回でサプレス
email.complained	即時永久サプレス + 運営者 high 通知
email.delivery_delayed	Resend 側自動再送待機、24h 後も未配信なら当方カウンタ +1
email.opened/clicked	集計のみ (個人特定なし)
署名検証失敗	即時破棄 + 運営者 high 通知 (NFR-310)

10.11.4 11.4 サプレスリスト復帰フロー

イベント	アクション	復帰方法
ハードバウンス	即時サプレス、全契約横断共有	SCR-015「再有効化申請」→ 運営者承認 (IF #5) → 復帰
ソフトバウンス 5 連続	サプレス、全契約横断共有	同上
苦情 (complaint)	即時永久サプレス	復帰不可
レピュテーション低下警告	契約送信レート -50% (IF #5)	24h 経過 + バウンス率 <1% で自動復帰

10.11.5 11.5 DLQ 運用 (§11.9 から移管)

項目	仕様
DLQ 保持期間	4 日間 (Cloudflare Queues 現行制限値)。超える保持が必要なイベント → R2 にコピー保存
自動再処理	DLQ 投入から 1 時間以内 は自動指数 BO 再試行、それ以降は運営者の明示的リプレイ操作のみ (SCR-097)
リプレイ範囲	直近 30 日 (R2 退避分を含む)。30 日超は不可
DLQ 監視	DLQ 滞留が § 8.7.2 の IF 別上限値を超えた瞬間に運営者 high 通知 + メール
署名検証失敗	即時破棄 + 運営者 high 通知 (NFR-310)

10.12 12. ウィジェット保護 (§10.2 から移管)

項目	方式
許可ドメイン検証	Origin / Referer で判定、完全一致 + *.example.com ワイルドカード
CORS	許可ドメインのみ、Access-Control-Max-Age=600
API 署名	公開キー (pk_live_<32-char base62>)+ セッショントークン組み合わせ認証
iframe sandbox	sandbox="allow-scripts allow-forms allow-same-origin allow-popups"(allow-top-navigation なし)
CSP	default-src 'self' https://api.<service>; script-src 'self'; frame-ancestors *
レート制限	プロジェクト / IP / セッション単位 (IF #5 で運営者調整可)
Bot 対策	Turnstile を必要に応じて適用 (FR-177)
入力制限	文字数 2,000、連続送信 (EU 10 件/分)、危険文字列無害化

10.13 13. PII マスキング・プロンプト注入対策

10.13.1 13.1 PII マスキング (§10.7 から移管)

観点	方針
検出器配置	Cloudflare ネットワーク内 (Workers AI + 正規表現ルール)、外部 API 送信不可
検出ルール保守	KV に保持、運営者システム (SCR-098) で更新可能
監査記録	マスキング発動: <code>audit_logs.action='ai.pii_masked'</code> 、検査 NG: <code>ai.output_inspection_failed</code> (マスク前データ非記録)
誤検出改善ループ	管理者ユーザーが「誤検出」報告 → SCR-098 に集約 → 検出ルール改善 (AC-036、3 営業日以内判定)

10.13.2 13.2 プロンプト注入対策 (§10.3 から移管)

対策	内容
FAQ 限定ポリシー固定	サーバ側でシステム指示を固定 (§ 6.4.4)、クライアント上書き不可
候補なし時	AI 生成へ進まない
出力検査	参照 FAQ 外の要素を検出 (§ 6.4.2)
不審入力検知	命令上書き等を検知・記録 (<code>audit_logs.action='ai.prompt_injection_detected'</code>)
失敗時	安全側に倒し未解決登録または安全エラー
2 段階テスト	社内 100+ ケース 95% × 必須 20 ケース 100%(AC-019 × AC-035)

10.14 14. バックアップ・復旧

(運用詳細は [03_運用/運用手順書.md](#) 参照)

項目	仕様
D1 バックアップ	Cloudflare 自動バックアップ (時間単位)
R2 バックアップ	バージョンング有効、削除はソフトデリート
復旧目標	RPO 1 時間 / RTO 4 時間
災害時手順	RB-021(メイン障害時の運営者側縮退運転)

10.15 15. 未決事項

No	内容	確認先	期限	ステータス
----	----	-----	----	-------

10.16 16. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude

\newpage

11 課金・請求設計書 (メイン)

11.1 1. 文書概要

11.1.1 1.1 目的

メインシステムの課金・契約・請求・決済を一元化する。**MVP の課金モデル**(完全従量課金 + 月次無料枠 + 14 日トライアル)、契約状態(`accounts.contract_status` 4 値)、契約ライフサイクル、契約別利用上書き、決済フロー(Stripe)を定義する。

11.1.2 1.2 対象範囲

- 対象: 利用者向け課金 UI(SCR-015 / SCR-016 / SCR-024)、契約状態管理、月次利用量計測、Stripe 連携、請求書管理
- 対象外: Stripe Webhook の一次受信・DLQ・リプレイ (02_ 運営者システム/個別設計書群/11_ 課金請求設計書.md § 13 正本)

11.1.3 1.3 版数

項目	値
版数	1.0
更新日	2026-05-17

11.1.4 1.4 関連ドキュメント

ドキュメント名	役割	参照先
索引	11 ドキュメント体系の俯瞰	00_ 索引.md
共有概念対応表	contract_status / 契約上書きテーブル	../共有/共有概念.md
権限設計書	契約別利用制限	05_ 権限設計書.md
API 設計書	連携 IF #1 / #10	03_API 設計書.md
エラー設計書	課金エラー (E-BILL-*, E-QUOTA-*)	06_ エラー設計書.md
メッセージ一覧	課金・契約メッセージ / critical 通知	07_ メッセージ一覧.md
認証・認可設計書	サスペンション中の操作制限	09_ 認証認可設計書.md
運営者側 課金・請求設計書	Stripe Webhook / DLQ / 月次請求確定 cron(正本)	../02_ 運営者システム/個別設計書群/11_ 課金請求設計書.md
要件 § 8.11	課金単位 / 機能要件の正本	../01_ 要件定義書.md

11.2 2. 契約モデル (MVP は単一プラン、共有概念正本)

11.2.1 2.1 単一プラン定義

MVP は **Free / Basic / Pro / Enterprise** の階層プランを採用しない。以下の単一モデルを全契約に適用する。

項目	MVP 仕様	正本
課金モデル	完全従量課金制 + 月次無料枠	要件 § 8.11.1 / 基本設計書 § 6.6
トライアル	14 日 (終了日翌日 00:00 JST に自動サスペンション)	§ 5.1
再課金リトライ	Stripe Smart Retries 委譲、独自リトライ禁止	§ 11.4
契約別カスタマイズ	owner_quota_overrides(resource_kind 統一実装) で契約単位に上書き (運営者操作)	§ 3 / 05_ 権限設計書.md § 7
月次境界	JST 暦月、無料枠は毎月リセット	§ 8.2
訂正請求	Stripe Credit Note API、運営者の手動操作のみ (自動禁止)	§ 11.5

11.2.2 2.2 階層プランへの拡張余地

将来的にプラン階層を導入する場合 (Future)、本書は **pricing_plans** テーブル + **accounts.plan_id** 追加で拡張可能な構造を残す。MVP では **pricing_plans** テーブルは作成しない。

11.3 3. 契約別利用上書き

運営者が契約単位で **owner_quota_overrides** テーブルを操作する (SCR-093)。**resource_kind** で統一実装 (**rate_limit_overrides / budget_limit_overrides** の別テーブルではない、テーブル定義書 04 § 3.26 参照)。

resource_kind	用途	主管 SCR(運営者)	KV ミラー
widget_ask_per_min	ウィジェット質問レート	SCR-093	あり (60s TTL)

resource_kind	用途	主管 SCR(運営者)	KV ミラー
widget_inquiry_per_min	ウィジェット未解決質問送信レート	SCR-093	あり
widget_chat_per_min	ウィジェットチャット投稿レート	SCR-093	あり
email_per_hour	メール送信レート	SCR-093	あり
admin_api_per_min	管理 API レート	SCR-093	あり

詳細は 04_ テーブル定義書.md § 3.26 参照。

11.4 4. 契約状態 (accounts.contract_status 4 値 = 共有概念正本)

(基本設計書 § 4.9 から移管)

状態	説明	利用可否	システム動作	関連メッセージ ID
active	有効	全機能	通常	-
suspended	休止中(支払い失敗 / トライアル終了)	オーナーのみ、課金画面 / 退会画面 / データエクスポート画面	ウィジェット応答は機能停止旨を返す(423、FR-138)	MSG-BILL-CONTRACT-SUSPENDED
deleted_pending	退会申請中(30 日猶予)	オーナーのみ、退会キャンセル / データエクスポート	データ参照可、新規操作不可	MSG-BILL-DELETE-PENDING
deleted	削除済み	×	アカウントスラグのみ accounts_retired に永久保持(運営者側)	MSG-BILL-DELETED

11.4.1 4.1 状態遷移詳細 (付録 B.5 から移管)

From	To	トリガー	reason	セッション処理
-	active	契約作成	-	-
active	suspended	IF #1(支払い失敗 7 日猶予経過)	payment_failure_grace_expired	継続(課金 / エクスポート / 退会のみ)
active	suspended	IF #1(運営者手動)	operator_manual / tos_violation	5 秒以内全削除 (FR-022)
active	suspended	Cron(トライアル終了 + 支払方法未登録)	trial_expired_no_payment_method	継続
suspended	active	IF #1(支払再開 / 解除)	-	再ログイン要求
active	deleted_pending	admin 退会申請 (SCR-024)	-	継続 (参照中心)
deleted_pending	active / suspended(元の状態)	admin 撤回 (30 日以内)	-	継続
deleted_pending	deleted	30 日経過 + 物理削除 Batch	-	全セッション無効化
suspended	deleted_pending	運営者退会・削除移行	-	-

11.5 5. 契約ライフサイクル

11.5.1 5.1 トライアル・本契約フロー

イベント	変更前状態	変更後状態	トリガー	関連 API
トライアル開始	(新規)	active(trial=true)	SCR-002 新規登録完了	POST /accounts
トライアル終了(支払方法未登録)	active(trial=true)	suspended	終了日翌日 00:00 JST cron	(cron)
本契約開始	active(trial=true)	active(trial=false)	支払方法登録 + 初回決済成功	POST /billing/payment-method

トライアル按分: 質問 1,000/月相当を 14 日按分 ÷ 466 件 通知: トライアル開始日、残り 3 日、終了日に inbox(billing / normal)+ email 起動: メイン Cron(JST 00:00 daily)

11.5.2 5.2 サスペンションフロー (§6.2.7 から移管)

起点イベント:

- ・支払い失敗 連携 IF #1 受信 → `reason=payment_failure_grace_expired`(7 日猶予タイマー開始)
- ・運営者手動停止 → `reason=operator_manual / tos_violation`(即時 suspended)
- ・トライアル終了 メイン Cron → `reason=trial_expired_no_payment_method`(即時 suspended、猶予なし)

認可ゲート (`accounts.contract_status=suspended` 中):

- ・許可: 課金画面 / データエクスポート画面 / 退会画面のみアクセス可
- ・その他: 403
- ・ウィジェット応答: 423(FR-138)

解除条件: 顧客管理側の連携 IF #1 受信 (支払い成功 / 運営者解除) で `accounts.contract_status='active'`(オーナー行) へ

11.5.3 5.3 退会・解約フロー (§6.2.8 から移管)

admin が SCR-024 で退会申請

- 再認証 FR-005
- `accounts.contract_status='deleted_pending'`(オーナー行)
- ウィジェット応答停止、新規 FAQ 登録不可
- 当月末まで利用可
- 月末締めで利用停止(月割りなし)
- 30 日エクスポート猶予開始
- 物理削除バッチ実行: `accounts.contract_status='deleted'`(オーナー行)
- 全データ削除 + `announcement_recipients` 削除

観点	仕様
解約予告期間	当月末まで利用可、月末締めで停止(予告期間なし)
データエクスポート猶予	退会確定から 30 日、SCR-016 から JSON/CSV エクスポート可
物理削除	30 日経過後にバッチで物理削除(NFR-704)
クーリングオフ	B2B サービスのため特商法適用外。利用規約に明示
月途中の日割り	しない(FR-125)
未請求残高返金	返金しない旨を利用規約に明記
解約 vs 退会	解約申請(サブスクリプション終了)と退会(契約削除)は別フロー

11.6 6. 契約とオーナーの関係

項目	内容
契約単位	アカウント (<code>accounts.is_owner=1</code> の行)= 1 契約
オーナー / 組織との関係	契約 = 1 オーナーアカウント。組織概念は MVP 範囲外
複数契約可否	同一メールで複数契約は不可 (<code>accounts.email_hmac</code> UNIQUE)
契約管理者	オーナーアカウント (MVP では譲渡不可、FR-333)
契約停止時の利用制限	課金画面 / 退会画面 / データエクスポートのみ

11.7 7. プラン変更時の仕様 (MVP は契約上書きのみ)

MVP は単一プランのため、プラン階層変更は存在しない。契約別上書きの追加・変更・削除のみが行われる。

変更種別	反映タイミング	課金処理	利用制限の扱い	備考
契約上書き追加(運営者操作)	即時(KV TTL 60s 経過後)	翌月から	即時適用	SCR-093 / 4-eyes 承認ログ
契約上書き削除	即時	翌月から標準値	即時標準値復帰	SCR-093 / 4-eyes 承認ログ

11.8 8. 課金方式 / 課金単位

11.8.1 8.1 課金単位 (要件 §8.11.1 / 基本設計書 §6.6.1 正本)

課金対象	計測単位	計測タイミング	失敗時の扱い	MVP 無料枠初期値	MVP 超過課金単価初期値
質問数	1 質問 = エンドユーザーが「送信」操作した 1 リクエスト	リクエスト到達時 (同期)	AI 推論失敗時もカウントするが metering_billable=false	1,000 件 / 月	0.5 円 / 件
FAQ 件数	公開状態の FAQ 件数 (下書き・非公開・削除除外)	月末 23:59:59 JST スナップショット	n/a	100 件	5 円 / 件 / 月
個別チャット部屋数	1 部屋 = 新規 chat_room レコード作成 1 件	部屋作成成功時	再オープン (自動クローズ後 30 日以内の同一 room_id 復活) はカウントしない	30 部屋 / 月	30 円 / 部屋
AI 利用コスト (原価)	推論呼び出しトークン換算 (社内可視化用)	呼び出し成功時のみ	失敗は計測のみ・課金対象外。再試行は最初の 1 回のみ計測	サービス側吸収 (MVP)	n/a (質問数単価に内包)

11.8.2 8.2 80/100/125% 三段階アクション (FR-122)

データ種別	80% 到達	100% 到達	125% 到達
質問数	inbox 通知 (billing / normal)	inbox + email (billing / high)。拒否はしない (エンドユーザー体験を優先、事後課金)	同左 + 翌 1 時間レート制限を 1/2 + 運営者へエスカレーション
FAQ 件数	inbox 通知	新規 FAQ 登録を 拒否 (既存編集は可)	同左 + 運営者へエスカレーション
個別チャット部屋数	inbox 通知	新規部屋作成を 拒否 (既存返信は可)	同左 + 運営者へエスカレーション

11.8.3 8.3 月次境界

JST 暦月。無料枠は毎月 1 日 00:00 JST にリセット。

11.8.4 8.4 通貨 / 税計算

項目	内容
通貨	JPY
税計算	日本国内 10% 固定か顧客管理 IF #10 経由か (未決事項 No.1)

11.9 9. 請求対象

対象	課金条件	金額算出方法	備考
月次無料枠超過分 (質問数)	100% 超過	(超過件数 × 単価)	拒否しない、事後課金
月次無料枠超過分 (FAQ 件数 / チャット部屋)	100% 超過	(超過件数 × 単価)	拒否 (E-QUOTA-*429 + Retry-After)
トライアル中	課金しない	0 円	14 日
サスペンション中	課金しない (月次集計対象外)	0 円	-

11.10 10. 請求状態

請求状態	説明	システム動作	関連エラー ID
未請求	月次集計前	-	-
請求済み	請求書発行済、Stripe 決済中	-	-

請求状態	説明	システム動作	関連エラー ID
支払い成功	Stripe 決済成功	-	-
支払い失敗 (Smart Retries 中)	Stripe Smart Retries 中	-	-
支払い失敗確定 (3 回失敗後)	Smart Retries 終了	顧客 IF #1 「決済失敗確定」 イベント	E-BILL-PAYMENT-FAILED
返金済み	Stripe Credit Note API	-	-
取消済み	運営者手動	-	-

11.11 11. 決済フロー

フロー ID	フロー名	概要	関連 API	外部サービス
BILL-FLOW-001	支払い方法登録	Stripe Setup Intent → 支払方法保存	POST /billing/payment-method	Stripe
BILL-FLOW-002	初回決済	トライアル終了時 or 即時本契約時	(Stripe 経由)	Stripe
BILL-FLOW-003	継続課金 (月次)	月初 1 日 02:00 JST cron(運営者側 § 11 正本)	(cron + IF #10)	Stripe
BILL-FLOW-004	支払い失敗	Stripe Smart Retries → 3 回失敗 → IF #1	(IF #1 受信)	Stripe
BILL-FLOW-005	返金	Stripe Credit Note API(運営者手動)	(運営者側 API)	Stripe
BILL-FLOW-006	訂正請求	Stripe Credit Note API(運営者手動、自動禁止)	(運営者側 API)	Stripe

11.11.1 11.4 Stripe Smart Retries 委譲 (基本設計書 §6.6.4)

観点	仕様
再課金リトライ	Stripe Smart Retries に委譲、独自リトライ実装は行わない
失敗確定	最大 3 回失敗後にメイン側へ「決済失敗確定」 イベント送信 (連携 IF #1)
猶予期間	7 日間 (顧客管理側からのイベント受信時刻起点)
猶予中の操作	管理者ユーザーは管理画面の課金画面・データエクスポート画面・退会画面のみアクセス可、それ以外は 403
解除条件	管理者ユーザーが課金画面から手動で支払方法更新 → 即時再決済 → 成功なら顧客管理側が解除イベント発火 → 連携 IF #1 で accounts.contract_status='active'(オーナー行)
訂正請求	Stripe Credit Note API 経由、運営者の手動操作のみ (自動禁止)

11.12 12. 外部決済サービス連携 (Stripe)

連携先	連携内容	連携方式	Webhook 有無	備考
Stripe	サブスクリプション / 支払方法 / Smart Retries / Credit Note	REST API + Webhook	あり (IF #10 経由、運営者側 § 13 正本)	-

11.13 13. Webhook 処理 (運営者側 §13 が正本、本書は参照)

メイン側で扱う Webhook 関連処理:

- IF #1(契約停止イベント) 受信: accounts.contract_status 更新 + キャッシュ無効化 + セッション処理
- IF #10 経由で渡される Stripe 関連の通知

詳細仕様は [02_運営者システム/個別設計書群/11_課金請求設計書.md §13](#) を正本とする。

11.14 14. 請求書・領収書

帳票	発行タイミング	記載項目	ダウンロード可否	保持期間
請求書	月次集計確定時	利用量 / 請求金額 / 税 / 期間	SCR-015 から PDF ダウンロード (R2 署名 URL 有効期限 5 分)	7 年 (電子帳簿保存法、運営者側正本)
領収書	支払い成功時	支払金額 / 支払日	SCR-015 から PDF ダウンロード	7 年

帳票仕様 (PDF 出力有無 / 税計算ルール / インボイス制度対応) は未決 —— 未決事項 No.1 参照。

11.15 15. 課金・契約エラー時の動作

ケース	システム動作	ユーザー表示	メッセージ ID
月次無料枠 100% 超過 (FAQ / チャット部屋)	新規操作 429 + Retry-After(月末まで)	「上限に到達しました」 + 課金ダッシュボード誘導	MSG-QUOTA-*
月次無料枠 100% 超過 (質問数)	拒否しない (事後課金)	「無料枠を超過しました。125% までは事後課金で継続利用できます」	MSG-QUOTA-QUESTIONS-100
契約停止中 (contract_status='suspended')	課金 / 退会 / データエクスポート以外 403	サスペンション理由 + 再決済誘導	MSG-BILL-CONTRACT-SUSPENDED
支払い失敗	7 日猶予期間カウント開始 + メール通知 (critical)	「お支払いが確認できませんでした」 + 課金画面誘導	MSG-BILL-PAYMENT-FAILED
支払い方法未登録 (トライアル終了時)	サスペンション + メール通知 (critical)	「お支払い方法を登録してください」	MSG-TRIAL-EXPIRED
退会済み契約	403、ログイン拒否	「アカウントが削除されています」	MSG-BILL-DELETED

11.16 16. 月次集計フロー (§6.2.10 から移管)

項目	仕様
実行頻度	月初 1 日 02:00 JST(運営者側 §11 正本)
対象期間	前月の利用量
処理内容	1. usage_metering から月次集計、2. 契約上書き適用、3. billing_invoices 作成、4. Stripe 請求作成 (IF #10 経由)、5. 通知メール (high)
冪等性	同一月の二重実行はスキップ (billing_invoices.unique(owner, period))
エラー処理	個別契約失敗時は他契約継続、DLQ 投入
監査	audit_logs.action='billing.monthly_close'(retention_class=billing)

11.17 17. 未決事項

No	内容	確認先	期限	ステータス
1	請求書帳票仕様 (PDF 出力有無 / 税計算ルール / インボイス制度対応の項目)	既存ドキュメントに帳票フォーマットなし	-	要確認

11.18 18. 変更履歴

日付	版数	変更内容	変更者
2026-05-17	1.0	初版作成	claude